A DORA-aligned cyber resilience metrics framework

Maria Aguilar

Monika Didziulyte

Master's Degree Project in
Open eGovernment
Autumn term 2026
Supervisor: Simon Hacks
Department of Computer
and Systems Sciences



Stockholm
University

Abstract

Introduction Financial institutions increasingly depend on interconnected ICT systems and shared infrastructure, making operational resilience a strategic regulatory priority. The Digital Operational Resilience Act (DORA) requires institutions to operationalize ICT risk management objectives, including the monitoring of key performance indicators and risk metrics, but prescribes neither which metrics to use nor how to derive them. To address this gap, this thesis develops an expert-informed DORA-aligned Cyber Resilience Metrics Framework.

Research Question This thesis asks which DORA ICT Risk Management requirements can be translated into measurable indicators (RQ1), how a structured and traceable framework can operationalize these requirements into quantitative metrics (RQ2), and to what extent such a framework meets the practical operational resilience needs of credit institutions (RQ3).

Method Following a Design Science Research methodology, a systematic literature review grounded the problem, and the Goal-Question-Metric (GQM) approach was applied to Articles 6-13 of DORA to derive a metrics framework, which was then refined through six semi-structured expert interviews spanning policy, financial industry, and cybersecurity perspectives.

Results The thesis resulted in an expert-evaluated Cyber Resilience Metrics Framework comprising 14 goals and 50 quantitative metrics. Findings across the three research questions show that: (1) DORA requirements are translatable into technically observable indicators when they concern the framework's technical execution – the observable behavior of systems and processes – rather than its design; (2) the GQM approach proved suitable

for developing a traceable Cyber Resilience Metrics Framework; and (3) expert evaluation confirmed a genuine practical need among credit institutions to monitor and improve their cyber resilience capabilities, one that the developed framework addresses.

Discussion The framework offers a traceable and flexible set of indicators rather than a mandatory checklist, with threshold calibration left to each institution. While the development approach was validated through iterative expert feedback, the framework itself was evaluated through expert assessment rather than field deployment. Future work should therefore prioritize empirical threshold calibration, extension to third-party risk management, and development of a complementary qualitative assessment approach for governance and organizational requirements.

Keywords: cyber resilience, DORA, digital business ecosystems, ICT risk management, Goal-Question-Metric, metrics framework, financial institutions, regulatory compliance

Abbreviations

Abbreviation	Description
AI	Artificial Intelligence
BCP	Business Continuity Plan
DBE	Digital Business Ecosystem
DORA	Digital Operational Resilience Act
DSR	Design Science Research
EU	European Union
GDPR	General Data Protection Regulation
GQM	Goal-Question-Metric
ICT	Information and Communication Technologies
IS	Information Systems
IT	Information Technology
KPI	Key Performance Indicator
MFA	Multi-Factor Authentication
MTTD	Mean Time To Detect
MTTR	Mean Time To Respond
RQ	Research Question
RPO	Recovery Point Objective
RTO	Recovery Time Objective

SIEM/XDR	Security Information and Event Management / Extended Detection and Response
SLR	Systematic Literature Review

List of Figures

3.1 DSR process followed in this study, adapted from Peffers et al. [46]. 15

4.1 Scoping decision tree for the GQM-based derivation of the Cyber Resilience Metrics Framework 34

List of Tables

2.1 Two-stream categorization of related-work 11

3.1 List of interviewees 20

4.2 Requirement-to-Goal translation for **Req** 29
4.4 Goal-to-Question translation 30
4.6 Question-to-Metric translation for **Q22.1** and **Q22.2** from **G22** 31
4.8 Resilience metrics structure for metrics derived from G22 . . 33
4.13 Cyber Resilience Metrics Framework with GQM traceability to DORA source articles 42

A.1 Inclusion and exclusion criteria 70
A.2 Identification of studies via databases 73
A.3 Articles retained for Ddta extraction in the Systematic Literature Review 79

B.1 Requirement-to-Goal translation for Article 6 requirements . 85
B.2 Requirement-to-Goal translation for Article 7 requirements . 86
B.3 Requirement-to-Goal translation for Article 8 requirements . 87
B.4 Requirement-to-Goal translation for Article 9 requirements . 89
B.5 Requirement-to-Goal translation for Article 10 requirements 90
B.6 Requirement-to-Goal translation for Article 11 requirements 92
B.7 Requirement-to-Goal translation for Article 12 requirements 94
B.8 Requirement-to-Goal translation for Article 13 requirements 95
B.9 Thematic consolidation of overlapping goals 97
B.10 Consolidated G3 from goals refinement 97
B.11 Consolidated G5 from goals refinement 98
B.12 Consolidated G6 from goals refinement 98
B.13 Consolidated G7 from goals refinement 99
B.14 Consolidated G8 from goals refinement 99
B.15 Consolidated G11 from goals refinement 99
B.16 GQM Step 1: Requirement-to-Goal translation 105

B.17 GQM Step 2: Goal-to-Question translation 108
B.18 GQM Step 3: Question-to-Metric translation 115
B.19 Full metric catalog and specs 127

D.1 Example of the metric design 135
D.2 Example of the metric structure 135
D.3 DORA KPI evaluation overview 137
D.4 Resilience KPI evaluation overview 142

Contents

Abstract **iii**

Abbreviations **v**

List of Figures **vii**

List of Tables **ix**

Contents **xi**

1 Introduction **1**
1.1 Problem statement 2
1.2 Research objective and contribution 2
1.3 Research questions 3
1.4 Delimitations 3
1.5 Limitations 4
1.6 Thesis structure 4

2 Background **5**
2.1 Digital Business Ecosystems 5
2.2 Cyber and operational resilience 6
2.3 DORA regulatory context 7
2.3.1 ICT Risk Management under DORA 7
2.3.2 Measurable aspects of DORA's ICT Risk Management pillar 7
2.4 Related work 8
2.4.1 Existing resilience metrics frameworks 8
2.4.2 Types of cyber resilience metrics 9
2.4.3 Gaps in existing frameworks 12

3 Research methodology **13**
3.1 Research strategy: Design Science Research approach 13
3.1.1 Alternative DSR methodologies 14
3.1.2 DSR process overview 14
3.2 Systematic Literature Review 16
3.3 GQM-based Cyber Resilience Metrics Framework design . . 17
3.3.1 Alternative methodological approach to developing metrics 18
3.4 Demonstration and evaluation: expert interviews 18
3.4.1 Semi-structured interviews 19
3.4.2 Approach to interview analysis 22
3.4.3 Evaluation and validation outcomes 23

4 Resilience Metrics Framework **25**
4.1 Design objectives and scope 25
4.2 Framework design 27
4.2.1 Requirement-to-Goal translation 27
4.2.2 Goal-to-Question Translation 30
4.2.3 Question-to-Metric translation 31
4.3 Metric structure 31
4.4 Full framework overview 33

5 Results **43**
5.1 Framework coherence and scope 44
5.1.1 GQM approach to framework development 44
5.1.2 Framework coherence 44
5.1.3 Framework scope 46
5.2 Metric relevance and practical applicability 47
5.3 Completeness 48

6 Discussion **51**
6.1 Requirements translatable into technically observable and measurable indicators (RQ1) 51
6.2 Suitability of the GQM approach for developing a traceable Cyber Resilience Metrics Framework (RQ2) 52
6.3 Addressing the practical needs of credit institutions for evaluating operational resilience (RQ3) 53
6.4 Relation to previous research 53
6.5 Limitations 55
6.6 Future work 56

7 Conclusion **57**

A Explicit systematic literature review plan and protocol **67**
A.1 SLR protocol 67
A.1.1 Purpose of the review 67
A.1.2 Structured review protocol 68
A.1.3 Backward snowballing 72
A.2 SLR findings 72
A.2.1 Selection process 72
A.2.2 Descriptive statistics of publications 73
A.2.3 Descriptive synthesis of key insights from the studies 74
A.2.4 Identification of research gaps and future research directions 76

B Explicit GQM Application **81**
B.1 GQM Phase 1: Requirement-to-Goal 82
B.1.1 Goal refinement and consolidation 96
B.2 GQM Phase 2: Goal-to-Question 105
B.3 GQM Phase 3: Question-to-Metric 108
B.4 Metric structure 115

C Consent Form **129**

D Complementary Interview Materials **133**
D.1 Annex A: Metrics and their attributes 139

Appendices **67**

1

Introduction

Credit institutions operate within increasingly complex digital business ecosystems (DBEs), where operational continuity depends on interconnected ICT systems, third-party service providers, and shared infrastructure [18]. In this environment, resilience – an organization's capacity to withstand, recover from, and adapt to disruptions [18, 34] – is both an individual organization's property and a systemic concern. This is because disruptions may not remain contained within a single entity but propagate across the ecosystem. The failure of one component can cascade through interdependent systems and services [18]. Consequently, the ability to measure and monitor operational resilience has become both a strategic and regulatory priority, requiring structured, indicator-based approaches capturing systemic conditions rather than isolated organizational states [41, 8].

The Digital Operational Resilience Act (DORA) is a European Union regulation (Regulation EU 2022/2554) [19] that aims to strengthen and harmonize cyber resilience across the financial sector.[1] Effective since January 2025, DORA establishes requirements across five pillars: ICT Risk Management, Incident Reporting, Digital Operational Resilience Testing, ICT Third-Party Risk Management, and Information Sharing. This thesis focuses on ICT Risk Management, as it forms the foundation of the regulatory framework and is the pillar most suitable for systematic, indicator-based measurement.

[1] Article 2 defines the scope of the regulation and the financial entities to which it applies. This study focuses specifically on credit institutions, such as banks.

1.1 Problem statement

DORA requires financial institutions to develop key performance indicators and risk metrics to monitor and assess the effectiveness of their resilience measures [30]. However, neither DORA nor its regulatory technical standards prescribe a specific set of metrics or a methodology for developing or selecting them. Institutions are expected to define indicators appropriate to their size, complexity, and risk profile, without a structured framework to guide that process [10].

At the same time, existing resilience measurement frameworks are either domain-agnostic, focused primarily on organizational performance, or insufficiently aligned with the specific requirements of DORA [4, 41, 35]. While resilience frameworks have been developed for sectors such as maritime, energy, and telecommunications, they cannot be directly applied to the financial sector without losing the regulatory specificity required by DORA [31, 39]. Furthermore, based on the studies reviewed, no framework systematically translates DORA's ICT Risk Management requirements into measurable, operational indicators for credit institutions operating within interconnected DBEs [11, 30].

In summary, **there is a gap between regulatory expectations and practical tooling: credit institutions are obliged to demonstrate measurable operational resilience under DORA's ICT Risk Management pillar, yet no structured, regulation-specific framework exists to guide the derivation of such metrics**. This is the problem addressed by this thesis.

1.2 Research objective and contribution

To address this problem, this thesis applied the Goal-Question-Metric (GQM) approach to DORA's ICT Risk Management pillar within a Design Science Research methodology, resulting in a framework of measurable, quantitative cyber resilience metrics that was evaluated through expert interviews. The framework enables credit institutions not only to assess whether core operational resilience mechanisms are in place, but also whether these mechanisms are applied consistently, operate effectively, and align with both regulatory compliance requirements and internal institutional thresholds [8].

1.3 Research questions

The following research questions guide this thesis:

- **RQ1:** Which requirements within DORA's ICT Risk Management pillar can be translated into technically observable and measurable indicators?
- **RQ2:** How can a structured and traceable framework be designed to operationalize DORA's ICT Risk Management requirements into measurable operational cyber resilience metrics for credit institutions operating within DBEs?
- **RQ3:** To what extent does the proposed Cyber Resilience Metrics Framework address the practical operational resilience needs of credit institutions in alignment with DORA's ICT Risk Management requirements?

The research questions are intentionally sequential and build on one another. **RQ1** establishes the scope of what can be measured within DORA's ICT Risk Management pillar, providing the foundation for framework development. **RQ2** addresses the central design challenge of systematically deriving quantitative cyber resilience metrics from regulatory requirements using the GQM approach. Finally, **RQ3** focuses on validation and refinement, incorporating expert feedback not only to assess the framework's relevance, applicability, and practical feasibility, but also to support the iterative improvement of both individual metrics and the framework as a whole.

1.4 Delimitations

This thesis focuses exclusively on quantitative technical cyber resilience metrics. This scope was chosen intentionally to develop a comprehensive set of measurable indicators that can support credit institutions in monitoring their resilience based on data they currently collect or could feasibly collect.

Qualitative methods are better suited for assessing non-technical and organizational aspects of DORA, including requirements related to management bodies and accountability, governance structures, and human resource obligations. While some of these dimensions may be partially evaluated through quantitative measures, they are generally more effectively assessed through qualitative auditing and review practices. Addressing these

aspects is therefore beyond the scope of this thesis. Notably, however, the framework development approach proposed in this study is not limited to technical requirements: the same GQM-based derivation process could be applied to the organizational and governance provisions of DORA, which represents a natural direction for future research.

1.5 Limitations

At the same time, the study faced several limitations. Access to experts was constrained by the financial sector's regulatory and operational restrictions, making it challenging to engage practitioners with relevant profiles within the study's timeline. While six interviews were conducted, a larger and more diverse sample would have strengthened the study, as interviews were critical for guiding metric selection, scope, prioritization, and for providing qualitative context on DORA implementation.

A related limitation concerns the metrics themselves. Despite a thorough review of the ICT Risk Management pillar, careful metric design, and evaluation through high-quality interviews, the metric set may not be fully comprehensive. New areas of interest and concern emerged during interviews, and the scope of DORA is extensive, making complete coverage difficult within a single study.

1.6 Thesis structure

The remainder of this thesis is organized as follows: Chapter 2 reviews DBEs, DORA's ICT Risk Management requirements, and existing resilience metrics. Chapter 3 outlines the Design Science Research methodology, including the systematic literature review, the GQM-based framework design process, and the evaluation of the framework through expert reviews. Chapter 4 presents the complete Cyber Resilience Metrics Framework, its design rationale, and the resulting indicator set. Chapter 5 reports the validation of the approach, the evaluation of the framework through expert interviews, and the resulting refinements. Chapter 6 interprets the findings, highlights implications, and suggests directions for future research. Chapter 7 concludes the study.

2

Background

2.1 Digital Business Ecosystems

The **Digital Business Ecosystem (DBE)** extends Moore's concept of a business ecosystem, defined as an economic community of interconnected organizations and individuals that collaboratively create value [28]. By integrating digital technologies, automation, and real-time data exchange, DBEs create technology-driven environments characterized by dynamic interactions among participants [48]. With digital technologies embedded in products, services, and business processes, organizations become increasingly interconnected and interdependent. Consequently, disruptions in one part of the ecosystem can rapidly propagate across multiple participants.

The financial sector is a prominent example of a DBE. Banks, payment processors, insurers, cloud service providers, and regulators are linked through complex contractual, operational, and data dependencies. As a result, disruptions affecting a single participant may cascade across the broader ecosystem, making cyber resilience a systemic rather than purely organizational concern [18]. This interdependence has motivated regulatory initiatives to strengthen resilience across the sector, most notably the Digital Operational Resilience Act (DORA).

2.2 Cyber and operational resilience

Because disruptions affecting one participant in DBEs can expose the entire ecosystem to risk, digital technology adoption shapes how ecosystems anticipate, absorb, and respond to disruptions, making resilience central to managing this interdependence [21]. In the context of financial institutions, Dupont [18] defines **cyber resilience** as the capacity to withstand, recover from, and adapt to external shocks caused by ICT-related incidents. This definition includes the three key phases that recur across cyber resilience frameworks: resistance, recovery, and adaptation [38, 4, 23]. Cyber resilience assumes that some incidents will inevitably occur and focuses on minimizing their impact and duration [18, 41]. **Operational resilience** is another key concept of this thesis. It encompasses cyber resilience but extends to the full set of operational capabilities required to deliver critical business services [11, 41, 35]. The relationship is hierarchical: cyber resilience is a necessary but not sufficient condition for operational resilience [11]. This follows from operational resilience broader objective: it depends on the preparedness of processes and resources, not only IT systems, and financial institutions report supplier relationships and resource constraints among practical challenges to sustain it [1]. This distinction matters for how the concept is reflected in regulation.

In the European financial sector, these concepts have been codified in DORA: Article 3 defines digital operational resilience as a financial entity's ability to build, assure, and continuously review the integrity and reliability of its ICT-related capabilities – whether provided directly or through third-party ICT service providers – to secure its network and information systems and sustain the provision and quality of financial services, including during disruptions [19, Art. 3]. This definition frames resilience as a capability to be built, assured, and reviewed on an ongoing basis, implying that it must be observable and assessable in practice.

This thesis adopts cyber resilience as the guiding concept for the framework developed in the following chapters, relying on a definition aligned with DORA's own conception of resilience. Although the term *operational* does not appear in the framework's name, its scope is implicit: the metrics and the overall framework are designed to support the monitoring of ICT systems critical to the continued operations of credit institutions.

2.3 DORA regulatory context

DORA's rationale stems from the financial sector's growing reliance on technology to deliver services, which increases its exposure to cyber attacks and operational disruptions. This thesis focuses on the ICT Risk Management pillar, which forms the foundation of the regulatory framework and is the pillar most amenable to systematic, indicator-based measurement.

2.3.1 ICT Risk Management under DORA

DORA's ICT risk management requirements are set out primarily in Articles 5 through 16. Article 6 requires financial entities to maintain a "*sound, comprehensive and well-documented ICT risk management framework*" as part of their overall management system **[Art.6]**. The subsequent articles structure this obligation along a set of capability dimensions: identification of ICT risks, protection and prevention, detection, response and recovery, learning and evolving, and communication. These dimensions form the foundation of DORA's ICT risk management requirements and provide the structure for deriving measurable cyber resilience indicators.

The framework must include strategies, policies, procedures, protocols, and technical tools to protect information assets and ICT systems. It must be formally documented, regularly reviewed, and overseen by the management body, which bears ultimate accountability for ICT risk management [30, 10]. It should also define methods for addressing ICT risks and achieving ICT-related objectives, including clearly defined information security goals operationalized through **key performance indicators (KPIs)** and **key risk metrics**.

While DORA mandates the use of such indicators, it provides limited guidance on their design and operationalization. This creates a need for systematic approaches to developing measurable and actionable resilience metrics, which this thesis addresses.

2.3.2 Measurable aspects of DORA's ICT Risk Management pillar

The requirements outlined above are primarily qualitative, reflecting the principles-based nature of EU regulation, which allows institutions to tailor implementation and assessment practices to their specific context. Nevertheless, several aspects are amenable to quantitative or semi-quantitative measurement. For example, the proportion of ICT assets inventoried and

classified, as well as recovery time objective and recovery point objective targets, are inherently measurable. Similarly, resilience capabilities such as detection and response can be operationalized through metrics including mean time to detect and mean time to respond[9, 3].

Importantly, this reflects the design of DORA itself, which intentionally adopts a broad, principles-based approach rather than prescribing a standardized set of metrics. While some guidance exists on monitoring ICT risk and operational resilience, there is no exhaustive or harmonized list of indicators aligned with the regulation beyond a limited set of metrics associated with mandatory ICT incident reporting. This flexibility is deliberate but results in limited standardization in the translation of regulatory requirements into measurable indicators – a gap that this thesis seeks to address.

2.4 Related work

This thesis contributes to Information Systems research on the operationalization of regulatory requirements into measurement instruments, at the intersection of cyber resilience measurement and IT governance. The systematic literature review (SLR), conducted to frame the problem and inform the design choices of this study, identified two key aspects of the related literature: existing resilience metrics frameworks and the types of metrics used to measure cyber resilience across organizations (see Appendix A (Explicit systematic literature review plan and protocol)).

2.4.1 Existing resilience metrics frameworks

A **metrics framework** is a structured set of indicators designed to operationalize abstract concepts into measurable quantities that can be tracked, compared, and used to guide decision-making [5]. Effective resilience metrics frameworks share several common properties: they are multi-dimensional, capturing both technical and organizational aspects; temporally sensitive, tracking changes over time; actionable, with indicators granular enough to guide improvement; and aligned with governance or regulatory references [41, 35, 9].

The SLR identified several complementary approaches. Linkov et al. [38] proposed a four-phase resilience model – plan/prepare, absorb, recover, adapt – that forms the foundation of many subsequent frameworks. Bodeau and Graubart [8] and Bodeau et al. [9] operationalized this model for the cyber domain, producing a taxonomy of cyber resilience metrics

that distinguishes between structural metrics (system properties) and operational metrics (observed behavior under stress). Overall, approaches can be grouped into three distinct categories:

- **Maturity-based frameworks**, which assess resilience through capability maturity levels, enabling benchmarking and progression tracking [41, 35];
- **Quantitative risk-integration frameworks**, which express resilience as a computable function of threat likelihood, control effectiveness, and recovery capacity [15, 3]. These offer precision but often require data that is unavailable in practice;
- **KPI-oriented frameworks**, which focus on specific, measurable indicators suitable for routine collection and regulatory reporting [13, 32, 10].

This thesis builds on the KPI-oriented approach, developing a framework of measurable cyber resilience indicators aligned with DORA's ICT Risk Management pillar and validated by domain experts. This approach aligns with the regulation itself, which requires information security objectives to be operationalized through KPIs and risk metrics, thereby directly tracing regulatory requirements to measurement instruments.

2.4.2 Types of cyber resilience metrics

Through SLR, **performance metrics** were identified as the most frequently cited category. These metrics capture an organization's operational capacity to detect, respond to, and recover from cyber disruptions, and are typically expressed as time-based indicators such as detection latency, response speed, and recovery time, as well as accuracy-oriented measures like false positive rate and incident escalation accuracy [11, 23, 25, 2, 20, 35, 39]. Their prevalence in the literature reflects a broad consensus that measurable, time-sensitive indicators are central to assessing cyber resilience in practice.

Technical and **compliance metrics**, while less frequently discussed, are equally relevant to the understanding of resilience measurement approaches. Technical metrics address system-level attributes such as reliability, scalability, and vulnerability exposure, reflecting the infrastructure conditions that underpin an organization's resilience positioning [7, 39]. Compliance metrics cover regulatory adherence indicators including reporting completeness, testing frequency, and compliance rates [11, 36, 13], a noticeably

underrepresented area given the binding obligations imposed on institutions in highly regulated sectors like financial services.

Although **organizational metrics** appear frequently in the literature (e.g., maturity scores, governance indicators – see Appendix A), they fall outside this thesis's scope, as they measure process adoption rather than directly observable ICT resilience outcomes mappable to DORA's requirements. Only technical, performance, and compliance metrics were therefore carried forward. To structure the related work more precisely, Table 2.1 organizes the literature into two streams, highlighting the most relevant articles on metrics frameworks and the regulatory dimension of resilience measurement.

Overall, the SLR identified 29 relevant articles across multiple domains (see Appendix A); the two streams below focus specifically on those most directly informing this thesis's DORA-aligned Cyber Resilience Metrics Framework for credit institutions.

Stream	Author(Year)	Description
Metrics frameworks for cyber and operational resilience	Linkov et al. (2013)	Provided a foundational four-phase resilience framework that has influenced many subsequent resilience frameworks.
	Bodeau and Graubart (2015, 2018)	Operationalized Linkov's work for the cyber domain, producing the most comprehensive open taxonomy of cyber resilience metrics and measures of effectiveness. Their distinction between structural and operational metrics was directly relevant to the metrics' design choices made in this thesis.
	AlHidaifi et al. (2024)	Extended Bodeau and Graubart's work, developing a cyber resilience quantification framework for IT infrastructure.
	Mbanaso et al. (2019) and Kulugh et al. (2022)	Developed maturity-based measurement models establishing precedent for structured, level-based assessment.

Stream	Author(Year)	Description
	Ko et al. (2025)	Demonstrated the viability of translating generic cyber resilience constructs into domain-specific KPIs in the maritime sector. Their methodological approach was foundational for this thesis.
Regulatory dimension of resilience measurement	Dupont (2019)	Provided a comprehensive approach to cyber resilience in the financial sector. Offered an analytical lens for understanding how the industry has institutionalized resilience through standards, regulatory compliance tools, and cybersecurity practices.
	Cojocaru (2025)	Developed a theoretical framework, aligning regulation and governance for cyber resilience in the UK financial sector, offering a structurally comparable exercise in a different jurisdiction.
	Kanepa et al. (2025)	Assessed DORA's impact on IT governance, identifying organizational changes DORA demands but stopping short of proposing measurement instruments.
	Bose and Caulfield (2026)	Proposed a KPI-level cyber risk framework for board governance, representing the closest existing work in terms of scope, though not anchored to DORA's specific ICT risk management requirements or the DBE context.

Table 2.1: Two-stream categorization of related-work

Together, both streams confirm the relevance and novelty of this thesis. The intersection of DORA-aligned ICT risk management, quantitative KPI frameworks, and financial DBE resilience has not been addressed as an integrated problem.

2.4.3 Gaps in existing frameworks

The SLR revealed that no identified framework has been specifically designed to operationalize DORA's ICT Risk Management requirements into measurable cyber resilience metrics for financial DBEs. Several frameworks address cyber resilience generically without regulatory anchoring [4, 9]; others are oriented towards sectors such as maritime, energy, or telecommunications [32, 22, 36]. This thesis addresses the resulting gap by translating DORA's ICT Risk Management requirements into a quantitative cyber resilience framework for credit institutions operating within DBEs, using a systematically derived and expert-validated approach.

3

Research methodology

3.1 Research strategy: Design Science Research approach

This thesis adopted a **Design Science Research (DSR)** methodology. Unlike purely descriptive research approaches, DSR is characterized by the systematic creation of artifacts intended to solve identified problems and by the evaluation of these artifacts in context [17]. The methodology also has an established track record in complex socio-technical environments, having proved effective for analyzing and improving large-scale systems composed of interacting technological and organizational components [50]. Financial ICT infrastructure is precisely such an environment: its resilience depends on the interplay of technological and organizational factors distributed across interconnected entities. In line with this, the primary outcome of this thesis is not merely theoretical but practical: **an expert-informed cyber resilience measurement framework** that can support financial-sector organizations in operationalizing resilience requirements under DORA, as well as in monitoring the resilience of their ICT systems and their compliance with the regulation.

Having established DSR as the appropriate research strategy, the next step was to select among several DSR methodologies available in the literature, which differ in process structure and in the type of artifact they support best.

3.1.1 Alternative DSR methodologies

Venable et al. [29] provide an account of Design Science Research methodologies and compare them to help researchers choose among them. Of the six, three are objectivist and positivist in orientation: the Systems Development Research Methodology (SDRM), the DSR Process Model (DSRPM), and the methodology we selected, Design Science Research Methodology (DSRM) by Peffers et al. [46]. These aligned with our objective of creating an optimal artifact. To guide selection among them, the authors propose a framework: SDRM is the preferred choice when the intended outcome is an IT system, DSRPM when the aim is to develop design theory, and DSRM when the artifact requires extensive adaptation to daily use. Because our objective was to develop a framework that makes it easier for credit institutions to monitor cyber resilience and comply with DORA, one that practitioners must adapt to their institutional context and apply in routine operations, DSRM was best suited.

3.1.2 DSR process overview

To structure the research process, this study followed the DSR methodology proposed by Peffers et al. [46], whose framework outlines **six core activities** that guide the development of design science artifacts. For each activity, the concrete research methods employed in this thesis are indicated below:

- **Problem identification and motivation.** The problem – the absence of DORA-aligned cyber resilience measurement instruments tailored to financial DBEs – was identified through and motivated by a systematic literature review (SLR) (Section 3.2), which mapped existing resilience measurement research and confirmed the gap described in Section 2.4 Related work. The problem statement and its practical relevance are presented in Chapter 1;

- **Definition of objectives for a solution.** The SLR findings were used to translate the identified problem into design objectives. The study team aimed to ensure that the developed framework derived metrics traceably from DORA's ICT Risk Management requirements, producing quantitative and technically observable indicators. The practical feasibility of implementing the framework using the data credit institutions can collect was also prioritized. These objectives operationalized the research questions posed in Chapter 1;

- **Design and development.** The Cyber Resilience Metrics Framework was developed using the Goal-Question-Metric (GQM) approach [5], which allowed translating regulatory requirements into goals, assessment questions, and metrics (Section 4.2);
- **Demonstration.** The framework's structure, components, and intended application were presented to domain experts through complementary materials shared in advance of each interview, as well as a guided walkthrough of the GQM derivation logic during the interviews themselves (Section 3.4);
- **Evaluation.** The artifact was assessed through six semi-structured expert interviews, analyzed using a deductive, criteria-based approach (Section 3.4);
- Finally, the outcomes of the research were **communicated** through this thesis.

It is worth noting that the artifact has not yet been applied in operational practice; its evaluation is therefore based on expert assessment rather than field deployment. Additionally, the stages described above were not followed in a strictly sequential manner; rather, some activities were performed simultaneously or in parallel. In particular, the expert reviews served as formative evaluation activities, directly informing the development process and resulting in refinements to the artifact.

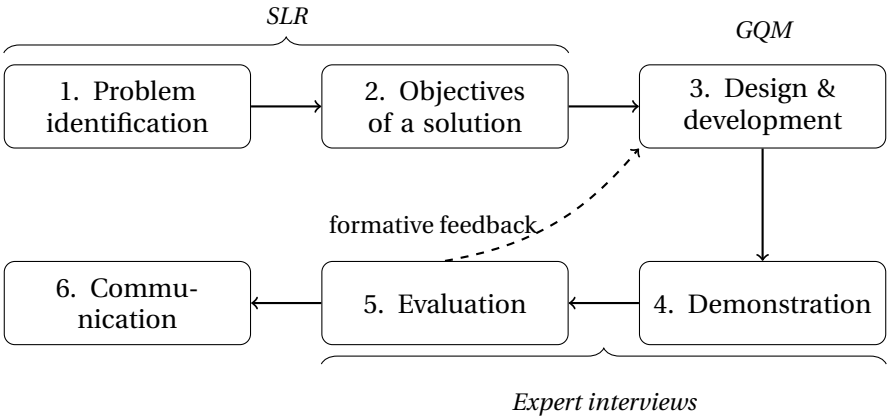


Figure 3.1: DSR process followed in this study, adapted from Peffers et al. [46].

The remainder of this chapter details the methods supporting these activities: Section 3.2 describes the systematic literature review underpinning

problem identification and objective definition; Section 4.2 describes the GQM-based design of the artifact, and Section 3.4 its demonstration and evaluation. The sections are presented in this order to reflect the chronological progression of the research. Mapped onto the conventional structure of a methodology chapter, the *research strategy* corresponds to the DSR approach and the GQM-based framework design; *data collection* comprises the systematic literature review and the semi-structured expert interviews; and *data analysis* comprises the structured synthesis of the literature and the deductive analysis of expert feedback.

3.2 Systematic Literature Review

The study team conducted a systematic literature review (SLR) to ground the problem identification and objective definition activities of the DSR process, and to provide the theoretical foundation for the framework design. SLRs provide structure and ensure method reproducibility for identifying, evaluating, and synthesizing existing research on a specific topic [45]. Unlike traditional narrative reviews, SLRs follow an explicit methodological protocol designed to reduce bias and ensure comprehensive coverage of the relevant literature [45, 52].

The literature review approach adopted in this thesis is based primarily on the methodological guidance proposed by Okoli and Schabram [45], providing practical guidance to conduct an SLR in Information Systems (IS) research. Their approach emphasizes the structured, transparent, and well-documented identification and evaluation of existing literature, enabling a reliable synthesis of findings within a selected research domain. According to this approach, the SLR process includes several key stages: defining the purpose of the review, developing an SLR protocol, conducting systematic database searches, screening relevant studies, extracting data, and synthesizing the findings.

In alignment with the research questions posed in Chapter 1 Introduction, **the purpose of the SLR was twofold**:

1. to identify existing research on resilience metrics and measurement approaches relevant to ICT risk management in credit institutions;

2. to identify frameworks and conceptual models that measure cyber resilience in DBEs.

To identify relevant literature, searches were conducted across three databases widely used in IS and cybersecurity research: ACM Digital Library, Scopus, and Web of Science. To ensure the relevance and quality of the reviewed literature, a combination of keywords related to resilience measurement and cybersecurity risk management was used. The SLR plan, protocol, and findings are described in detail in Appendix A.

Finally, selected literature was analyzed using a structured synthesis approach. Key concepts, measurement approaches, and proposed metrics were extracted and categorized to identify common measurement dimensions and gaps in existing frameworks. These insights served as the main input for the design of the resilience measurement framework developed in this study, as described in Section 2.4(Related work).

3.3 GQM-based Cyber Resilience Metrics Framework design

The resilience measurement framework proposed in this thesis was developed using the Goal–Question–Metric (GQM) approach, a structured methodology for deriving context-specific metrics from clearly defined objectives [5]. The GQM approach organizes measurement design into three hierarchical levels: goals, questions, and metrics. Rather than defining metrics in isolation, Basili, Caldiera, and Rombach [5] emphasize that measurement systems should be explicitly linked to the objectives they are intended to evaluate. The GQM structure has also been extended beyond software engineering to derive metrics in other domains, including information technology [47], reinforcing its adaptability as a metric-derivation technique.

In the context of resilience measurement, the GQM approach provides a systematic mechanism for translating high-level resilience objectives into measurable indicators. Resilience goals can be decomposed into operational questions that assess specific aspects of organizational resilience, such as incident detection capabilities, recovery performance, and the maturity of ICT risk management practices. These questions are then operationalized through metrics that enable the quantitative or qualitative assessment of the corresponding objectives. Consistent with the delimitations of this thesis, only quantitative metrics were carried forward in the framework design.

In this study, the ICT Risk Management pillar of DORA served as the primary source for defining resilience objectives, complemented by the measurement dimensions, metric categories, and candidate indicators identified through the SLR (Section 3.2). These regulatory requirements were translated into desired resilience states, which were subsequently decomposed into assessment questions and associated resilience metrics following the GQM methodology. This process ensured a clear traceability between regulatory requirements and the resulting measurement framework.

The application of this process – the derivation of goals, questions, and metrics from the ICT Risk Management requirements – is presented in Chapter 4 (Resilience Metrics Framework), with the complete GQM derivation documented in Appendix B (Explicit GQM Application).

3.3.1 Alternative methodological approach to developing metrics

We considered an alternative method for developing cyber resilience metrics, namely the SMART methodology by Doran [16], used by Ko, Hyeon Lee, and Seo [32] when developing a cyber resilience framework for ships. The SMART methodology is a systematic approach for defining performance indicators that are aligned with organizational objectives and achievable within established time constraints; its components are specific, measurable, achievable, relevant, and time-bound. However, the SMART approach focuses more on the qualities of the end goal or metric, whereas GQM prioritizes the top-down hierarchical derivation of what to measure. GQM better suited our purpose, considering that we were the first to translate the DORA regulation into metrics and had to first establish what to measure and how. SMART could therefore have complemented our approach by refining and validating individual metrics – which we achieved instead through expert evaluation of the metrics' reliability and practicality and of the framework's coherence and scope.

3.4 Demonstration and evaluation: expert interviews

A defining feature of DSR is the systematic evaluation of the artifact. The KPI framework must be not only conceptually sound, but also practically applicable. Therefore, evaluation mechanisms are embedded in the research design. Following the methodology proposed by Peffers et al. [46],

the resilience measurement framework developed in this study was evaluated through qualitative interviews with experts involved in ICT risk management and operational resilience in credit institutions. In this study, the demonstration and evaluation activities of the DSR process were integrated within the same interview sessions: each interview began with a demonstration of the framework supported by complementary materials shared in advance, and proceeded to its evaluation against the dimensions described below.

Semi-structured interviews are widely used in qualitative research to obtain expert perspectives and assess the relevance and applicability of conceptual frameworks. This method enables researchers to explore participants' knowledge and professional experiences in depth [14]. It is also suitable for investigating organizational practices and evaluating conceptual models [43].

In this thesis, **six experts working in ICT risk management or regulatory compliance were interviewed**. The proposed approach to framework development and the framework itself, including all suggested metrics, were shared with participants in advance to allow informed feedback. The expert interviews evaluated the perceived usefulness and applicability of the proposed resilience metrics and assessed their alignment with the regulatory expectations defined by DORA. The feedback also served to validate the proposed approach to developing the framework and to inform its subsequent refinement.

3.4.1 Semi-structured interviews

For the evaluation and demonstration stage of the metrics framework, the study team used **semi-structured interviews** [12]. This approach allowed the team to prepare a clear list of metrics for experts to evaluate alongside open-ended questions about the framework's coherence, relevance, and practicality, while retaining flexibility during the interviews. Depending on the interviewee's expertise, the team could skip or highlight specific metrics, solicit detailed feedback, propose alternative metrics, and learn about the interviewee's own or their institution's approach to compliance and ICT risk management.

Each interview had four primary sections. First, the introduction covered the interviewee's role within the financial sector and their experience with compliance, particularly ICT and EU regulations. Second, serving as the demonstration step, the team presented the framework-building approach, showing a simplified GQM structure with an example, and asked

whether the approach made sense, aligned with field practice, and if not, how practice differed. Third, the interviewee reviewed and evaluated metrics on relevance for DORA compliance and practicality, supported by a validation sheet included in the materials; the sheet served primarily to prepare interviewees and structure the review, with feedback captured verbally during the discussion. Finally, the interviewee answered open-ended questions about overall quality of metrics, missing metrics, and additional comments or suggestions. Interviews lasted between 30 and 45 minutes and were conducted online.

Before each interview, participants received complementary materials (see Appendix D), introducing the project, summarizing the framework development approach, and detailing the metric design. These materials formed part of the demonstration of the artifact.

Regarding the **choice of informants**, we required experts in the field who could evaluate our work, provide feedback, and benchmark our approach against real-world practice. Not only did we need experts in a highly regulated, closed banking field, but also niche specialists who understand compliance, work with ICT risk management, and have experience with metrics, particularly in the DORA context. Therefore, we did not rely on probability or random but purposive sampling [12].

Ultimately, we have conducted six expert interviews across the following positions and types of organizations:

No	Position	Organization type
1	Senior Policy Adviser (Cybersecurity)	Supranational financial industry association
2	Senior Policy Adviser (Prudential Regulation & Risk)	Supranational trading industry association
3	Head of Non-Financial Risk	Regional financial services holding group
4	Senior Adviser (Security)	National financial sector trade body
5	Managing Director (Cybersecurity)	Global financial advisory firm (Office 1)
6	Manager (Cybersecurity)	Global financial advisory firm (Office 2)

Table 3.1: List of interviewees

3.4.1.1 Alternative methodological approach to demonstration and evaluation

Although a survey would generate a larger volume of responses, potentially increasing the quality of our metrics framework or increasing confidence in the empirical evidence, achieving a large number of responses was highly unrealistic. The sensitive and confidential nature of compliance and ICT risk management practices within the banking industry made external surveying of specialists particularly difficult. Therefore, we chose to be practical and proceeded with interviews.

Additionally, field deployment would be an optimal way to validate the final version of the Cyber Resilience Metrics Framework, and could also help calibrate metric thresholds for a specific credit institution type. However, since the goal of this study was to develop the metrics, the priority was to receive feedback on the approach and draft the framework and its metrics. Field deployment is the natural next step (see Section 6.6).

3.4.1.2 Research ethics

To ensure **ethical approach to conducting interviews**, we prioritized four core principles of ethical research as emphasized by Denscombe [12]: protecting participants' interests, ensuring voluntary participation through informed consent, maintaining scientific integrity by avoiding deception and keeping our process transparent and traceable (with recordings, transcripts, and consent forms excluded from publication and stored under anonymization), and complying with laws and regulations of the land.

In the best interests of participants, we conducted interviews as comfortably as possible. Voluntary participation was ensured by sharing detailed information about the research topic, aims, and supplementary materials (e.g., introduction, approach to framework development, list of metrics, open-ended questions), so that participants could give fully informed consent (see Appendix D (Complementary Interview Materials)). All informants signed consent forms detailing the handling of their and their organization's data prior to each interview (see Appendix C (Consent Form)).

Regarding compliance with regulations, we adhered to the General Data Protection Regulation (GDPR) and its Swedish implementation. Within this framework, we particularly emphasized data protection in accordance with the Swedish Research Council [49], ensuring that all personal and organizational data were handled confidentially, stored securely, and processed only for explicitly stated research purposes.

3.4.1.3 Software and AI tools used

In the interest of transparency, we note the software and AI tools used in conducting this study. Interviews were conducted, recorded, and transcribed via Microsoft Teams, using the study team's institutional access. Reference management was supported by Zotero, and the thesis was prepared using LaTeX in Overleaf. Generative AI tools, specifically Claude (Anthropic) and ChatGPT (OpenAI), were used during the writing process to support language editing, proofreading, and the structuring of tables, figures, and LaTeX code.

3.4.2 Approach to interview analysis

Consistent with the evaluation role of the interviews within the DSR process, the analysis of interview data followed a deductive, criteria-based approach. In terms of evaluation strategy, the study relied on an approach akin to the framework proposed by Venable, Pries-Heje, and Baskerville [51]. The interviews constituted **formative evaluation episodes**: they were used to refine and legitimize the resilience metrics framework. In this sense, they were a source of expert feedback on the framework development approach and on the intermediary as well as near-final versions of the Cyber Resilience Metrics Framework.

The analysis was structured around the evaluation dimensions embedded in the interview guide: the coherence of the framework development approach, the relevance of individual metrics for DORA compliance and their practicality of implementation in credit institutions, and the completeness of the framework as a whole. After each interview, the notes, recordings, and transcripts were reviewed and reconciled, and feedback on both specific metrics and the framework as a whole was systematized. Feedback was synthesized cumulatively across interviews, with recurring comments given particular weight in artifact refinement.

More concretely, each comment was categorized according to the dimension it addressed and assessed along three criteria: whether it recurred across multiple interviewees, whether it was consistent with the framework's stated scope and delimitation (Chapter 1, Section 1.4), and whether addressing it was practically feasible within the study's timeline. Comments meeting several of these criteria were prioritized for incorporation. Distinctive suggestions raised by a single interviewee, by contrast, were recorded and considered but only incorporated where independently consistent with the framework's design objectives; otherwise they were reported

as individual observations in Chapter 5 rather than reflected as changes to the artifact.

3.4.2.1 Research reliability

A note on **reliability** is warranted. Given that we employed a qualitative data collection method, we could not claim complete replicability of the process and its results [12]. Nevertheless, we aimed for traceability by being transparent about the research process. This included keeping a detailed record of the materials presented to informants and the types of questions they were asked. This approach aligns with the concept of **dependability**, requiring that research procedures and decisions be documented in a manner that allows other researchers to evaluate them in terms of their reputability and rationale [37].

That said, complete replicability was not the primary aim of this study. In our case, the interview data, while empirical, did not serve as the sole foundation of the thesis's claims and contributions. Beyond triangulation, which can mitigate concerns regarding the reliability of qualitative data, we treated the interviews primarily as external validation – feedback on the framework of resilience metrics – rather than as an independent input in their own right.

3.4.3 Evaluation and validation outcomes

The sequence in which the interviews were conducted was not intentional but proved to be effective: policy experts first confirmed the high-level interpretation of DORA; financial-sector representatives then assessed the practical needs the metrics should serve; and cybersecurity consultants with private banking experience evaluated the framework against credit institutions' capabilities and needs.

The interviews were conducted in parallel with the framework design and directly informed its evolution. Most changes concerned individual metrics – their names, definitions, and structure. Nevertheless, the framework did undergo one major revision: its scope was narrowed to operational resilience, binary status indicators were replaced with quantitative metrics specified through explicit formulas, and each metric was anchored to an exact DORA article reference. The revised framework, shared with

the final participants, received only minor cosmetic suggestions, suggesting that the iterative expert feedback had validated the artifact development approach and that the resulting framework had reached an acceptable level of evaluation among domain experts. The framework's validity in practice would, however, require subsequent field deployment. The revision and the feedback that motivated it are reported in detail in Chapter 5.

4

Resilience Metrics Framework

This chapter presents the design, structure, and final version of the Cyber Resilience Metrics Framework, the key output of this research project. The validated framework comprises 14 goals and 50 quantitative cyber resilience metrics derived from Articles 6-13 of DORA, each metric specified through a name, definition, formula, and measurement type, accompanied by illustrative data sources, and presented in full in Table 4.13. The chapter focuses on the design logic, key decisions, and the resulting metric structure, while the full derivation detail, consolidation, and complete cyber resilience metrics catalog are provided in Appendix B.

The remainder of this chapter is organized as follows: Section 4.1 outlines the design objective and scoping criteria applied to DORA's ICT Risk Management pillar; Section 4.2 presents the three step GQM translation through a single worked example; Section 4.3 defines the attribute structure used to specify each metric; and Section 4.4 presents the full framework in its final form.

4.1 Design objectives and scope

The starting point for the framework design is DORA Chapter II, which covers Articles 5 through 16 and constitutes the **ICT Risk Management** pillar. The articles were reviewed systematically and individually to determine which requirements are susceptible to technical measurement and therefore suitable as a basis for metric derivation.

The first scoping criterion applied to the requirements was the distinction between organizational and operational requirements. Organizational requirements refer to the conditions governing how assets are managed, documented, and arranged by the management body and human resources; despite being verifiable, these typically do not lend themselves to quantitative, indicator-based measurement. By contrast, operational and technical requirements refer to the conditions that govern the configuration, behavior, and performance of ICT systems and processes, and can be expressed as measurable quantities trackable over time [9][44]. This distinction is consistent with the cyber resilience measurement literature, which differentiates between structural and organizational measures, and technically observable metrics [9, 35, 41].

After reviewing Articles 5 to 16, the following articles were scoped out in full, as their requirements do not lend themselves to quantifiable, indicator-based measurement or fall outside the entity and regulatory scope of this thesis:

- Article 5 was scoped out as all its requirements concern management body governance, accountability, and oversight, none of which produce technically measurable indicators without access to internal governance records.
- Article 14 was scoped out as it governs crisis communication policies and personnel assignments.
- Article 15 was scoped out because it mandates European Supervisory Authorities to develop regulatory technical standards rather than requirements for financial institutions; thus, no direct obligations are imposed by this article.
- Article 16 was scoped out because it defines a simplified framework applicable only to small and non-interconnected entities, which fall outside the financial DBE context addressed by this thesis.

A second scoping criterion concerned third-party ICT risks, as the broader management of these risks is addressed under DORA's dedicated third-party risk management pillar (Articles 28 to 44), which is outside the scope of this work. The remaining in-scope articles were then subject to selective exclusion at the paragraph level. Within these articles, paragraphs governing policy documentation, management reporting, internal audit conduct, staff training, and specific obligations applicable to counterparties, data service providers, or entity categories other than credit institutions

were excluded. A definitive list of requirements covering asset identification and classification, risk assessment, protection and prevention controls, and learning and improvement was retained as the basis for metric derivation. The complete paragraph-level evaluation, including the justification for each exclusion, is documented in Appendix B (Section B.1).

The framework is therefore designed for financial entities subject to the full DORA ICT risk management framework under Articles 6 to 13, operating within interconnected financial DBEs where systemic risk propagation and shared ICT dependencies are significant factors.

4.2 Framework design

The application of GQM to this framework follows three sequential translation steps, each described in the subsections below. The approach operates top-down from goals to questions to metrics, but is validated bottom-up, ensuring that the identified metrics answer the questions, and that the questions collectively determine whether a goal is met [5]. To illustrate the logic and aid in following the steps, a single worked example is carried through all three steps, using the requirement established in Article 12, paragraph 3 of DORA. The requirement, hereafter referred to as **Req** and used throughout the rest of the chapter, states: "When restoring backup data using own systems, financial entities shall use ICT systems that are physically and logically segregated from the source ICT system." The ICT systems shall be securely protected from any unauthorized access or ICT corruption and allow for the timely restoration of services making use of data and system backups as necessary [19, Art. 12.3].

4.2.1 Requirement-to-Goal translation

The first translation step converts DORA requirements into measurable goals. Each goal in this framework follows the goal definition template proposed by Basili, Caldiera, and Rombach [5], which specifies that a measurement goal comprises five components: an object (what is being examined), a purpose (why it is being examined), a quality focus (the specific property of interest), a viewpoint (whose perspective the assessment is made from), and a context (the environment in which the assessment applies).

In the context of this framework, each goal represents a desired state of cyber resilience that a financial entity should achieve to satisfy one or more DORA requirements. The framework's goals therefore consistently follow

the structure “Assess «object» for «purpose» with respect to «quality focus», from the viewpoint of «viewpoint», in the context of «context»”.

Additionally, the study team defined three translation rules to guide the conversion of requirements into goals, based on the recurring patterns observed in how DORA formulates its requirements:

- Requirements that specify a desired system or process state (e.g., ensuring backup coverage) are translated into goals that express such a state as an observable condition.
- Requirements that specify a frequency or periodicity (e.g., regular testing) are translated into goals that include recency as a measurable dimension.
- Requirements that specify a threshold or standard (e.g., data integrity) are translated into goals that express the standard as a measurable property of the system.

By requiring that backup systems be “securely protected from any unauthorized access or ICT corruption”, **Req** states a desired state, which is translated into an observable condition. Additionally, by requiring the systems to “allow for the timely restoration of services”, it arguably implies a standard, provided that recovery time objectives are defined: not only must restoration occur, it must occur within an acceptable time frame. This standard becomes a measurable property of the system in two respects: restoration completeness and speed. The resulting goal for **Req** is shown in Table 4.2.

Source	Requirement Summary	Goal Statement
12.3	*Financial entities shall use ICT systems that are physically and logically segregated from the source ICT system.*	Assess the segregation and protection of backup systems for ensuring reliable recovery capability with respect to operational integrity and access security, from the viewpoint of security management, in the context of backup and recovery management.

Table 4.2: Requirement-to-Goal translation for **Req**

The goal[1] is now associated with an object, a purpose, a quality focus, a stakeholder perspective, and a context. The object is the segregation and protection of backup systems; the purpose is to ensure reliable recovery capability; the quality focus is operational integrity and access security; the perspective is that of security management; and the context is backup and recovery management.

The per-article requirement-to-goal translation produced a total of 40 goals across Articles 6 to 13, as listed in Appendix B (Section B.1). However, DORA's requirements structure cross-references articles when they address the same underlying requirement from different regulatory angles, thus producing overlapping goals. For instance, Articles 6, 9, and 10 all address detection and monitoring capabilities: although the corresponding goals were derived independently, they measure the same underlying capability – the ability to observe ICT system behavior and detect anomalous activities. For such cases, goal refinement was performed through thematic consolidation [5] to produce a non-redundant framework, resulting in a set of distinct and independently measurable dimensions of cyber resilience.

This thematic consolidation reduced the number of goals from 40 to 27. Each consolidated goal retained the identifier of the earliest-numbered goal in its group, after which all goal identifiers were reassigned in a new continuous sequence from 1 to 27, as detailed in Appendix B (Section B.1.1).

[1] G22 in the Appendix B

4.2.2 Goal-to-Question Translation

The second translation step breaks each goal down into a set of questions that collectively determine whether the goal is being met. Questions in GQM serve as a bridge between the abstract intention of a goal and the concrete data that can be collected, as each question should ideally identify a specific aspect of the goal that needs to be assessed [5]. Two types of questions are derived from the goals: state questions and performance questions. State questions ask whether a condition exists or a property is in place at a given point in time, while performance questions ask how well a condition is maintained or how efficiently a process operates [5].

Together, state and performance questions ensure that the framework captures both compliance status and resilience quality. The type of question formulated for each goal depends on the nature of the goal itself. Goals expressing a behavioral property or a technically observable standard produce performance questions, which in turn lead to resilience metrics. Goals that do not yield technically observable or system-behavioral performance questions are assigned state questions instead. As state questions verify the existence of a condition rather than a measurable degree of system behavior, they do not yield resilience metrics. The goals decomposed only into state questions therefore carry no indicators in the final framework, as documented in Appendix B.

Breaking down the example goal into its measurable components produces the following questions:

Question	Type
How effectively are backup systems protected from compromise?	Performance
How reliably can they support recovery within defined targets?	Performance

Table 4.4: Goal-to-Question translation

At least one question was formulated for each goal; the complete list of questions from the goal-to-question translation applied to the 27 goals is in Appendix B.

4.2.3 Question-to-Metric translation

The third and final translation step converts each question into one or more metrics. A metric in the GQM approach is a measurement procedure that produces a value answering its associated question [5, 6]. Because the questions derived from the example goal are performance questions, resilience metrics are produced. As previously stated, not every question yields a resilience metric. Where a goal produced only state questions, the absence of a corresponding metric is not a gap in the framework but a direct consequence of the goal's nature.

The metrics derived for the example goal and its questions are shown in Table 4.6.

Question	Metric
How effectively are backup systems protected from compromise?	% of unauthorized access attempts to backup systems that were detected and blocked
How reliably can they support recovery within defined targets?	% of backup restoration tests completed successfully (data restored completely and within RTO) Average time to restore from backup for systems supporting critical/important functions

Table 4.6: Question-to-Metric translation for **Q22.1** and **Q22.2** from **G22**

Applying this translation across the questions retained from the 27 consolidated goals produced a total of **50 quantitative resilience metrics spanning 14 goals**, which constitute the final framework. The full question-to-metric translation, including the explicit justification for each question that yields no resilience metric, is provided in Appendix B (Section B.3).

4.3 Metric structure

Following the structure proposed by [32, 9], each metric in the scope of this work is defined with at least the following attributes:

- **Name:** a short, descriptive label.
- **Definition:** an accurate statement of what is measured.

- **Formula:** a calculation method, where applicable.
- **Measurement type:** an expected value from the measurement.

However, three additional attributes are highly recommended for a fully operational metric, but determining them requires specific data and use case, validated measurement instruments, and empirical calibration – all beyond the scope of this work. These attributes are:

- **Data source:** the system, process, or record from which the measurement is drawn.
- **Frequency:** how often the measurement should be collected.
- **Threshold/Benchmark:** a reference value or range, where applicable.

The frequency and data source mainly depend on the type and size of financial institution; however, some recommended data sources are stated in this work for example purposes only. The threshold design choice should be deliberate and consistent with DORA's principles. Although DORA does not prescribe specific thresholds, guidance ranges are noted, and entities are expected to define values consistent with their risk tolerance [30]. Literature and industry benchmarks can also provide reference ranges.

Table 4.8 shows the structure of the metrics resulting from the worked example built throughout this chapter. The complete list of metrics and their attributes is in Appendix B (Section B.4).

Metric Name	Definition	Formula	Measurement Type	Data Sources
Backup Restoration Success Rate	Percentage of backup restoration tests completed successfully within defined recovery objectives.	(Successful Backup Restorations / Total Backup Restoration Tests) $\times$ 100	Percentage (%)	Backup platforms, recovery test reports
Backup Restore Time	Average time required to restore systems or data from backup.	Σ Restore Times / Number of Restore Operations	Time	Backup management systems
Unauthorized Access Attempts Blocked (Backup Systems)	Percentage of unauthorized access attempts to backup systems that were detected and blocked.	(Blocked Unauthorized Attempts / Total Unauthorized Attempts) $\times$ 100	Percentage (%)	Backup security logs, SIEM/XDR platforms

Table 4.8: Resilience metrics structure for metrics derived from G22

4.4 Full framework overview

This chapter has presented the derivation of the Cyber Resilience Metrics Framework through the three GQM translation steps, walking through the worked example of G22 to illustrate the logic applied consistently across all

in-scope requirements. The scoping and translation process end-to-end, from the full set of requirements to the 50 metrics, is summarized in Figure 4.1. The framework's final form, refined following the expert validation described in Chapter 5, is presented below. The main framework updates after the validation stage pertained to narrowing the scope to operational resilience and replacing binary status indicators with quantitative metrics only.

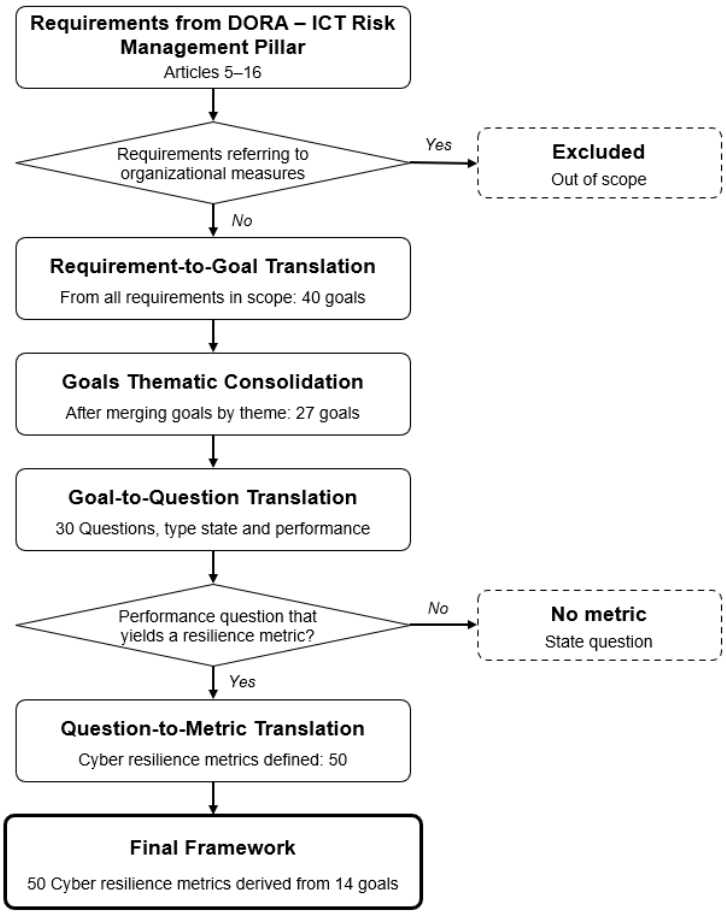


Figure 4.1: Scoping decision tree for the GQM-based derivation of the Cyber Resilience Metrics Framework

Table 4.13 closes the chapter with the complete result of the derivation and the full picture of the framework: 14 goals and 50 metrics, each fully specified with its definition, formula, measurement type, and recommended data source. This is the artifact this thesis set out to build, presented as a single point of reference before its final evaluation is reported in Chapter 5. The intermediate goals, questions, requirement summaries,

and the goals excluded from the final quantitative scope, together with the rationale for each exclusion, are documented in Appendix B.

Source	Goal	Question	Metric Name	Metric Definition	Metric Formula
6.8(e) 6.8(f) 9.1 10.1 10.3	G5: Assess the monitoring of ICT systems and user activity for enabling timely threat detection with respect to coverage and continuity, from the viewpoint of Security Management, in the context of ICT threat detection operations.	How completely and continuously are ICT systems and user activities covered by operational detection mechanisms?	ICT systems covered by operational detection mechanisms	% of ICT systems covered by operational detection mechanisms	(ICT systems covered by detection mechanisms / Total ICT systems) $\times$ 100
			Mean Time to Detect (MTTD)	Mean Time to Detect (MTTD) ICT-related incidents, anomalous activity or security events	$\sum$ Detection Times / Number of Detected Events
			False alert rate	% of false alerts out of the total # of alerts	(False Alerts / Total Alerts) $\times$ 100
			Detection test success rate	% of successful detection tests out of the total simulated attack scenarios	(Successful Detection Tests / Total Simulated Attack Scenarios) $\times$ 100
6.8(g) 7(d) 10.1 11.2(c) 11.2(d) 12.1 12.2	G6: Assess the testing of business continuity, recovery, and backup plans for validating operational readiness with respect to test frequency, success rate, and scenario coverage, from the viewpoint of ICT operations, in the context of resilience preparedness.	Q6.1: How frequently and successfully are recovery and backup plans tested against defined RTO/RPO targets?	Recovery and backup plans meeting RTO/RPO targets	% of recovery and backup plans that meet defined RTO/RPO targets during tests	(Plans Meeting RTO/RPO During Tests / Total Plans Tested) $\times$ 100
			Average recovery time gap vs RTO	Average gap between tested recovery time and defined RTO, across systems supporting critical functions	$\sum$(Tested Recovery Time $-$ Defined RTO) / Number of Tests
		Q6.2: How representative are the test scenarios of real-world adverse conditions?	Adverse scenario coverage	% of defined minimum adverse scenarios covered in tests per testing cycle	(Adverse Scenarios Tested / Defined Minimum Adverse Scenarios) $\times$ 100

Source	Goal	Question	Metric Name	Metric Definition	Metric Formula
7(b) 9.2 9.3(b) 9.3(c) 11.2(a) 11.2(b)	G7: Assess ICT systems supporting critical functions for ensuring continuous operational trustworthiness with respect to availability, authenticity, integrity, and confidentiality, from the viewpoint of Security Management, in the context of ongoing ICT operations.	To what extent do ICT systems supporting critical/important functions maintain required operational properties under normal and adverse conditions?	System availability (uptime)	% uptime of ICT systems supporting critical functions per measurement period (availability)	(Total Time − Downtime) / Total Time × 100
			Confirmed integrity violations	Number of confirmed integrity violations detected in systems supporting critical functions per measurement period	Count per measurement period
			Confirmed confidentiality breaches	Number of confirmed confidentiality breaches in systems supporting critical functions per measurement period	Count per measurement period
			Cryptographic signing coverage	% of signed assets out of the total deployable assets	(Signed Assets / Total Deployable Assets) × 100
7(c) 11.4 11.6(a) 12.4	G8: Assess the redundant capacity of ICT infrastructure supporting critical/important functions for ensuring service continuity with respect to activation speed and sufficiency within defined RTO/RPO targets, from the viewpoint of ICT operations, in the context of disruption scenarios.	Can redundant capacity sustain all critical/important functions within defined RTO and RPO targets when primary systems are unavailable?	Failover time	Failover time (time to activate redundant capacity) per critical function	$\sum$ Failover activation times / Number of failover tests
			Operational load sustainability during failover	% of critical functions whose redundant capacity sustains full operational load during failover tests	(Functions sustaining full load / Functions tested) × 100
			Failover RTO compliance	% of failover tests completed within defined RTO targets	(Failover tests meeting RTO / Total failover tests) × 100

Source	Goal	Question	Metric Name	Metric Definition	Metric Formula
8.2 13.1	G10: Assess the threat and vulnerability analysis process for enabling timely risk reduction with respect to coverage and remediation speed, from the viewpoint of Security Management, in the context of continuous vulnerability management.	How completely and promptly are threats and vulnerabilities identified and addressed across ICT systems supporting critical functions?	Vulnerability scan coverage	% of ICT systems scanned within the defined scanning frequency	(Systems scanned within required frequency / Total systems) $\times$ 100
			Mean Time to Remediate Vulnerabilities	Mean time from vulnerability identification to remediation	$\sum$ Remediation times / Number of vulnerabilities remediated
			ICT systems without critical vulnerabilities	% of ICT systems with no unaddressed critical severity vulnerabilities at a given point in time	(Systems with no open critical vulnerabilities / Total systems) $\times$ 100
			Critical vulnerability backlog	Number of open critical/high critical vulnerabilities	Count of open critical/high vulnerabilities
			Vulnerability recurrence rate	% of recurrent vulnerabilities out of the total remediated vulnerabilities	(Recurrent vulnerabilities / Total remediated vulnerabilities) $\times$ 100
8.7	G12: Assess legacy ICT systems (without active vendor security support) for managing residual risk with respect to assessment regularity and remediation effectiveness, from the viewpoint of ICT operations, in the context of system lifecycle management.	How effectively are risks from legacy systems identified and mitigated over time?	Legacy ICT systems with unmitigated critical findings	% of legacy ICT systems with at least one unmitigated critical or high severity finding at a given point in time	(Legacy Systems with open critical findings / Total legacy systems) $\times$ 100
			Time to initiate remediation	Average time between legacy system risk identification and initiation of remediation action	$\sum$ (Time from identification to remediation start) / Number of findings
			Vendor Support Verification Rate	% of systems with verified ICT support status out of the total production systems	(Systems With Verified Support Status / Total Production Systems) $\times$ 100

9.3(a) 9.3(d)	G13: Assess the protection of data across all operational states for maintaining confidentiality, integrity, authenticity, and availability with respect to completeness of technical protection mechanisms, from the viewpoint of Security Management, in the context of data security operations.	To what extent is data technically protected across all operational states?	Encryption coverage (data in transit)	% of data in transit protected by defined encryption mechanisms	(Protected data flows / Total sensitive data flows) × 100
			Encryption coverage (data at rest)	% of data at rest protected by defined encryption mechanisms	(Encrypted data repositories / Total sensitive data repositories) × 100
			Confirmed integrity or confidentiality violations	Number of confirmed data integrity or confidentiality violations per measurement period	Count per measurement period
			Integrity protection coverage	% of critical data stores with integrity validation out of the total # of critical data stores	(Critical data stores with integrity validation / Total critical data stores) × 100
9.4(b)	G14: Assess the network architecture for limiting the propagation of ICT disruptions with respect to segmentation effectiveness and containment speed, from the viewpoint of ICT operations, in the context of incident response.	How effectively and quickly does the network architecture contain ICT disruptions within the initially affected segment?	Time to isolate compromised segment	Time to isolate a compromised network segment from systems supporting critical functions	$\sum$ Isolation times / Number of isolation events
			Disruptions contained within initial segment	% of ICT disruptions contained within the initially affected network segment (i.e., did not propagate)	(Contained disruptions / Total disruptions) × 100
			Disruptions reaching ICT systems supporting critical functions	% of disruptions that reached systems supporting critical functions from an initially non-critical segment	(Disruptions Reaching ICT Systems supporting critical functions / Total disruptions) × 100
			Segmentation validation success rate	% of segmentation validation tests out of total # of segmentation tests	(Successful segmentation tests / Total segmentation tests) × 100

9.4(c)	G15: Assess access control mechanisms across ICT systems for limiting exposure to unauthorized use with respect to enforcement effectiveness and audit completeness, from the viewpoint of Security Management, in the context of identity and access management.	How effectively are access controls enforced and how completely are access events audited across systems?	Unauthorized access attempts detected and blocked	% of unauthorized access attempts to systems that are detected and blocked	(Unauthorized attempts blocked / Total unauthorized attempts detected) $\times$ 100
			Access revocation time	Average time to revoke access rights following a detected compromise or user departure	$\sum$ Revocation times / Number of revocations
			Auditable access events	% of access events (categories?) to systems that are fully logged and auditable	(Fully logged access events / Total access events) $\times$ 100
			Privileged access review compliance	% of accounts reviewed within required period out of the total # of privileged accounts	(Privileged accounts reviewed / Total privileged accounts) $\times$ 100
9.4(d)	G16: Assess the implementation of strong authentication mechanisms for reducing identity-based attack exposure with respect to coverage and consistency across privileged and remote access, from the viewpoint of Security Management, in the context of identity and access management.	How completely and consistently are strong authentication mechanisms applied to privileged and remote access?	Privileged accounts with strong authentication	% of privileged accounts with strong authentication enforced	(Privileged accounts with strong authentication / Total privileged accounts) $\times$ 100
			Authentication-related security events detected	% of authentication-related security events (e.g., bypass attempts, credential compromise) detected per measurement period	Count per measurement period
			MFA coverage for remote access	% of remote access accounts protected by MFA out of the total # of remote access accounts	(Remote access accounts protected by MFA / Total remote access accounts) $\times$ 100

Source	Goal	Question	Metric Name	Metric Definition	Metric Formula
9.4(f)	G18: Assess the patch and update management process for reducing vulnerability exposure with respect to timeliness relative to criticality-based policy thresholds, from the viewpoint of ICT operations, in the context of vulnerability management.	How timely is the application of patches and updates relative to criticality-based policy thresholds?	Patch deployment time	Average time from patch release to patch installation	$\sum$ (Patch installation date − Patch release date) / Number of patches
			Patch compliance rate	% of systems with patches applied within policy-defined time frames	(Systems patched within policy time frame / Total systems requiring patches) × 100
10.2	G19: Assess the alert threshold and automatic alerting mechanisms for enabling timely incident response with respect to operational coverage and alerting reliability, from the viewpoint of Security Management, in the context of ICT threat detection.	Q19.1: How reliably do automatic alerting mechanisms trigger upon threshold breaches? Q19.2: How quickly do alerting mechanisms generate alerts upon threshold breaches?	Operational alert threshold coverage	% of defined alert thresholds for which automatic alerting is verified as operational	(Operational alert thresholds / Total defined alert thresholds) × 100
			Alert latency	Mean time between a threshold breach and alert generation (alert latency)	$\sum$ (Alert generation time − Threshold breach time) / Number of alerts
			Alert activation rate	% of threshold breaches that successfully triggered an automatic alert (alert activation rate)	(Threshold breaches triggering alerts / Total threshold breaches) × 100
			False alert rate	% of false alerts out of the total # of alerts	(False alerts / Total alerts) × 100

Source	Goal	Question	Metric Name	Metric Definition	Metric Formula
12.3	G22: Assess the segregation and protection of backup systems for ensuring reliable recovery capability with respect to operational integrity and access security, from the viewpoint of Security Management, in the context of backup and recovery management.	Q22.1: How effectively are backup systems protected from compromise? Q22.2: How reliably can they support recovery within defined targets?	Backup restoration success rate	% of backup restoration tests completed successfully (data restored completely and within RTO)	(Successful backup restorations / Total backup restoration tests) $\times$ 100
			Backup restore time	Average time to restore from backup for systems supporting critical/important functions	$\sum$ Restore times / Number of restore operations
			Unauthorized access attempts blocked (Backup Systems)	% of unauthorized access attempts to backup systems that were detected and blocked	(Blocked unauthorized attempts / Total unauthorized attempts) $\times$ 100
12.7	G23: Assess the data integrity verification process during recovery operations for ensuring trustworthiness of recovered data with respect to coverage, speed, and detection effectiveness, from the viewpoint of ICT operations, in the context of ICT recovery management.	How completely, quickly, and effectively is data integrity verified across assets subject to recovery operations?	Integrity validation time	Average time to complete integrity validation after recovery initiation	$\sum$ Validation times / Number of recovery operations
			Integrity verification methods applied	Number of integrity verification methods applied per recovery operation	$\sum$ Verification methods / Number of recovery operations
			Integrity verification coverage	% of recovered assets subjected to integrity validation out of the total # of recovered assets	(Recovered assets validated / Total recovered assets) $\times$ 100
			Integrity verification success rate	% of recovery operations passing integrity verification out of the total # of recovery operations	(Recovery operations passing integrity verification / Total recovery operations) $\times$ 100

Table 4.13: Cyber Resilience Metrics Framework with GQM traceability to DORA source articles

5

Results

The thesis resulted in a Cyber Resilience Metrics Framework, consisting of 14 goals and 50 quantitative metrics derived from Articles 6–13 of DORA (see Table 4.13). The framework demonstrated and evaluated through six semi-structured expert interviews, which were structured around three evaluation dimensions:

- **Framework coherence:** whether the GQM-based derivation process produces a logical and traceable link between DORA's ICT Risk Management requirements and the resulting indicators, and whether this approach aligns with field practice;
- **Relevance and practical applicability:** whether the indicators are relevant for DORA compliance and realistic to collect, interpret, and act upon within a financial entity;
- **Completeness:** whether any relevant resilience conditions were absent from the framework or inadequately captured by the current metric definitions.

Representatives of the key roles within the domain – policy, financial-sector, and cybersecurity specialists – contributed to the framework's evaluation. The diversity and relevance of the interviewed experts allowed for a holistic review of the framework along the evaluation dimensions and granted confidence in the final artifact.

Because the expert interviews were formative evaluation episodes, the framework changed alongside the evaluation, and interviewees consequently

reviewed different versions of it. Most changes were targeted, adjusting the wording or definitions of specific metrics. Nevertheless, one major revision took place, resulting in the near-final version demonstrated to the last three interviewees. The version reviewed by the first interviewees comprised binary status indicators across a broader scope, including compliance and governance goals. In contrast, the near-final version featured quantitative operational resilience metrics and their attributes.

Consistent with the deductive, criteria-based approach to interview analysis described in Section 3.4, the findings below are organized along these evaluation dimensions: Section 5.1 addresses framework coherence and scope, Section 5.2 the relevance and practical applicability of the metrics, and Section 5.3 the completeness of the framework, together with the refinements each assessment produced. Direct quotes are used selectively to illustrate representative positions; all quotes are anonymized and attributed using the notation I1–I6, corresponding to the interviewees listed in Table 3.4.1. Findings are reported against the framework version each interviewee reviewed, with version-specific findings marked explicitly.

5.1 Framework coherence and scope

5.1.1 GQM approach to framework development

Each interview began with an explanation of the GQM derivation logic, and interviewees were asked to comment on the approach. The experts' assessment was unanimously positive, although little detailed feedback on the derivation logic itself was provided. The final interviewee (I6), who praised the resulting structure of the framework – from DORA reference to goal, question, and metric – as "very well thought out", noted, however, that in practice many organizations employ the reverse approach to compliance metrics: starting from the indicators they already have in place and mapping them back to DORA requirements. This is done to save time, as an organization's maturity determines the feasibility of adopting, tracking, and monitoring metrics. For less mature organizations, the focus lies on "what metrics are relevant that we can show and that we can use to make sure that our board and our senior stakeholders are well informed" (I6).

5.1.2 Framework coherence

The recurring feedback on the framework's coherence concerned the dilemma between a compliance check and an effectiveness measure. This concern

first arose during the 2nd and 3rd expert reviews, where the initial version of the framework – binary indicators assessing whether processes and systems were in place – was demonstrated. These interviewees agreed that the framework resembled a *"checklist"*, or a *"check-the-box exercise"*, rather than a measure of the effective implementation of an ICT risk management strategy (I2).

> Is the objective to demonstrate compliance with DORA, or is it to show that the requirements implemented within your company are actually effective? [...] When you look at your KPIs, you can say, "Yes, I've checked the box," but are you resilient? I'm not sure your KPIs can tell you that. (I2)

I2 emphasized that if the framework were retained in its current form, it should include a disclaimer clarifying that its purpose is to assess compliance with the requirements, not to determine whether the organization is operationally resilient. I2 further noted that such an exercise is precisely what regulators do not want to see: it does not answer the key questions about operational resilience but attempts to appease the regulator, thereby inviting further questions and potential scrutiny. I3 supported this position from a practitioner's perspective, emphasizing that a status – which the initial version predominantly tracked – cannot be measured, only assessed. In their view, effective metrics and a coherent framework require clearly defined and measurable indicators, preferably with thresholds, measurement criteria, and status classifications (I3).

Related to this, I1 and I2 observed that the framework's intention and audience were underdefined: it was unclear who the framework was for and what each metric was intended to achieve. I2 noted that within a company there are "KPIs for directors, KPIs at management level and KPIs at expertise level" and that "bank [...] is a very large organization" with correspondingly diverse internal audiences. Defining who will use the metrics, they argued, would guide the selection, structure, hierarchy, and wording of the metrics (I1, I2). This critique sharpens the GQM viewpoint component itself: a single organizational role label, such as "Security Management", is not, on its own, specific enough to determine a metric's intended audience within large, hierarchically differentiated institutions.

> Where do you want to put this table – as an example, as a clarification or as a sheet that a bank can translate into their internal policy? [...] Is it for general awareness or is it actually something practicable you want to present to the bank? (I1)

Reviewing the revised version, I4 made a similar observation from a different perspective. Rather than criticizing the framework, the comment highlighted its flexibility and adaptability to different organizational needs. I4 suggested that the metrics could be used at different levels of management – for example, as detailed indicators in a Chief Security Officer's dashboard, while a consolidated subset with predefined thresholds could be presented in a Chief Executive Officer-level report.

These comments proved the most consequential for the framework evolution. The metrics evolved from a list of binary yes/no status questions into measurable indicators with definitions, formulas, and suggested data sources. The version integrating these changes was demonstrated to the last three interviewees, who gave positive feedback on the overall framework and metric structure (I4, I5, and I6).

5.1.3 Framework scope

Feedback on the scope of the framework was another major input informing its development. The first version of the framework comprised binary status questions covering diverse aspects of ICT risk management. Some indicators were strictly compliance- or governance-oriented: for example, the goal *ICT risk management framework is up to date and reviewed*, with the corresponding metric *Framework documentation status*. Other indicators, although vague, were more operational or technical in nature: for instance, *Regular testing of BCP, recovery and backup plans – Plan testing status* and *Adverse scenario inclusion*. The logic of the study team at the time was to follow the DORA ICT Risk Management pillar to the letter and ensure that all existing requirements were translated into metrics (see the discussion of framework completeness in Section 5.3). The expert feedback, however, made clear that this pursuit of completeness stood in the way of efficient scoping and of the value of the resulting artifact.

Reviewing the initial version, I1 and I2 pointed out that the indicators needed to be organized into meaningful categories – through a categorization framework or at minimum a distinction between technical and organizational metrics. A crucial input from I1 was to establish the level of application. In their view, policy definition and policy implementation should be segregated. This, combined with the finding that status measures are ineffective, led the study team to reconsider which aspects of the regulation are actually worth translating into indicators. I3 similarly reasoned that not everything should be a metric: some requirements are better assessed qualitatively, and each metric should be warranted.

> Maybe you shouldn't even try to measure everything with KPIs, especially where the objective is more easily assessed qualitatively. Then it shouldn't [be] the rule that [you] must keep an eye on every DORA requirement because you can assess compliance with other tools as well[...] (I3)

Ultimately, the study team decided to retain only those aspects of the regulation that could be translated into specific goals connected to measurable, quantitative metrics concerning operational resilience.

5.2 Metric relevance and practical applicability

Overall, the relevance of the metrics framework to DORA was not disputed by any of the experts. I2, however, highlighted the importance of explicitly stating which DORA articles each goal derived from. Before this, the information had not been included in the supplementary materials to save space. This comment prompted the addition of a regulatory reference column – according to I2, "for a compliance officer in a bank, the most important column" – which was included in the supplementary materials for all subsequent interviews. Later interviewees appreciated the added clarity and transparency, which in their view legitimized the framework.

One qualification came from I1, who, when asked about the relevance of the metrics and how realistically they would be used, was hesitant to answer, explaining that "this depends on what you are trying to achieve and what you are aiming at with these KPIs, because [...] they are [at] very different levels" (I1). This hesitation stemmed from the same underdefinition of intention and audience discussed in Section 5.1, and no longer arose after the major revision of the framework.

Comments on individual metrics mostly concerned their formulation. What made metrics impractical in the initial version was their format and vagueness. The format – binary status indicators – has already been addressed in Section 5.1. Regarding vagueness, several interviewees emphasized that measurable metrics should be concrete and specific (I1, I3). For instance, I1 challenged the goal *Critical systems meet high standards*, measured through a binary compliance status, asking what *high* means. In the revised framework, the vague standard was replaced by observable system properties: availability (uptime), confirmed integrity violations, confirmed confidentiality breaches, and cryptographic signing coverage. The goal *Data protected*, with its corresponding secure data transfer protocol status, drew similar criticism: I1 found its meaning unclear, and I3 noted

that asking a business unit for such a status would yield "a long description [but] not something measurable" (I3). It was reformulated into coverage metrics – encryption coverage for data in transit and at rest, and integrity protection coverage.

A further practicality concern related to the compliance, governance, and organizational indicators that the study team later scoped out – for instance, *Secure data transfer protocol status* and *ICT risk management framework is up to date and reviewed*. Not only were the answers to these indicators unspecified, but collecting data for them was deemed impractical. As I3 explained, a framework is usually not a single document, so a yes/no question is unrealistic; and even if all documents have been reviewed, this does not mean their contents are compliant with DORA – something that can only be assessed qualitatively (I3).

After the major revision, the framework was demonstrated to the remaining three interviewees, whose feedback on relevance and practical applicability was generally positive, with no critical comments. I4 reasoned that the framework structure and metrics could be kept as they are, as they can be repurposed or presented differently depending on stakeholder needs. I5 shared this sentiment, suggesting the framework should be treated "as a menu" from which organizations can choose. They argued that depending on the organizations' type, size, and maturity, they may not be able to monitor and achieve everything at once, and the framework allows them to select the goals that are realistic to monitor and address in their individual context. I5 also emphasized that a good design approach is to have top-level overall targets that help identify key gaps, together with a subset of more detailed metrics for when an organization wants to "double-click" on a specific topic. This confirmed the usefulness of the framework's approach of nesting multiple metrics under a single targeted goal. Finally, I6 noted that the format of the supplementary materials themselves – a table listing each metric alongside *relevant* and *practical* check boxes – could be reused in practice: every organization has to decide for itself which metrics to adopt, and one "could easily go to a client and give them this list and do this exercise with them as well from a relevance and practicality perspective" (I6).

5.3 Completeness

As previously explained (Section 5.1.3), the initial version of the framework covered all articles under DORA's ICT Risk Management pillar. However,

aiming for a framework that adds value through the actual evaluation of operational resilience, rather than compliance on paper, the study team scoped out the indicators that were qualitative in nature or better assessed through qualitative methods.

The completeness of the resulting framework should therefore be understood relative to its narrowed scope. I6 made this explicit: although they considered the final framework well constructed, relevant, and useful, a credit institution seeking to evaluate compliance with DORA as a whole would need to cover every article, including governance aspects such as third-party risk management and contractual arrangements. Within its chosen focus on operational resilience, however, the scoping was, in their view, sound.

Although the framework was generally considered complete within its scope, interviewees repeatedly pointed to third-party ICT risk as a critical aspect of digital operational resilience (I1, I2, I6). I1 and I2 in particular highlighted the practical difficulty of managing risks across multi-tier supply chains, where requirements imposed on direct vendors cannot easily be enforced upon subcontractors. These concerns fall under DORA's dedicated third-party risk management pillar (Articles 28–44), which lies outside the scope of this thesis. Extending the framework to this pillar, beginning with the supplier exit strategy metrics suggested by I6, represents a natural direction for future work.

6

Discussion

The Discussion chapter interprets the results reported in Chapter 5. Sections 6.1 through 6.3 address the study's three research questions in turn. Section 6.4 positions the thesis in the context of existing literature. Finally, sections 6.5 and 6.6 acknowledge the limitations of the study while providing directions for future work.

6.1 Requirements translatable into technically observable and measurable indicators (RQ1)

The GQM methodology was initially applied to the full set of requirements within DORA's ICT Risk Management pillar. As reported in Chapter 5, this pursuit of completeness undermined both the quality of individual metrics and the coherence of the framework as a whole; the expert evaluation prompted a narrowing to the requirements that genuinely support quantitative measurement.

The expert feedback thereby contributed the key criterion for deciding whether a requirement is translatable: the distinction between the design and the execution of ICT risk management. The design of the risk management framework – its policies and its organizational, managerial, and governance arrangements – can only be assessed; its execution, manifested in observable system and process behavior, can be measured and expressed as a coverage, time, count, or rate. Applying this criterion, the requirements of Articles 6 through 13 concerning detection, protection, testing, recovery, and vulnerability and access management proved translatable, while

governance-oriented requirements within the same articles, and Articles 5 and 14 in full, did not.

This boundary is itself a finding rather than a shortfall. It locates the frontier of quantitative measurement within the pillar, within DORA and, arguably, within cyber and operational resilience management more broadly. It also demonstrates that quantitative metrics alone cannot provide a complete evaluation of a credit institution's cyber resilience or compliance, as the requirements on the design side of the boundary still require qualitative assessment. The answer to RQ1 is therefore twofold: the study identified which requirements can be linked to quantitative measurement and established that those that cannot are not thereby unimportant. Rather, they belong to a complementary qualitative assessment approach.

6.2 Suitability of the GQM approach for developing a traceable Cyber Resilience Metrics Framework (RQ2)

The framework's evaluation confirmed that the framework structure and its traceability to regulatory requirements were genuine user requirements rather than incidental byproducts of the derivation process. I6 observed that organizations more commonly work in the opposite direction in practice, mapping existing metrics back to DORA requirements rather than deriving new ones from the regulation outward (Section 5.1.1). This observation is not specific to DORA or to this framework but reflects a structural property of GQM itself. Basili, Caldiera, and Rombach [5] formulated GQM as a top-down process by design, with no mechanism for incorporating existing measurement practice back into goal formulation. Later extensions of GQM addressed this gap; for instance, Philippou, Frey, and Rashid [47] built an explicit bottom-up feedback loop into their security metrics for organizations that already had metrics in place. This trade-off does not undermine the suitability of GQM for the task at hand, but it does clarify the scope of that suitability. GQM's suitability is strongest at the point of artifact construction, where regulatory novelty demands establishing *what* to measure from first principles. On the other hand, it is comparatively weaker as a prescription for how mature organizations should subsequently integrate the artifact into pre-existing measurement practice.

Answering RQ2, the GQM approach proved suitable for deriving a structured and traceable Cyber Resilience Metrics Framework from DORA's ICT

Risk Management requirements, and did so in a context where no established metrics existed to reverse-map from. This suggests a more general design principle for regulation-anchored measurement frameworks: GQM's top-down rigor is best suited to the initial construction of a traceable catalog in the absence of established practice, while the subsequent catalog's adoption should remain deliberately flexible to accommodate organizations that already operate bottom-up.

6.3 Addressing the practical needs of credit institutions for evaluating operational resilience (RQ3)

The evaluation stage confirmed the practical need for the framework developed in this study. The needs of credit institutions can be characterized as follows: understanding DORA's requirements and obtaining relevant cyber resilience metrics that help institutions both track their status quo and take action to improve their cyber resilience capabilities. The resulting framework addresses these needs by design: each metric is anchored to its regulatory origin, and each is specified concretely enough to be collected and acted upon.

At the same time, the expert evaluation emphasized that the framework's relevance is institution-dependent. Some institutions may lack the capacity to track certain metrics, while others may already track most of them as part of their monitoring processes. The structure of the framework accommodates this variation: users can select the goals, questions, and metrics of highest priority, or those whose data collection and monitoring are feasible in their current context. The same logic guided the study team's decision not to suggest thresholds, leaving this step to the institutions themselves.

In response to RQ3, the framework's fit to practice is therefore best summarized as conditional: it provides an expert-informed, regulation-anchored selection of measurable indicators developed through a validated approach, while the final tailoring – metric selection, threshold calibration, and reporting format – remains an exercise for each institution.

6.4 Relation to previous research

This work connects to previous research along two streams. The resulting Cyber Resilience Metrics Framework falls under the KPI-oriented category

identified in Section 2.4.1: it suggests specific, measurable indicators suitable for routine collection and regulatory reporting. Within the metrics-frameworks stream, the contribution of this work lies in metrics derived directly from DORA's ICT Risk Management pillar – a response to the well-recognized but regulation-agnostic frameworks of Linkov et al. [38], Bodeau and Graubart [8], Bodeau et al. [9], and Alhidaifi, Asghar, and Ansari [4]. This thesis, by contrast, takes the requirements of a specific regulation as its foundation, making the resulting framework specific to current regulatory needs and operational resilience concerns. In this respect, the work parallels Ko, Hyeon Lee, and Seo [32], who demonstrated the viability of translating generic cyber resilience constructs into domain-specific KPIs in the maritime sector; this thesis performs an analogous translation for a financial regulation. Regarding the GQM approach itself, its application here extends beyond its traditional software engineering roots. Philippou et al. [47] similarly adapted GQM to derive security metrics traceable to business objectives. This thesis extends GQM's applicability further still, to cyber resilience metrics anchored in a specific financial regulation.

Positioning the work within the literature on cyber resilience in the financial sector, this thesis provides an expert-informed framework that partially answers the call made by Cojocaru [11]. The authors identify existing resilience quantification as static and compliance-focused, failing to capture an entity's ability to detect, react, and recover, and highlight the lack of a harmonized measurement framework. They also explicitly call for empirical validation of resilience frameworks through engagement with credit institutions. This study responds to these calls by developing a measurement framework through a validated approach and evaluating the resulting framework with domain experts. It considers compliance but prioritizes meaningful measurement of resilience over compliance on paper. Similarly, Miya and Joseph [42], based on a bibliometric analysis of two decades of financial-sector cybersecurity research, found that resilience-oriented work remains limited relative to security-focused research and called for holistic frameworks that combine prevention, detection, and recovery rather than treating these capabilities in isolation. The framework developed here responds to this call within the scope of DORA's ICT Risk Management pillar: its goals and metrics span detection, protection, response, and recovery capabilities within a single derivation logic.

In general, this work provides the first comprehensive framework of quantitative cyber resilience metrics derived from DORA's ICT Risk Management requirements. The financial-sector frameworks identified in Section 2.4 (Related work) pursue different objects of measurement. Bose and Caulfield [10] assess maturity in board-level cyber risk governance, while Dong et al. [15] offer a quantification model for defense and recovery investment decisions; neither provides metrics for evaluating the cyber resilience of the organization itself. The contrast with Bose and Caulfield [10] is particularly informative: their KPIs are deliberately framed as yes/no questions about whether governance structures and processes are in place – the very format this study initially adopted and later abandoned, after experts argued during the evaluation that a status can only be assessed, not measured. The two frameworks therefore complement each other: binary process questions may suit governance maturity as an object of measurement, whereas operational resilience demands quantitative indicators of observable system behavior. Read together, they corroborate the boundary between design and execution identified in Section 6.1.

6.5 Limitations

Two limitations qualify the results of this work. First, the framework was evaluated through expert assessment rather than validated through field deployment: it has not been applied operationally by any institution, and metrics that appear feasible in an expert interview may surface unanticipated data-availability or definitional issues once implementation is attempted. The framework's practical utility in operational use therefore remains untested.

Second, while the six interviewees represented policy, financial-sector, and cybersecurity perspectives, most engaged with credit institutions as advisers, consultants, or industry-association representatives rather than as practitioners within the institutions themselves. The perspective of credit institutions' compliance offices and operational teams that would collect, monitor, and act on these metrics is therefore represented only indirectly, and the interviewees' exposure was primarily to institutions of particular profiles. A larger sample including in-house practitioners from credit institutions of varying size and maturity would have strengthened confidence in the findings on practical applicability.

6.6 Future work

The findings from this study point in three directions. First, threshold and benchmark values were deliberately left uncalibrated. A follow-up study scoped to a specific institution type, size, or maturity level could establish these empirically, ideally using operational data from a participating institution rather than expert estimation alone. Moreover, field deployment of the framework with a participating institution, ideally across at least one full measurement cycle, would address the limitation noted in Section 6.5 and could surface practical refinements, such as data-collection tooling or reporting templates, that expert review alone cannot reveal.

Second, interviewees repeatedly raised third-party ICT risks as central to operational resilience. Extending the GQM derivation to DORA's third-party risk management pillar represents a natural next step, allowing the framework to address the multi-tier supply chain risks that I1 and I2 highlighted as difficult to manage in practice.

Third and final, the design/execution boundary identified in Section 6.1 suggests a complementary line of work: developing a qualitative assessment instrument for the governance, policy-design, and organizational requirements this framework deliberately excludes, so that institutions could pair the two into a single, complete DORA ICT Risk Management assessment rather than treating quantitative and qualitative evaluation as separate exercises.

7

Conclusion

In the context of interconnected digital business ecosystems, digital and operational resilience is vital to credit institutions' continuous performance. To ensure institutions consistently monitor and strengthen the resilience of their ICT systems, DORA mandates the operationalization of ICT risk management through KPIs and risk metrics. However, neither DORA nor its technical standards prescribe specific indicators or a method for deriving them from the regulation. This gap motivated the central aim of this thesis: to develop an expert-informed framework of cyber resilience metrics, grounded in the Goal-Question-Metric (GQM) approach, for measuring those aspects of DORA's ICT Risk Management pillar that are best captured in quantitative terms.

During the formative evaluation sessions with experts, three main findings emerged, corresponding to the thesis's three research questions. First, a DORA requirement is translatable into a technically measurable indicator when it concerns the framework's technical execution – the observable behavior of systems and processes, expressible as coverage, time, or rate – rather than its design, such as policies or governance arrangements (RQ1). Second, the GQM approach proved suitable for developing a traceable Cyber Resilience Metrics Framework: its hierarchical structure emerged directly from the method itself, as goals were refined into questions and questions into metrics, each with a direct link to the source article and paragraph (RQ2). Finally, expert feedback confirmed that understanding DORA's

requirements and deriving relevant cyber resilience metrics to help institutions monitor and improve their cyber resilience capabilities is a genuine practical need – one that the developed framework addresses (RQ3).

This thesis presents the first expert-evaluated Cyber Resilience Metrics Framework for DORA-compliant credit institutions. The framework can be adapted to an institution's needs depending on its maturity and size, and each metric is specified with attributes such as definition, measurement type, formula, and suggested data sources. Thresholds were deliberately excluded as organization-specific. Altogether, the framework is a near-ready-to-use tool for credit institutions to quantitatively measure the resilience of their systems in a DORA-compliant way. Finally, although credit institutions were the focus of this thesis and validating experts were themselves affiliated with credit institutions, the framework is equally applicable to other financial entities under DORA, because the derived metrics cover all quantitatively measurable aspects of the regulation's ICT risk management pillar.

Bibliography

[1] Adewale A. Ademowo. “Operational resilience implementation: Challenges and opportunities for UK building societies”. In: *Journal of Risk Management in Financial Institutions* 17.4 (Oct. 1, 2024), p. 395. ISSN: 1752-8895. DOI: 10.69554/YNUO2601. URL: https://hstalks.com/doi/10.69554/YNUO2601/ (visited on 03/23/2026).

[2] Ali Aghazadeh Ardebili, Marianna Lezzi, and Mahdad Pourmadadkar. “Risk Assessment for Cyber Resilience of Critical Infrastructures: Methods, Governance, and Standards”. In: *Applied Sciences* 14.24 (Dec. 17, 2024), p. 11807. ISSN: 2076-3417. DOI: 10.3390/app142411807. URL: https://www.mdpi.com/2076-3417/14/24/11807 (visited on 03/10/2026).

[3] Saleh Mohamed AlHidaifi, Muhammad Rizwan Asghar, and Imran Shafique Ansari. “Towards a Cyber Resilience Quantification Framework (CRQF) for IT infrastructure”. In: *Computer Networks* 247 (June 2024), p. 110446. ISSN: 13891286. DOI: 10.1016/j.comnet.2024.110446. URL: https://linkinghub.elsevier.com/retrieve/pii/S1389128624002780 (visited on 03/23/2026).

[4] Saleh Mohamed Alhidaifi, Muhammad Rizwan Asghar, and Imran Shafique Ansari. “A Survey on Cyber Resilience: Key Strategies, Research Challenges, and Future Directions”. In: *ACM Computing Surveys* 56.8 (Aug. 31, 2024), pp. 1–48. ISSN: 0360-0300, 1557-7341. DOI: 10.1145/3649218. URL: https://dl.acm.org/doi/10.1145/3649218 (visited on 03/23/2026).

[5] Victor R Basili, Gianluigi Caldiera, and H Dieter Rombach. “THE GOAL QUESTION METRIC APPROACH”. In: (1994).

[6] Victor R. Basili et al. “Linking Software Development and Business Strategy Through Measurement”. In: *Computer* 43.4 (Apr. 2010), pp. 57–65. ISSN: 0018-9162, 1558-0814. DOI: 10.1109/MC.2010.108. URL:

https://ieeexplore.ieee.org/document/5445168/ (visited on 03/08/2026).

[7] Joy Dalmacio Billanes, Bo Nørregaard Jørgensen, and Zheng Ma. "A Framework for Resilient Community Microgrids: Review of Operational Strategies and Performance Metrics". In: *Energies* 18.2 (Jan. 17, 2025), p. 405. ISSN: 1996-1073. DOI: 10.3390/en18020405. URL: https://www.mdpi.com/1996-1073/18/2/405 (visited on 03/23/2026).

[8] Deborah Bodeau and Richard Graubart. *Cyber Resilience Metrics: Key Observations*. Technical Report 16-0779. MITRE Corporation, Jan. 1, 2015.

[9] Deborah J. Bodeau et al. *Cyber Resiliency Metrics, Measures of Effectiveness, and Scoring*. Technical Report 18-2579. MITRE Corporation, Sept. 2018.

[10] Robert Bose and Tristan Caulfield. "Cyber Risk Integration framework for Boards (CRIB): If Boards Had KPIs, Would They Pass?" In: *Proceedings of the 2025 New Security Paradigms Workshop*. NSPW '25. New York, NY, USA: Association for Computing Machinery, Jan. 29, 2026, pp. 139–159. ISBN: 979-8-4007-1875-5. DOI: 10.1145/3774761.3774773. URL: https://dl.acm.org/doi/10.1145/3774761.3774773 (visited on 03/21/2026).

[11] Andra Cojocaru. "Aligning regulation and governance for cyber resilience: A theoretical framework for the UK Financial Sector". In: *Computers & Security* 157 (Oct. 2025), p. 104627. ISSN: 01674048. DOI: 10.1016/j.cose.2025.104627. URL: https://linkinghub.elsevier.com/retrieve/pii/S0167404825003165 (visited on 03/23/2026).

[12] Martyn Denscombe. "The Good Research Guide: For Small-scale Social Research Projects". In: 4 (2010), p. 392.

[13] Sintija Deruma. "Cyber Resilience Key Metrics in Small and Medium-Sized Enterprises". In: *Economics Ecology Socium* 9.1 (Mar. 31, 2025), pp. 15–23. ISSN: 2616-7107, 2616-7107. DOI: 10.61954/2616-7107/2025.9.1-2. URL: https://ees-journal.com/index.php/journal/article/view/278 (visited on 03/25/2026).

[14] Barbara DiCicco-Bloom and Benjamin F Crabtree. "The qualitative research interview". In: *Medical Education* 40.4 (Apr. 2006), pp. 314–321. ISSN: 0308-0110, 1365-2923. DOI: 10.1111/j.1365-2929.2006.02418.x. URL: https://asmepublications.onlinelibrary.wiley.com/doi/10.1111/j.1365-2929.2006.02418.x (visited on 03/08/2026).

[15] Kunxiang Dong et al. “Building cybersecurity resilience: integrating defense and recovery investment strategies in an expected resilience framework”. In: *Journal of Enterprise Information Management* 38.2 (Feb. 25, 2025), pp. 502–531. ISSN: 1741-0398. DOI: 10.1108/JEIM-04-2023-0189. URL: http://www.emerald.com/jeim/article/38/2/502-531/1240933 (visited on 03/23/2026).

[16] Doran, George T. “There’s a S.M.A.R.T. way to write managements’s goals and objectives”. In: *Management Review* 70.1 (1981), p. 35.

[17] Aline Dresch, Daniel Pacheco Lacerda, and José Antonio Valle Antunes. *Design science research: a method for science and technology advancement*. Cham Heidelberg New York Dordrecht London: Springer, 2015. 1 p. ISBN: 978-3-319-07373-6 978-3-319-07374-3.

[18] Benoît Dupont. “The cyber-resilience of financial institutions: significance and applicability”. In: *Journal of Cybersecurity* 5.1 (Jan. 1, 2019), tyz013. ISSN: 2057-2085, 2057-2093. DOI: 10.1093/cybsec/tyz013. URL: https://academic.oup.com/cybersecurity/article/doi/10.1093/cybsec/tyz013/5585673 (visited on 04/04/2026).

[19] European Parliament and Council of the European Union. *Regulation EU 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector*. Dec. 14, 2022. URL: https://eur-lex.europa.eu/eli/reg/2022/2554/oj.

[20] Esther Eze and Gahangir Hossain. “Redefining Cyber Resilience: AI-Driven Metrics for Enhanced Threat Intelligence Systems”. In: *2025 IEEE International Carnahan Conference on Security Technology (ICCST)*. 2025 IEEE International Carnahan Conference on Security Technology (ICCST). San Antonio, TX, USA: IEEE, Oct. 13, 2025, pp. 1–7. ISBN: 979-8-3315-2319-0. DOI: 10.1109/ICCST63435.2025.11293935. URL: https://ieeexplore.ieee.org/document/11293935/ (visited on 03/23/2026).

[21] Rosanna Fornasiero and Tullio A. M. Tolio. “Digital supply chains for ecosystem resilience: a framework for the Italian case”. In: *Operations Management Research* 18.1 (Mar. 2025), pp. 210–225. ISSN: 1936-9735, 1936-9743. DOI: 10.1007/s12063-024-00511-2. URL: https://link.springer.com/10.1007/s12063-024-00511-2 (visited on 02/03/2026).

[22] Ivo Friedberg et al. “Towards a Resilience Metric Framework for Cyber-Physical Systems”. In: 4th International Symposium for ICS & SCADA Cyber Security Research 2016. Oct. 2016. DOI: 10.14236/ewic/ICS2016.3. URL: https://scienceopen.com/hosted-document?doi=10.14236/ewic/ICS2016.3 (visited on 04/04/2026).

[23] Lakshmi Goel et al. “Information systems security resilience as a dynamic capability”. In: *Journal of Enterprise Information Management* 36.4 (June 13, 2023), pp. 906–924. ISSN: 1741-0398. DOI: 10.1108/JEIM-07-2022-0228. URL: http://www.emerald.com/jeim/article/36/4/906-924/201088 (visited on 03/25/2026).

[24] Yu Han, Woon Kian Chong, and Dong Li. “A systematic literature review of the capabilities and performance metrics of supply chain resilience”. In: *International Journal of Production Research* 58.15 (Aug. 2, 2020), pp. 4541–4566. ISSN: 0020-7543, 1366-588X. DOI: 10.1080/00207543.2020.1785034. URL: https://www.tandfonline.com/doi/full/10.1080/00207543.2020.1785034 (visited on 03/25/2026).

[25] Tracy Hatton et al. “Developing a model and instrument to measure the resilience of critical infrastructure sector organisations”. In: *International Journal of Critical Infrastructures* 14.1 (2018), p. 59. ISSN: 1475-3219, 1741-8038. DOI: 10.1504/IJCIS.2018.090653. URL: http://www.inderscience.com/link.php?id=90653 (visited on 03/25/2026).

[26] Viktoriia Hrosul et al. “Enterprise digital resilience capability framework: an integrated dynamic capability approach”. In: *Entrepreneurship and Sustainability Issues* 13.2 (Dec. 1, 2025), pp. 399–416. ISSN: 2345-0282. DOI: 10.9770/e4483987593. URL: https://jssidoi.org/jesi/article/1382 (visited on 03/25/2026).

[27] Chhaya Jahajeeah-Suntoo and Sheeba Armoogum. “Towards an AI-Powered Cyber Resilience Model: A Systematic Evaluation of Frameworks Against Emerging Threats”. In: *International Journal of Advanced Computer Science and Applications* 17.1 (2026). ISSN: 21565570, 2158107X. DOI: 10.14569/IJACSA.2026.0170106. URL: http://thesai.org/Publications/ViewPaper?Volume=17&Issue=1&Code=ijacsa&SerialNo=6 (visited on 03/23/2026).

[28] James Moore. “Predators and Prey: A New Ecology of Competition”. In: 71 (May 1999), pp. 75–86.

[29] John R. Venable; Jan Pries-Heje; Richard L. Baskerville. “Choosing a Design Science Research Methodology”. In: *ACIS 2017 Proceedings*. Australasian Conference on Information Systems 2017. Hobart, Tasmania, Australia, 2017, p. 112. URL: https://aisel.aisnet.org/acis2017/112.

[30] Aiga Kanepa, Jeļena Trokša, and Andrejs Romānovs. “Impact Assessment of the DORA Regulation on IT Governance”. In: *2025 66th International Scientific Conference on Information Technology and Management Science of Riga Technical University (ITMS)*. 2025 66th International Scientific Conference on Information Technology and Management Science of Riga Technical University (ITMS). Riga, Latvia: IEEE, Oct. 9, 2025, pp. 1–7. ISBN: 979-8-3315-4528-4. DOI: 10.1109/ITMS67030.2025.11236606. URL: https://ieeexplore.ieee.org/document/11236606/ (visited on 03/23/2026).

[31] Jin Kim and Sam Youl Lee. “Cyber Resilience of Ships: An Evaluation of Guideline and Frameworks”. In: *IEEE Access* 13 (2025), pp. 97337–97347. ISSN: 2169-3536. DOI: 10.1109/ACCESS.2025.3571438. URL: https://ieeexplore.ieee.org/document/11007106/ (visited on 03/23/2026).

[32] Areum Ko, Ju Hyeon Lee, and Jung Taek Seo. “KPI-Based Evaluation Framework for Cyber Resilience of Ships”. In: *IEEE Access* 13 (2025), pp. 64226–64245. ISSN: 2169-3536. DOI: 10.1109/ACCESS.2025.3550501. URL: https://ieeexplore.ieee.org/document/10924200/ (visited on 04/04/2026).

[33] Nelli Kononova et al. “Resilience in manufacturing enterprises – connecting resilience, factory flows and sustainability dimensions”. In: *Procedia CIRP* 135 (2025), pp. 582–587. ISSN: 22128271. DOI: 10.1016/j.procir.2024.12.080. URL: https://linkinghub.elsevier.com/retrieve/pii/S221282712500321X (visited on 03/23/2026).

[34] Beāte Krauze. “An Analysis of Resilience in Digital Business Ecosystems”. In.

[35] Victor Emmanuel Kulugh, Uche M. Mbanaso, and Gloria Chukwudebe. “Cybersecurity Resilience Maturity Assessment Model for Critical National Information Infrastructure”. In: *SN Computer Science* 3.3 (May 2022), p. 217. ISSN: 2662-995X, 2661-8907. DOI: 10.1007/s42979-022-01108-x. URL: https://link.springer.com/10.1007/s42979-022-01108-x (visited on 03/23/2026).

[36] Yves Le Bray, Nicolas Mayer, and Jocelyn Aubert. “Defining measurements for analyzing information security risk reports in the telecommunications sector”. In: *Proceedings of the 31st Annual ACM Symposium on Applied Computing*. SAC ’16. New York, NY, USA: Association for Computing Machinery, Apr. 4, 2016, pp. 2189–2194. ISBN: 978-1-4503-3739-7. DOI: 10.1145/2851613.2851847. URL: https://dl.acm.org/doi/10.1145/2851613.2851847 (visited on 03/21/2026).

[37] Yvonna S. Lincoln and Egon G Guba. *Naturalistic Inquiry*. Beverly Hills, CA: SAGE Publications, 1985. ISBN: 978-0-8039-2431-4.

[38] Igor Linkov et al. “Resilience metrics for cyber systems”. In: *Environment Systems and Decisions* 33.4 (Dec. 2013), pp. 471–476. ISSN: 2194-5403, 2194-5411. DOI: 10.1007/s10669-013-9485-y. URL: http://link.springer.com/10.1007/s10669-013-9485-y (visited on 04/06/2026).

[39] Muharman Lubis et al. “Guarding Our Vital Systems: A Metric for Critical Infrastructure Cyber Resilience”. In: *Sensors* 25.15 (July 22, 2025), p. 4545. ISSN: 1424-8220. DOI: 10.3390/s25154545. URL: https://www.mdpi.com/1424-8220/25/15/4545 (visited on 03/25/2026).

[40] Jose Marquez-Tejon, Montserrat Jimenez-Partearroyo, and Diana Benito-Osorio. “Integrated security management model: a proposal applied to organisational resilience”. In: *Security Journal* 37.2 (June 2024), pp. 375–398. ISSN: 0955-1662, 1743-4645. DOI: 10.1057/s41284-023-00381-6. URL: https://link.springer.com/10.1057/s41284-023-00381-6 (visited on 03/25/2026).

[41] Uche M. Mbanaso, Lucienne Abrahams, and Oghenevovwero Zion Apene. “Conceptual Design of a Cybersecurity Resilience Maturity Measurement (CRMM) Framework”. In: *The African Journal of Information and Communication (AJIC)* 23 (June 27, 2019). ISSN: 2077-7213, 2077-7205. DOI: 10.23962/10539/27535. URL: https://ajic.wits.ac.za/article/view/13552 (visited on 03/25/2026).

[42] Ntokozo F. Miya and Nazeer Joseph. “Banking on resilience: 20 years of cybersecurity evolution”. In: *South African Journal of Information Management* 27.1 (Sept. 18, 2025). ISSN: 1560-683X, 2078-1865. DOI: 10.4102/sajim.v27i1.2019. URL: https://sajim.co.za/index.php/sajim/article/view/2019 (visited on 03/25/2026).

[43] Michael D. Myers. *Qualitative Research in Business & Management*. 1 Oliver's Yard, 55 City Road London EC1Y 1SP: SAGE Publications Ltd., 2009. ISBN: 978-0-85702-974-4 978-1-0362-0841-7. DOI: 10.4135/9781036208417. URL: https://sk.sagepub.com/books/qualitative-research-in-business-and-management-2e (visited on 03/08/2026).

[44] Ogochukwu Susan Ndibe. "CYBER-ALIGN™ Maturity Index: A Multi-Dimensional Evaluation Framework for Measurable Cyber Resilience Across Governance, Human Behavior, and Operational Controls". In: ().

[45] Chitu Okoli and Kira Schabram. "A Guide to Conducting a Systematic Literature Review of Information Systems Research". In: *SSRN Electronic Journal* (2010). ISSN: 1556-5068. DOI: 10.2139/ssrn.1954824. URL: http://www.ssrn.com/abstract=1954824 (visited on 03/08/2026).

[46] Ken Peffers et al. "A Design Science Research Methodology for Information Systems Research". In: *Journal of Management Information Systems* 24.3 (Dec. 2007), pp. 45–77. ISSN: 0742-1222, 1557-928X. DOI: 10.2753/MIS0742-1222240302. URL: https://www.tandfonline.com/doi/full/10.2753/MIS0742-1222240302 (visited on 03/08/2026).

[47] Eleni Philippou, Sylvain Frey, and Awais Rashid. "Contextualising and aligning security metrics and business objectives: A GQM-based methodology". In: *Computers & Security* 88 (Jan. 2020), p. 101634. ISSN: 01674048. DOI: 10.1016/j.cose.2019.101634. URL: https://linkinghub.elsevier.com/retrieve/pii/S0167404818305170 (visited on 08/29/2026).

[48] Prince Kwame Senyo, Kecheng Liu, and John Effah. "Digital business ecosystem: Literature review and a framework for future research". In: *International Journal of Information Management* 47 (Aug. 2019), pp. 52–64. ISSN: 02684012. DOI: 10.1016/j.ijinfomgt.2019.01.002. URL: https://linkinghub.elsevier.com/retrieve/pii/S0268401218305991 (visited on 04/20/2026).

[49] Swedish Research Council. *Good Research Practice (2017)*. 2017.

[50] Richard J. Tarpey and Matthew T. Mullarkey. "Extending Design Science Research Through Systems Theory: A Hospital System of Systems". In: *Extending the Boundaries of Design Science Theory and Practice*. Ed. by Bengisu Tulu, Soussan Djamasbi, and Gondy Leroy. Vol. 11491. Series Title: Lecture Notes in Computer Science. Cham: Springer International Publishing, 2019, pp. 108–122. ISBN: 978-3-030-19503-8 978-3-030-19504-5. DOI: 10.1007/978-3-030-19504-5_8.

URL: http://link.springer.com/10.1007/978-3-030-19504-5_8 (visited on 03/08/2026).

[51] John Venable, Jan Pries-Heje, and Richard Baskerville. "A Comprehensive Framework for Evaluation in Design Science Research". In: *Design Science Research in Information Systems. Advances in Theory and Practice*. Ed. by Ken Peffers, Marcus Rothenberger, and Bill Kuechler. Red. by David Hutchison et al. Vol. 7286. Series Title: Lecture Notes in Computer Science. Berlin, Heidelberg: Springer Berlin Heidelberg, 2012, pp. 423–438. ISBN: 978-3-642-29862-2 978-3-642-29863-9. DOI: 10.1007/978-3-642-29863-9_31. URL: http://link.springer.com/10.1007/978-3-642-29863-9_31 (visited on 08/08/2026).

[52] Jane Webster and Richard T Watson. "ANALYZING THE PAST TO PREPARE FOR THE FUTURE: WRITING A LITERATURE REVIEW". In: ().

[53] Ratna Mira Yojana and Teuku Yuri M. Zagloel. "Evaluation of Supply Chain Resilience: Development of RARE Framework". In: *Proceedings of the 3rd Asia Pacific Conference on Research in Industrial and Systems Engineering*. APCORISE '20. New York, NY, USA: Association for Computing Machinery, Aug. 25, 2020, pp. 305–309. ISBN: 978-1-4503-7600-6. DOI: 10.1145/3400934.3400990. URL: https://dl.acm.org/doi/10.1145/3400934.3400990 (visited on 03/21/2026).

A

Explicit systematic literature review plan and protocol

A.1 SLR protocol

This study adopted a systematic literature review (SLR) methodology following the approach proposed by Okoli and Schabram [45]. Their approach enables structured and transparent identification and evaluation of existing research, as well as the synthesis of key findings from prior work in the defined domain. Structure and transparency are achieved and ensured by establishing and adhering to a clearly documented protocol that records decisions and actions, thereby supporting replicability and minimizing research bias.

Below, the key stages undertaken by the study team according to the SLR methodology are detailed. These stages included defining the purpose of the review, developing a search protocol, conducting systematic database searches, screening relevant studies, extracting data, and synthesizing findings.

A.1.1 Purpose of the review

The review aimed to map how cyber resilience is conceptualized and measured, identify commonly used indicators and metrics, and highlight gaps in measurement approaches relevant to financial sector risk management, particularly in the context of regulatory requirements such as DORA. Accordingly, the purpose of this systematic literature review was twofold:

1. To identify existing research on resilience metrics and measurement approaches relevant to ICT risk management in financial institutions;
2. To identify frameworks and conceptual models used to measure cyber resilience in digital business ecosystems, with relevance to regulatory-driven resilience requirements.

A.1.2 Structured review protocol

A structured review protocol ensuring transparency and replicability of the review process is detailed below, detailing research questions, data sources, queries and search strings, inclusion and exclusion criteria, practical screening, quality appraisal, data extraction, data analysis and synthesis, as well as reporting of the findings.

A.1.2.1 Research questions

The literature review was guided by the following research questions:

- RQ1: What metrics and indicators are most commonly used to measure cyber resilience in ICT systems?
- RQ2: What frameworks and conceptual models exist for assessing cyber resilience?
- RQ3: How are cyber resilience measurement approaches applied in financial institutions?

A.1.2.2 Data sources

The literature review drew on three key databases: ACM Digital Library, Scopus, and Web of Science.

- ACM Digital Library was selected for its domain focus, particularly computing and information technology.
- Scopus – a multidisciplinary abstract and citation database – was chosen to capture diverse literature, offering comprehensive coverage of scientific, technical, and social science literature, disciplines relevant to the study's subject.
- Web of Science (WoS) was selected as a comprehensive scientific citation indexing service with extensive citation search capabilities. As it provides access to multiple databases that reference cross-disciplinary

research, it was considered critical to exploring our subject, which lies at the intersection of regulations and ICT management.

A.1.2.3 Search strategy

The study team employed a range of queries and search strings tailored to each database and the desired breadth of the search. The queries were designed to capture literature on broad domains covered by the study, such as operational resilience , cyber resilience capabilities, or measurement frameworks, while others were more targeted to retrieve studies specifically related to the financial sector and ICT risk management. The search strings combined keywords related to cyber resilience (or resilience more broadly, to capture relevant articles on digital or operational resilience), metrics (including KPIs and indicators), and ICT systems. Additionally, some queries incorporated terms such as frameworks, models, and theories to identify conceptual contributions.

Although this study focuses on the Digital Operational Resilience Act (DORA), the queries did not limit the search exclusively to DORA. Given that DORA is a relatively new regulation at the time of writing, the search strategy also aimed to capture literature referencing other regulations, requirements, programs, or initiatives that incentivize or mandate financial institutions to develop ICT management frameworks, as well as KPIs and risk indicators for assessing cyber resilience.

Furthermore, for the ACM Digital Library each query was run twice, for Journals (Research Articles) and Proceedings (Research Articles), as the platform did not allow to select both types of publications at the same time.

The full set of unique queries across the three databases is presented below.

A.1.2.4 Inclusion and exclusion criteria

The study team applied a set of pre-established inclusion and exclusion criteria to ensure the relevance and quality of selected studies. Some criteria were operationalised through database filters during the search process, while others were applied manually during screening.

Filter-based criteria To scope the literature, the search was limited to publications from the past ten years (2016–2026). Although the Digital Operational Resilience Act (DORA) was introduced in 2023 and enforced in 2025 and therefore has limited dedicated literature, this ten-year window allowed the inclusion of adjacent or foundational works addressing other

regulations, requirements, or best practices for establishing metrics and KPIs.

In terms of publication type, only peer-reviewed research outputs were included. Accordingly, the following filters were applied across databases:

- ACM Digital Library: Journals (Research Articles) and Proceedings (Research Articles)
- Scopus: Journals and Conference Proceedings
- Web of Science: Articles

Elegibility criteria The remaining criteria were applied manually on a case-by-case basis during the screening process to determine the inclusion or exclusion of each article (see Table A.1.2.4).

Inclusion criteria	Exclusion criteria
Focus on cyber resilience or ICT resilience	Focus solely on cybersecurity prevention without resilience
Propose or analyse metrics, indicators, or measurement approaches	Do not include measurement or evaluation aspects
Present frameworks, models, or methodologies for ICT risk management or measurement	Are editorials, presentations, or other non-scholarly articles
Are peer-reviewed journal articles or conference papers	
Are written in English	
Are published between 2016 and 2026	

Table A.1: Inclusion and exclusion criteria

A.1.2.5 Practical screening

The screening process was conducted in multiple stages to ensure systematic and transparent selection of relevant studies:

- Stage 1: Pre-screening of titles and abstracts in databases
  Before importing records into Zotero, articles were initially screened directly within each database to remove obviously irrelevant papers. This pre-screening step focused on excluding studies that addressed technical approaches to cyber resilience without any connection to

metrics or KPIs. At this stage, a significant proportion of articles were excluded for focusing on practical methods, tools, or interventions rather than measurement approaches. Additionally, articles proposing mathematical or statistical models emphasizing predictability and institutional planning were excluded, as they fell outside the scope of measurement frameworks and indicators. Similarly, studies discussing AI agents and predictive tools aimed at enhancing cyber resilience were deemed outside the scope and excluded.

- Stage 2: Duplicate removal
  Following the initial pre-screening, the reduced set of records was imported into Zotero, where duplicate entries across the three databases were identified and removed.

- Stage 3: Full-text review
  For unique articles that passed the title and abstract screening, the full text was reviewed to confirm alignment with the inclusion criteria. During this stage, articles that were found to be irrelevant upon full reading were removed. The remaining articles were used for analysis, data extraction and synthesis of findings.

A.1.2.6 Quality appraisal

Because the review focused on conceptual frameworks and resilience metrics rather than empirical studies, a detailed methodological quality appraisal was not performed. Instead, the review was limited to peer-reviewed journal articles and conference papers indexed in major academic databases, ensuring that the quality of the reviewed literature is sufficient for the purposes of this study.

A.1.2.7 Data analysis and synthesis

The extracted data were analysed using a descriptive synthesis approach. Studies were organised according to the cyber resilience frameworks proposed, the metrics and indicators used for measurement, and the application domains. The analysis specifically focused on:

- Commonly used cyber resilience metrics
- Types of frameworks and conceptual models
- Measurement approaches across different ICT systems and digital ecosystems, with a particular focus on business ecosystems

- Research gaps and limitations

A.1.2.8 Reporting the review

The results were reported in a structured format including the following:

- PRISMA-style flow diagram illustrating the literature selection process
- Descriptive statistics of publications
- Descriptive synthesis of key insights from the studies
- Identification of research gaps and future research directions

A.1.3 Backward snowballing

To ensure extensive coverage beyond the results retrieved through the database queries, backward snowballing was incorporated as a complementary search technique. This procedure consists of systematically examining the reference lists of all articles selected after the practical screening. The goal of backward snowballing is to identify relevat studies that may have been missed by the original search or were not indexed in the consulted databases. All candidate articles surfaced through this process were evaluated against the same inclusion and exclusion criteria applied on the primary phase.

A.2 SLR findings

A.2.1 Selection process

Using the aforementioned queries, the study team identified 1,746 articles across the three databases – ACM Digital Library, Scopus, and Web of Science (see Table A.2.1). The study team members performed the initial screening of titles and abstracts directly in the databases, which resulted in the exclusion of 1,673 articles. The remaining 73 articles were imported to the Zotero library, where they were deduplicated. Deduplication was performed across all three databases in one consolidated step to reduce the workload, particularly given that two different study team members were responsible for article identification across different databases – one covering ACM Digital Library, and the other covering Scopus and WoS, respectively. After deduplication, 60 unique articles remained for full-text assessment. These were reviewed in detail, and study team members completed

each article's profile with key information. As a result of this review, 38 articles were excluded and 22 were retained for the analysis.

Identification	Records identified through database search (η= 1,746)
Screening	• Records screened on title and abstract (η= 1,746) • Records excluded at title/abstract screening (η= 1,686) • Records retained for full-text assessment (η= 73) • Records retained after the deduplication (η= 60)
Eligibility	• Full-text articles assessed for eligibility (η= 60) • Excluded: bibliographic error (η= 1); not publicly available (η= 4); irrelevant content/did not meet the SRL search criteria (η= 33) • Additional records identified via backward snowballing (η= 7)
Inclusion	Studies included in review (η= 29)

Table A.2: Identification of studies via databases

A.2.2 Descriptive statistics of publications

The retained articles span over a decade, ranging from 2013 to 2026, with the majority published in 2025 (η= 11). The preceding year, 2024 and year 2019 contributed three articles each. The current year, 2026, contributed two articles. It should be noted that 2026 figures are not yet complete, as only the first quarter of the year has passed at the time of writing, and additional publications are expected. For the full list of retained and analyzed articles see Table A.3.

Concerning application domains, the corpus is varied. The largest share is covered by studies addressing multiple sectors simultaneously (η= 9), followed by η= 6 studies focused on the financial sector and η= 5 studies focusing on the critical infrastructure. Of the five financial sector articles, four address the sector broadly, while one focuses specifically on the insurance industry. The remaining articles are distributed across organizational and governance contexts (η= 3), supply chain (η= 2), and single contributions from ICT/IT systems, telecommunications, maritime and manufacturing respectively.

Regarding the frameworks identified, overviewed, or proposed across the included studies, capability frameworks were the most prevalent, represented in 10 articles. These were followed by quantification frameworks (η= 6) and conceptual or theoretical frameworks and maturity models (η= 3 each). Capability frameworks typically describe the organizational or system-level capacities required for resilience (anticipation, absorption, response, and recovery). However, they do not always specify how to measure these capabilities. Quantification frameworks go further by operationalizing resilience into measurable, often time-based indicators that can be computed or scored. Maturity models, in contrast, assess the degree to which an organization has developed and embedded resilience practices. These studies usually employ a stage- or score-based system to evaluate the organization and categorize it according to a specific maturity type or level.

It is worth noting that a substantial number of articles were excluded at the screening stage precisely because they presented mathematical or predictive models aimed at improving the predictability of cyber-attacks or evaluating the relative importance of resilience factors, without identifying or naming specific indicators or metrics that could be applied in practice. The articles retained for this review were distinguished because of providing examples, exploring, comparing, proposing or evaluating metrics, indicators, or measurement approaches, which form the basis of the analysis in the following section.

A.2.3 Descriptive synthesis of key insights from the studies

Out of 29 retained articles, 24 articles included metrics. Most articles (η= 20) focused on **performance metrics**, which typically measure an organization's ability to respond to and recover from cyber disruptions. These included time-based metrics such as detection speed [53], detection latency [11], detection coverage [53], response speed [53], [23], recovery speed [53], [23], [25], as well as more granular metrics like start recovery time and complete recovery time [3]. Beyond these basic temporal measures, performance metrics also included false positive rate, threat intelligence correlation rate, and incident escalation accuracy [20], as well as composite resilience scores that aggregate multiple performance dimensions [53], [35], [39].

In addition, 16 articles contained **organizational metrics**, many of which focus on cybersecurity or cyber resilience maturity. These often take the

form of composite scores or indexes that rely on multiple underlying measurements, such as processes, policies, or structural requirements of a resilient organization. Examples include maturity scale scores and cyber resilience readiness scores per maturity quadrant [41], regulatory compliance and governance maturity scores [11], and risk governance and leadership maturity [10]. Other organizational metrics identified in the literature include board-level cyber risk oversight, testing frequency and coverage, third-party risk management, situational awareness, collaboration and information sharing, and adaptive capacity [24], [25], [13], [10].

A smaller number of articles addressed **technical metrics** (η= 11) and **compliance metrics** (η= 5). Technical metrics included system reliability (downtime), stability, flexibility, scalability, security control effectiveness, and vulnerability exposure scores [7], [39]. Compliance metrics focused primarily on regulatory adherence, including regulatory compliance rate, non-compliance incidents, annual risk management completion, and reporting completeness and timeliness [11], [36], [13].

It must be noted that many articles contained more than one category of indicators, and some metrics could be classified into more than one type. Some performance metrics, such as false positive rate and detection latency, could also be considered technical as they relate to system functions. However, for the purpose of this review, we classify metrics as performance when they measure speed, accuracy, or effectiveness, and as technical when they measure system attributes such as reliability or scalability. That said, this analysis has improved our understanding of the types of metrics being reviewed and serves as a foundation upon which we have built our own framework of metrics.

Zooming in on the financial sector, six articles specifically focused on this domain. Of these, three explicitly identified metrics [15], [11], [10]: detection latency, mean time to recover (MTTR), regulatory compliance rate, governance maturity score, and adaptive capacity index [11]; cyber risk classification status, organizational hierarchy clarity, risk governance and leadership maturity, board cyber risk oversight effectiveness, ICT third-party risk management score, incident reporting completeness, and resilience testing frequency [10]; and robustness, redundancy, resourcefulness, rapidity, time to recovery, recovery level, profit losses during disruption, expected resilience utility score [15]. These three articles demonstrate that resilience frameworks in regulated financial sectors include diverse indicators spanning performance, organizational, and compliance types.

A.2.4 Identification of research gaps and future research directions

Ultimately, our systematic literature review highlights the following key findings and gaps:

1. Performance metrics were the most frequently cited category, suggesting that literature emphasizes concrete time-based indicators such as detection latency, recovery time, and response speed. This aligns with DORA's expectations for measurable ICT resilience and its call for KPIs and risk metrics. This finding encourages us to focus on performance indicators when building our own measurement framework.

2. Compliance metrics appeared least frequently, with only four articles explicitly addressing regulatory adherence indicators such as incident reporting completeness, testing frequency, and regulatory compliance rates. This is a critical gap, especially for highly regulated sectors or infrastructures of critical importance to the nation or state. In particular, the financial sector must not only perform well but also demonstrate compliance with specific legal obligations. If concrete best practice compliance indicators exist, it can be easier for financial institutions to track their compliance processes and meet their obligations with due diligence and in a timely manner. Furthermore, compliance indicators are prioritized in this study due to the binding regulatory requirements imposed by DORA on financial institutions.

Ref	Author (Year)	Research Domain	Framework Type	Application Domain	Key Metrics	Metric Types
[4]	Alhidaifi et al. (2024)	Cyber resilience	No framework proposed/Not applicable	Cross-sector / Multiple	—	—
[3]	AlHidaifi et al. (2024)	IT infrastructure cyber resilience	Quantification framework	ICT / IT systems	Start attack time; Start recovery time; Absorb/Recover/Adapt duration	Performance
[7]	Billanes et al. (2025)	Energy resilience	Capability framework	Critical infrastructure	Resilience; Reliability (downtime); Stability; Flexibility (adaptability); Efficiency; Security (cyber protection); Scalability; Load prioritization effectiveness; FDI attack mitigation rate	Performance; Technical
[9]	Bodeau et al. (2018)	Cyber resilience governance	Quantification framework	Cross-sector / Multiple	Area under performance curve; Time to restart/transfer; Attack surface size; % mission capabilities restored; % stakeholders notified	Performance; Technical; Organizational
[10]	Bose and Caulfield (2026)	Cyber resilience governance	Governance framework	Financial sector	Cyber risk classification; Risk governance maturity; Board oversight effectiveness; Incident reporting completeness; Resilience testing frequency	Organizational; Compliance
[8]	Bodeau and Graubart (2015)	Cyber resilience governance	No framework proposed/Not applicable	Cross-sector / Multiple	Single figure-of-merit; Cyber value-at-risk; System Survivability KPP; MOEs; MOPs; CERT RMM metrics	Performance; Technical; Organizational
[11]	Cojocaru (2025)	Cyber resilience governance	Conceptual / Theoretical framework	Financial sector	Detection latency; MTTR; Regulatory compliance rate; Governance maturity score; Adaptive capacity index	Performance; Compliance; Organizational
[13]	Deruma (2025)	Cybersecurity management	Capability framework	Organizational / Governance	Asset management score; Incident response score; Access control score; Communication effectiveness; Decision-making quality	Technical; Organizational
[15]	Dong et al. (2025)	Cybersecurity / Economics	Quantification framework	Financial sector	Robustness; Redundancy; Resourcefulness; Rapidity; Time to recovery; Expected resilience utility score	Performance
[18]	Dupont (2019)	Cyber resilience governance	Conceptual / Theoretical framework	Financial sector	—	—
[20]	Eze and Hossain (2025)	Cybersecurity	Capability framework	Cross-sector / Multiple	MTTD; MTTR; False positive rate; Threat intelligence correlation rate; Incident escalation accuracy	Performance; Technical
[22]	Friedberg et al. (2016)	Critical infrastructure resilience	Quantification framework	Critical infrastructure	Resilience score; QoS; Control stability; Communication delay	Performance; Technical
[23]	Goel et al. (2023)	Information systems resilience	Capability framework	Cross-sector / Multiple	Response adequacy; Recovery speed; Adaptation capacity; Preparedness level; Disruption absorption capacity	Performance; Organizational

Ref	Author (Year)	Research Domain	Framework Type	Application Domain	Key Metrics	Metric Types
[24]	Han et al. (2020)	Supply chain resilience	Capability framework	Supply chain	Readiness (awareness, visibility, redundancy); Response (agility, collaboration, flexibility); Recovery (connectivity, market recovery, financial recovery)	Performance; Organizational
[25]	Hatton et al. (2018)	Critical infrastructure resilience	Capability framework	Critical infrastructure	Resilience attitudes; Situational awareness; Leadership & coordination; Adaptive capacity; Planning & preparedness; Recovery speed	Organizational; Performance
[26]	Hrosul et al. (2025)	Digital transformation resilience	Capability framework	Cross-sector / Multiple	Velocity (response/recovery speed); Fidelity (decision accuracy); Magnitude (scale of response)	Performance; Organizational
[27]	Jahajeeah-Suntoo and Armoogum (2026)	Cyber resilience governance	Conceptual / Theoretical framework	Cross-sector / Multiple	MTTD; MTTR; Resilience maturity progression score (all referenced from existing literature)	Performance; Organizational
[30]	Kaņepa et al. (2025)	IT governance and resilience	No framework proposed/Not applicable	Financial sector	—	—
[32]	Ko et al. (2025)	Cyber resilience governance	Capability framework	Maritime	Asset inventory; Risk assessment; Anomaly detection time; Compliance rate (response/recovery); Response exercise; Cybersecurity training	Organizational; Technical; Performance
[33]	Kononova et al. (2025)	Manufacturing resilience	Measurement taxonomy	Manufacturing	Flexibility; Adaptability; Redundancy; Robustness; Recovery time; Agility; Connectivity	Performance; Technical; Organizational
[35]	Kulugh et al. (2022)	Cyber resilience governance	Maturity model	Critical infrastructure	CNIIRI composite index; Governance maturity; Identify/Protect/Detect/Respond & Recover maturity scores	Organizational; Performance
[36]	Le Bray et al. (2016)	Cyber resilience governance / Cybersecurity management	Measurement taxonomy	Telecommunications	Regulatory adherence rate; Incident frequency & severity; Time to report; Detection coverage; Likelihood & impact indicators	Compliance; Performance; Technical
[38]	Linkov et al. (2013)	Cyber resilience governance / Cybersecurity management	Capability framework	Cross-sector / Multiple	Provider certifications; Asset categorization; Event logging; Time to recovery; Employee training; Management response review	Compliance; Performance; Technical; Organizational
[39]	Lubis et al. (2025)	Critical infrastructure resilience	Quantification framework	Critical infrastructure	Security evaluation score; Control adoption rate; Vulnerability exposure score; Composite cyber resilience rating	Technical; Performance
[40]	Marquez-Tejon et al. (2024)	Organizational resilience	Maturity model	Organizational / Governance	Maturity level (1–5); Policy integration; Risk assessment maturity; Incident management capability; BCM alignment	Organizational; Compliance
[41]	Mbanaso et al. (2019)	Cyber resilience governance	Maturity model	Organizational / Governance	Five-level maturity scale score; Readiness score per quadrant	Organizational

Ref	Author (Year)	Research Domain	Framework Type	Application Domain	Key Metrics	Metric Types
[42]	Miya and Joseph (2025)	Information systems resilience	Capability framework	Financial sector	—	—
[48]	Senyo et al. (2019)	Cyber resilience governance	No framework proposed/Not applicable	Cross-sector / Multiple	—	—
[53]	Yojana and Zagloel (2020)	Risk management and resilience	Quantification framework	Supply chain	Detection speed; Response speed; Recovery speed; Composite Resilience Score	Performance

Table A.3: Articles retained for Ddta extraction in the Systematic Literature Review

B

Explicit GQM Application

This appendix documents the complete application of the GQM approach, ensuring full traceability from DORA's ICT Risk Management requirements to the final metric catalog.

- **Section B.1 presents the requirement-to-goal translation**, in which every paragraph of Articles 5 through 16 was evaluated against the scoping criteria and, where in scope, translated into a goal – producing 40 goals across Articles 6 to 13. This section also includes **Subsection B.1.1, describing the thematic consolidation of overlapping goals**, reducing the 40 goals to 27 distinct and independently measurable dimensions.
- **Section B.2 presents the goal-to-question translation**, decomposing the 27 consolidated goals into 30 assessment questions.
- **Section B.3 presents the question-to-metric translation**. Notably, this section documents an explicit justification for scoping out 13 questions concerning governance and administrative processes, which could not be answered by operational resilience metrics. The remaining 17 questions, spanning 14 goals, were translated into quantitative metrics.
- Finally, **Section B.4 presents the resulting catalog: 14 goals, 17 questions, and 50 metrics**, each specified through a name, definition, formula, measurement type, and illustrative data sources.

The progression from 40 goals to 27 and ultimately 14 thus reflects two distinct filters: methodological consolidation to remove redundancy, and the

boundary between what can be measured quantitatively and what must be assessed qualitatively, identified during the expert validation of the framework (Chapter 5).

B.1 GQM Phase 1: Requirement-to-Goal

Below is the detailed evaluation of the requirements within DORA Chapter II: ICT Risk Management, and their translation into goals where applicable. Articles were scoped out according to the following exclusion criteria:

- Responsibility or accountability lies with organizational bodies and is not technically observable on ICT systems.
- The requirement addresses third-party ICT risks, which fall under DORA's dedicated third-party risk management pillar (Articles 28 to 44).

After exclusion, each remaining requirement was evaluated by the rules below to derive its corresponding goal(s). The translation logic results from adhering to the following three rules:

- Requirements that specify a desired system or process state (e.g., ensuring backup coverage) are translated into goals that express such a state as an observable condition.
- Requirements that specify a frequency or periodicity (e.g., regular testing) are translated into goals that include recency as a measurable dimension.
- Requirements that specify a threshold or standard (e.g., data integrity) are translated into goals that express the standard as a measurable property of the system.

This is the first translation step of the GQM approach, applied to each article as stated in Chapter 4. A table per article is therefore presented, where Source corresponds to the DORA article numbering, Requirement Summary to a brief description of the obligation stated by DORA, and Goal ID and Goal Statement to the goal identifier and declaration, respectively. In total, the requirement-to-goal translation produced 40 goals, derived from Articles 6 to 13; Articles 5, 14, 15, and 16 yielded no goals, as their requirements were scoped out in full – being organizational in nature, addressed to the ESAs rather than financial entities, or outside the financial DBE scope of this thesis.

Article 5 establishes the governance and organizational requirements for ICT risk management. All requirements from this article were scoped out as they are organizational in nature.

Article 6 defines the ICT risk management framework requirements, covering its structure, documentation, review cycles, audit processes, and the digital operational resilience strategy. Six in-scope goals were derived from the requirement-to-goal translation, shown in Table B.1.

Source	Requirement Summary	Goal ID	Goal Statement
6.1 6.2 6.3 6.4	*Financial entities shall have a sound, comprehensive and well-documented ICT risk management framework including strategies, policies, procedures to minimize the impact of ICT risks, and assign the responsibility to a control function.*	NA	Out of scope since these requirements are not technically observable but organizational.
6.5	*The ICT risk management framework shall be documented and reviewed at least once a year.*	G1	Assess the ICT risk management framework for ensuring currency and completeness with respect to review frequency and approval status.
6.6	*The ICT risk management framework of financial entities shall be subject to internal audit by auditors.*	NA	Out of scope since this requirement is not technically observable but organizational.
6.7	*Financial entities shall establish a formal follow-up process of critical ICT audit findings.*	G2	Assess the resolution of critical ICT audit findings for reducing risk exposure with respect to resolution timeliness.

Source	Requirement Summary	Goal ID	Goal Statement
6.8(a) 6.8(d) 6.8(h)	*Operational resilience strategy shall include methods that explain how the ICT risk management framework supports the financial entity's business, the ICT reference architecture and any change, and a communication strategy.*	NA	Out of scope since these requirements are not technically observable but organizational.
6.8(b)	*Financial entities shall establish the risk tolerance level for ICT risk.*	G3	Assess ICT risk and impact tolerance with respect to definition and documentation.
6.8(c)	*Security settings are clearly set out, including KPIs and key risks metrics.*	G4	Assess the ICT risk performance tracking process for enabling informed risk decisions with respect to KPI completeness, ownership, and active reporting.
6.8(e) 6.8(f)	*Outline mechanisms to detect incidents, prevent their impact, and protect from them, as well as reporting their effectiveness.*	G5	Assess that detection and prevention mechanisms are in place and effective.
6.8(g)	*Implement digital operational resilience testing.*	G6	Assess that digital operational resilience testing is implemented.

Source	Requirement Summary	Goal ID	Goal Statement
6.9	*Financial entities may define a holistic ICT multi-vendor strategy, at group or entity level, showing key dependencies on ICT third-party service providers.*	NA	Out of scope since this requirement is not technically observable but organizational, and overlaps with the third-party risk management pillar.
6.10	*Financial entities may outsource the tasks of verifying compliance with ICT risk management requirements.*	NA	Out of scope since this requirement is not technically observable but organizational, and overlaps with the third-party risk management pillar.

Table B.1: Requirement-to-Goal translation for Article 6 requirements

Article 7 specifies the requirements for ICT systems, protocols and tools, focusing on their reliability, capacity, and technological resilience under normal and stressed conditions. Three in-scope goals were derived from the requirement-to-goal translation, shown in Table B.2.

Source	Requirement Summary	Goal ID	Goal Statement
7(a)	*Financial entities shall use and maintain updated ICT systems, protocols and tools that are appropriate to the magnitude of operations supporting the conduct of their activities.*	NA	Out of scope since these requirements are not technically observable but organizational.
7(b)	*Financial entities shall use and maintain reliable ICT systems, protocols and tools.*	G7	Assess that ICT systems demonstrate adequate reliability.

Source	Requirement Summary	Goal ID	Goal Statement
7(c)	*Financial entities shall use ICT systems, protocols and tools equipped with sufficient capacity.*	G8	Assess that ICT systems maintain sufficient capacity under normal and peak conditions.
7(d)	*Financial entities shall use ICT systems, protocols and tools that are technologically resilient under stressed market conditions or other adverse situations.*	G9	Assess that ICT systems demonstrate resilience under stress or adverse conditions.

Table B.2: Requirement-to-Goal translation for Article 7 requirements

Article 8 establishes the identification requirements, covering asset inventory and classification, continuous risk source identification, third-party dependency mapping, and legacy system risk assessment. Four in-scope goals were derived from the requirement-to-goal translation, shown in Table B.3.

Source	Requirement Summary	Goal ID	Goal Statement
8.1 8.4 8.6	*Financial entities shall identify, classify and adequately document information assets and ICT assets, as well as maintain relevant inventories and update them periodically and upon any major change.*	G10	Assess that ICT and information assets are fully inventoried, classified, and kept up-to-date.
8.2	*Financial entities shall identify all sources of ICT risk.*	G11	Assess that ICT risk sources, threats and vulnerabilities are continuously identified and regularly reviewed.

Source	Requirement Summary	Goal ID	Goal Statement
8.3	*Financial entities shall perform a risk assessment upon each major change.*	NA	Out of scope since these requirements are not technically observable but organizational.
8.5	*Financial entities shall identify and document third-party ICT dependencies.*	G12	Assess that third-party dependencies are fully identified and documented.
8.7	*Financial entities shall conduct a specific ICT risk assessment on all legacy ICT systems.*	G13	Assess that legacy ICT systems are regularly assessed for ICT risks.

Table B.3: Requirement-to-Goal translation for Article 8 requirements

Article 9 covers protection and prevention requirements, addressing continuous monitoring, data security standards, network management, access control, authentication, and change and patch management. Eight in-scope goals were derived from the requirement-to-goal translation, shown in Table B.4.

Source	Requirement Summary	Goal ID	Goal Statement
9.1	*Financial entities shall continuously monitor and control the security and functioning of ICT systems and tools.*	G14	Assess that ICT systems and tools are continuously monitored for security and performance.

Source	Requirement Summary	Goal ID	Goal Statement
9.2 9.3(b) 9.3(c)	*Financial entities shall design, procure and implement ICT security policies, procedures, protocols and tools to prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data.*	G15	Assess that ICT systems, in particular the ones supporting critical functions, maintain high CIA standards.
9.3(a) 9.3(d)	*Financial entities must ensure data protection.*	G16	Assess that data is protected during transfer, storage and processing.
9.4(a)	*Financial entities shall develop and document an information security policy defining rules.*	NA	Out of scope since these requirements are not technically observable but organizational.
9.4(b)	*Financial entities must establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols following a risk-based approach.*	G17	Assess that network infrastructure is designed and managed to contain and prevent contagion.
9.4(c)	*Financial entities must limit the physical or logical access to information assets and ICT assets by addressing access rights.*	G18	Assess that access to ICT and information assets is controlled and limited to legitimate use.
9.4(d)	*Financial entities must implement policies and protocols for strong authentication mechanisms.*	G19	Assess that strong authentication and cryptographic mechanisms are implemented consistently.

Source	Requirement Summary	Goal ID	Goal Statement
9.4(e)	*Financial entities shall implement documented policies, procedures and controls for ICT change management.*	G20	Assess that ICT changes are managed through a controlled, risk-based process.
9.4(f)	*Financial entities shall have appropriate and comprehensive documented policies for patches and updates.*	G21	Assess that patches and updates are applied in a timely and comprehensive manner.

Table B.4: Requirement-to-Goal translation for Article 9 requirements

Article 10 defines the detection requirements, specifying mechanisms for identifying anomalous activities, alert threshold configuration, and continuous monitoring of user activity and ICT anomalies. Four in-scope goals were derived from the requirement-to-goal translation, shown in Table B.5.

Source	Requirement Summary	Goal ID	Goal Statement
10.1	*Financial entities shall have in place mechanisms to promptly detect anomalous activities and regularly test them.*	G22	Assess that detection mechanisms identify anomalous activities, performance issues and single points of failure promptly.
		G23	Assess that detection mechanisms are regularly tested for effectiveness.
10.2	*The detection mechanisms shall enable multiple layers of control, define alert thresholds and criteria to trigger and initiate ICT-related incident response processes.*	G24	Assess that alert thresholds are defined and automatic alerting is operational.

Source	Requirement Summary	Goal ID	Goal Statement
10.3	*Financial entities shall devote sufficient resources and capabilities to monitor user activity.*	G25	Assess that user activity and ICT anomalies are continuously monitored.
10.4	*Data reporting service providers shall, have in place systems that can effectively check trade reports.*	NA	Out of scope since these requirements are not technically observable but organizational and third-party related.

Table B.5: Requirement-to-Goal translation for Article 10 requirements

Article 11 addresses response and recovery requirements, covering business continuity policies, incident response procedures, continuity testing, business impact analysis, disruption records, and incident cost reporting. Six in-scope goals were derived from the requirement-to-goal translation, shown in Table B.6.

Source	Requirement Summary	Goal ID	Goal Statement
11.1	*Financial entities shall put in place a comprehensive ICT business continuity policy.*	NA	Out of scope since these requirements are not technically observable but organizational.
11.2(a) 11.2(b)	*Financial entities shall ensure the continuity of their critical or important functions, and quickly, appropriately and effectively respond to, and resolve, all ICT-related incidents.*	G26	Assess that critical and important functions are maintained or rapidly restored during ICT disruptions.

Source	Requirement Summary	Goal ID	Goal Statement
11.2(c) 11.2(d)	*Financial entities shall activate, without delay, dedicated plans that enable containment measures, and estimate preliminary impacts.*	G27	Assess that containment measures are activated promptly and damage is estimated upon ICT incidents.
11.2(e)	*Financial entities shall set out communication and crisis management actions.*	NA	Out of scope since these requirements are not technically observable but organizational.
11.3	*Financial entities shall implement associated ICT response and recovery plans and be subject to independent internal audit reviews.*	NA	Out of scope since this requirement is not technically observable but organizational.
11.4 11.6(a)	*Financial entities shall put in place, maintain and periodically test-appropriate ICT business continuity plans.*	G28	Assess that ICT business continuity and recovery plans are regularly and comprehensively tested.
11.5	*Financial entities shall conduct a business impact analysis (BIA) of their exposures to severe business disruptions.*	NA	Out of scope since conducting a BIA is an organizational assessment process; its measurable outputs (RTO/RPO targets, critical function identification) are captured under the goals derived from Articles 11.4, 11.6, and 12.6.

Source	Requirement Summary	Goal ID	Goal Statement
11.6(b)	*Financial entities shall test the crisis communication plans.*	NA	Out of scope since this requirement is not technically observable but organizational.
11.7	*Financial entities shall have a crisis management function.*	NA	Out of scope since these requirements are not technically observable but organizational.
11.8	*Financial entities shall keep readily accessible records of activities before and during disruption events.*	G29	Assess that records of disruption events and recovery activities are maintained.
11.9	*Central securities depositories shall provide the competent authorities with copies of the results of the ICT business continuity tests.*	NA	Out of scope since this requirement is not technically observable but organizational.
11.10	*Financial entities shall report an estimation of aggregated annual costs and losses caused by major ICT-related incidents.*	G30	Assess that aggregated costs and losses from major ICT incidents are tracked and reportable.
11.11	*The ESAs, through the Joint Committee, shall develop common guidelines on the estimation of aggregated annual costs and losses.*	NA	Out of scope since this requirement is not technically observable but organizational.

Table B.6: Requirement-to-Goal translation for Article 11 requirements

Article 12 specifies backup policies and restoration and recovery procedures, covering backup scope and frequency, system segregation, redundant capacity, and RTO/RPO definition. Five in-scope goals were derived from the requirement-to-goal translation, shown in Table B.7.

Source	Requirement Summary	Goal ID	Goal Statement
12.1 12.2	*Financial entities shall set up backup systems that can be activated and tested in accordance with the developed and documented backup policies and procedures.*	G31	Assess that backup coverage and frequency are defined and implemented according to data criticality.
12.3	*Financial entities shall use ICT systems that are physically and logically segregated from the source ICT system.*	G32	Assess that backup systems are physically and logically segregated, and securely protected.
12.4	*Financial entities shall maintain redundant ICT capacities equipped with resources, capabilities and functions that are adequate to ensure business needs.*	G33	Assess that redundant ICT capacities are maintained and adequate for business needs.
12.5	*Financial entities shall maintain at least one secondary processing site for central securities depositories.*	NA	Out of scope: this requirement applies only to central securities depositories, which fall outside the credit-institution scope of this thesis.
12.6	*Financial entities shall consider function criticality and potential overall impact to determine RTO and RPO.*	G34	Assess that RTO and RPO are defined per function and met in practice.

Source	Requirement Summary	Goal ID	Goal Statement
12.7	*Financial entities shall perform necessary checks in order to ensure that the highest level of data integrity is maintained.*	G35	Assess that data integrity is verified and maintained throughout the recovery process.

Table B.7: Requirement-to-Goal translation for Article 12 requirements

Article 13 establishes the learning and evolving requirements, addressing threat intelligence gathering, post-incident reviews, lessons learned integration, ICT risk trend monitoring, and technological development surveillance. Five in-scope goals were derived from the requirement-to-goal translation, shown in Table B.8.

Source	Requirement Summary	Goal ID	Goal Statement
13.1	*Financial entities shall have in place capabilities and staff to gather information on vulnerabilities and cyber threats, ICT-related incidents, in particular cyber-attacks, and analyze their impact.*	G36	Assess that threat intelligence and vulnerability information is continuously gathered and analyzed.
13.2	*Financial entities shall put in place post ICT-related incident reviews after a major ICT-related incident disrupts their core activities.*	G37	Assess that post-incident reviews are conducted after major ICT incidents and drive improvements.
13.3	*Financial entities shall incorporate lessons derived from the digital operational resilience tests into the ICT risk assessment process.*	G38	Assess that lessons learned from testing and incidents are incorporated into the ICT risk management framework.

Source	Requirement Summary	Goal ID	Goal Statement
13.4	*Financial entities shall monitor the effectiveness of the digital operational resilience strategy and map the evolution of risks over time.*	G39	Assess that ICT risk exposure and incident patterns are monitored and tracked over time.
13.5	*Senior ICT staff shall report at least yearly to the management body on the findings and recommendations of the operational resilience testing.*	NA	Out of scope since this requirement is not technically observable but organizational.
13.6	*Financial entities shall develop ICT security awareness programs and digital operational resilience training.*	NA	Out of scope since this requirement concerns staff training and awareness programs, which are organizational in nature and not technically observable on ICT systems.
13.7	*Financial entities shall monitor relevant technological developments to understand their possible impact on ICT security requirements and digital operational resilience*	G40	Assess the monitoring of technological developments for identifying emerging ICT security risks with respect to coverage and continuity.

Table B.8: Requirement-to-Goal translation for Article 13 requirements

Article 14 governs crisis communication plans and policies for internal staff and external stakeholders during ICT-related incidents. All requirements were scoped out as they are organizational in nature.

Article 15 mandates the ESAs to develop regulatory technical standards harmonizing ICT risk management tools, methods, and processes. All requirements were scoped out as they constitute an ESA regulatory obligation and do not mandate financial entities directly.

Article 16 defines a simplified ICT risk management framework applicable to small and non-interconnected financial entities exempt from Articles 5–15. All requirements were scoped out as outside the credit-institution and financial DBE scope of this thesis.

B.1.1 Goal refinement and consolidation

DORA's requirements structure reveals that several articles address the same underlying requirement from different regulatory angles, cross-referencing one another. Since the requirement-to-goal translation was performed per article, overlapping goals emerged from the first step of the GQM approach. The 40 goals derived across Articles 6 to 13 therefore went through a consolidation stage, in which it was decided whether to merge overlapping goals into a single consolidated goal, so as to avoid a redundant framework. Each resulting goal is mapped to all the requirements that served as sources of the overlapping goals it replaces.

The consolidation was derived inductively through pattern recognition: goals targeting the same or a similar ICT resilience capability (i.e., a theme) were grouped together. This approach has been used in a similar sense by other authors, such as AlHidaifi, Asghar, and Ansari [3] and Bodeau et al. [9]. The identified themes are:

- Detection and monitoring
- Operational resilience strategy testing
- Availability and continuity
- Capacity and redundancy
- Cyber threat and vulnerability intelligence
- ICT risk

By mapping goals to a theme based on the strongest match, the overlapping goals were identified, as shown in Table B.9. Note that the table lists only the 19 goals involved in overlaps; the remaining 21 goals were not

affected by consolidation. The 19 overlapping goals were merged into 6 consolidated goals, one per theme, reducing the total from 40 to 27 goals.

Theme	**Goals involved**
ICT risk	G3, G34
Detection and monitoring	G5, G14, G22, G25
Operational resilience strategy testing	G6, G9, G23, G27, G31
Availability and continuity	G7, G15, G26
Capacity and redundancy	G8, G28, G33
Cyber threat and vulnerability intelligence	G11, G36

Table B.9: Thematic consolidation of overlapping goals

The **ICT risk** theme was identified to be addressed by two goals (G3 and G34) that enforce the capability of documenting and tracking ICT risks and recovering tolerance levels. To avoid redundant indicators without measurement value, they consolidated into the new G3 under a new statement but traceable to both sources.

Source	Requirement Summary	Goal ID	Goal Statement
G3 G34	*Financial entities shall define and document their ICT risk and impact tolerance levels, including RTO and RPO per critical function, ensuring these are aligned with their risk appetite and regularly validated against crucial performance.*	G3	Assess the definition of ICT risk tolerance and recovery objectives for establishing operational boundaries.

Table B.10: Consolidated G3 from goals refinement

Regarding **Detection and Monitoring** theme, since all four goals (G5, G14, G22, and G25) are answerable by the same set of KPIs, retaining them as separate goals would produce redundant indicators without adding measurement value. Then, they are all consolidated into G5 under a new statement and is traceable to all four sources.

Regarding **Operational Resilience Strategy Testing** theme, since all five goals (G6, G9, G23, G27, and G31) address the same underlying capability, retaining them as separate goals would produce redundant indicators without adding measurement value. Then, they are all consolidated into G6 under a new statement and is traceable to all five sources.

Source	Requirement Summary	Goal ID	Goal Statement
G5 G14 G22 G25	*Financial entities shall continuously monitor ICT systems, user activity, and anomalous behavior as well as implementing and demonstrating the effectiveness of detection and prevention mechanisms covering incidents, performance issues and single points of failure.*	G5	Assess the monitoring of ICT systems and user activity for enabling timely threat detection.

Table B.11: Consolidated G5 from goals refinement

Source	Requirement Summary	Goal ID	Goal Statement
G6 G9 G23 G27 G31	*Financial entities shall periodically test ICT systems, business continuity plans, response and recovery plans, detection mechanisms and backup procedures to validate their effectiveness, including scenarios of cyber-attacks, switchover and failure of critical functions.*	G6	Assess the testing of business continuity, recovery, and backup plans for validating operational readiness.

Table B.12: Consolidated G6 from goals refinement

Regarding the **Availability and continuity** theme, that consolidates goals (G7, G15, and G26) addressing the ability of ICT systems and critical functions to remain available and operational under normal and adverse conditions, all three goals are consolidated into G7 with a new statement that is traceable to all three sources.

Regarding the **Capacity and Redundancy** theme, the three overlapping goals (G8, G28, G33) are consolidated into G8 under a new statement that is traceable to the three goals,

Finally, the **Cyber threat and vulnerability** theme encompasses two goals (G11 and G36) that address the same underlying capability and therefore consolidated in one goal about the continuous identification, gathering and analysis of cyber threats and vulnerabilities. The new statement of G11 is as follow and traceable to both sources.

Source	Requirement Summary	Goal ID	Goal Statement
G7 G15 G26	*Financial entities shall ensure that ICT systems supporting critical or important functions maintain high standards of availability, authenticity, integrity and confidentiality, and are capable of continuing or rapidly restoring operations under adverse or stressed conditions.*	G7	Assess ICT systems supporting critical/important functions for ensuring continuous operational trustworthiness with respect to availability, authenticity, integrity, and confidentiality.

Table B.13: Consolidated G7 from goals refinement

Source	Requirement Summary	Goal ID	Goal Statement
G8 G28 G33	*Financial entities shall ensure that ICT systems maintain sufficient capacity to process data accurately under normal and peak conditions, and shall maintain redundant ICT capacities and business continuity arrangements adequate to sustain critical operations.*	G8	Assess the redundant capacity of ICT infrastructure supporting critical/important functions for ensuring service continuity.

Table B.14: Consolidated G8 from goals refinement

Source	Requirement Summary	Goal ID	Goal Statement
G11 G36	*Financial entities shall continue identifying sources of ICT risk, assess cyber threats and vulnerabilities relevant to their ICT supported functions and assets, and gather and analyze threat intents to understand the likely impact on their digital operational resilience.*	G11	Assess the documentation of ICT third-party dependencies for enabling third-party risk management with respect to completeness and currency.

Table B.15: Consolidated G11 from goals refinement

The goals resulting from the first step, the Requirement-to-Goal translation, and the subsequent consolidation served as the starting point for

the Goal-to-Question translation. These 27 goals are listed in Table B.16, where the full goal definition template from Basili, Caldiera, and Rombach [5] was also applied.

Source Article	Goal ID	Goal Statement
6.5	G1	Assess the ICT risk management framework for ensuring currency and completeness with respect to review frequency and approval status, from the viewpoint of risk management, in the context of ICT risk governance.
6.7	G2	Assess the resolution of critical ICT audit findings for reducing risk exposure with respect to resolution timeliness, from the viewpoint of internal audit, in the context of ICT risk management.
6.8(b) 12.6	G3	Assess the definition of ICT risk tolerance and recovery objectives for establishing operational boundaries with respect to completeness and formal approval, from the viewpoint of senior management, in the context of ICT risk governance.
6.8(c)	G4	Assess the ICT risk performance tracking process for enabling informed risk decisions with respect to KPI completeness, ownership, and active reporting, from the viewpoint of risk management, in the context of ICT risk governance.
6.8(e) 6.8(f) 9.1 10.1 10.3	G5	Assess the monitoring of ICT systems and user activity for enabling timely threat detection with respect to coverage and continuity, from the viewpoint of Security Management, in the context of ICT threat detection operations.

Source	Goal ID	Goal Statement
6.8(g) 7(d) 10.1 11.2(c) 11.2(d) 12.1 12.2	G6	Assess the testing of business continuity, recovery, and backup plans for validating operational readiness with respect to test frequency, success rate, and scenario coverage, from the viewpoint of ICT operations, in the context of resilience preparedness.
7(b) 9.2 9.3(b) 9.3 (c) 11.2(a) 11.2(b)	G7	Assess ICT systems supporting critical/important functions for ensuring continuous operational trustworthiness with respect to availability, authenticity, integrity, and confidentiality, from the viewpoint of Security Management, in the context of ongoing ICT operations.
7(c) 11.4 11.6(a) 12.4	G8	Assess the redundant capacity of ICT infrastructure supporting critical/important functions for ensuring service continuity with respect to activation speed and sufficiency within defined RTO/RPO targets, from the viewpoint of ICT operations, in the context of disruption scenarios.
8.1 8.4 8.6	G9	Assess the ICT asset inventory for maintaining complete situational awareness with respect to completeness and currency, from the viewpoint of ICT operations, in the context of asset life-cycle management.
8.2 13.1	G10	Assess the threat and vulnerability analysis process for enabling timely risk reduction with respect to coverage and remediation speed, from the viewpoint of Security Management, in the context of continuous vulnerability management.

Source	Goal ID	Goal Statement
8.5	G11	Assess the documentation of ICT third-party dependencies for enabling third-party risk management with respect to completeness and currency, from the viewpoint of risk management, in the context of third-party risk governance.
8.7	G12	Assess legacy ICT systems (without active vendor security support) for managing residual risk with respect to assessment regularity and remediation effectiveness, from the viewpoint of ICT operations, in the context of system lifecycle management.
9.3(a) 9.3(d)	G13	Assess the protection of data across all operational states for maintaining confidentiality, integrity, authenticity, and availability with respect to completeness of technical protection mechanisms, from the viewpoint of Security Management, in the context of data security operations.
9.4(b)	G14	Assess the network architecture for limiting the propagation of ICT disruptions with respect to segmentation effectiveness and containment speed, from the viewpoint of ICT operations, in the context of incident response.
9.4(c)	G15	Assess access control mechanisms across ICT systems for limiting exposure to unauthorized use with respect to enforcement effectiveness and audit completeness, from the viewpoint of Security Management, in the context of identity and access management.

Source	Goal ID	Goal Statement
9.4(d)	G16	Assess the implementation of strong authentication mechanisms for reducing identity-based attack exposure with respect to coverage and consistency across privileged and remote access, from the viewpoint of Security Management, in the context of identity and access management.
9.4(e)	G17	Assess the change management process for preventing uncontrolled ICT changes with respect to risk based application and consistency, from the viewpoint of ICT operations, in the context of ICT system governance.
9.4(f)	G18	Assess the patch and update management process for reducing vulnerability exposure with respect to timeliness relative to criticality-based policy thresholds, from the viewpoint of ICT operations, in the context of vulnerability management.
10.2	G19	Assess the alert threshold and automatic alerting mechanisms for enabling timely incident response with respect to operational coverage and alerting reliability, from the viewpoint of Security Management, in the context of ICT threat detection.
11.8	G20	Assess the recording of ICT disruption and recovery events for enabling post-incident analysis with respect to completeness and accuracy, from the viewpoint of Audit and Compliance, in the context of incident management.
11.10	G21	Assess the tracking and reporting of costs and losses from major ICT incidents for quantifying operational impact with respect to completeness and regularity, from the viewpoint of senior management, in the context of ICT incident impact assessment.

Source	Goal ID	Goal Statement
12.3	G22	Assess the segregation and protection of backup systems for ensuring reliable recovery capability with respect to operational integrity and access security, from the viewpoint of Security Management, in the context of backup and recovery management.
12.7	G23	Assess the data integrity verification process during recovery operations for ensuring trustworthiness of recovered data with respect to coverage, speed, and detection effectiveness, from the viewpoint of ICT operations, in the context of ICT recovery management.
13.2	G24	Assess the post-incident review process for enabling organizational learning with respect to execution completeness and timeliness, from the viewpoint of Incident Management, in the context of continuous improvement.
13.3	G25	Assess the integration of post-incident lessons learned for improving ICT resilience practices with respect to completeness and timeliness of reflection in the framework, from the viewpoint of risk management, in the context of continuous improvement.
13.4	G26	Assess the monitoring and reporting of ICT risk exposure and incident patterns for informing risk decisions with respect to completeness and regularity of reporting, from the viewpoint of Senior Management and Security Management, in the context of ICT risk monitoring.
13.7	G27	Assess the monitoring of technology developments for identifying and acting on emerging security risks with respect to coverage and integration of findings, from the viewpoint of Security Management, in the context of emerging technology risk management.

Source	Goal ID	Goal Statement

Table B.16: GQM Step 1: Requirement-to-Goal translation

Each goal represents a distinct and independently measurable dimension of ICT resilience under DORA's ICT Risk Management pillar. The consolidation reduced the initial 40 goals derived from the per-article GQM translation to 27 by merging overlapping goals by theme, ensuring that the consolidated goals retain full traceability to their source DORA articles and that no requirement within scope is left without a corresponding measurement objective.

B.2 GQM Phase 2: Goal-to-Question

The second translation step breaks each consolidated goal down into a set of questions that collectively determine whether the goal is being met. As described in Chapter 4, two types of questions were formulated: state questions, asking whether a condition exists or a property is in place, and performance questions, asking how well a condition is maintained or how efficiently a process operates. The full goal-to-question derivation produced a total of 30 questions across the 27 consolidated goals, as shown in Table B.17. Most goals were decomposed into a single question capturing their measurable dimension, while three goals (G6, G19, and G22) required two questions each to cover distinct aspects of the underlying capability.

Goal ID	**Q ID**	**Question**
G1	Q1	Is the ICT risk management framework sufficiently current and complete to guide operational decisions?
G2	Q2	How quickly are critical ICT audit findings resolved after identification?
G3	Q3	Are ICT risk tolerance thresholds and recovery objectives sufficiently defined and approved to guide operational decisions?
G4	Q4	Are ICT risk KPIs comprehensively defined, actively owned, and regularly reported?

Goal ID	Q ID	Question
G5	Q5	How completely and continuously are ICT systems and user activities covered by operational detection mechanisms?
G6	Q6.1	How frequently and successfully are recovery and backup plans tested against defined RTO/RPO targets?
	Q6.2	How representative are the test scenarios of real-world adverse conditions?
G7	Q7	To what extent do ICT systems supporting critical/important functions maintain required operational properties under normal and adverse conditions?
G8	Q8	Can redundant capacity sustain all critical/important functions within defined RTO and RPO targets when primary systems are unavailable?
G9	Q9	How complete and current is the ICT asset inventory across all material changes?
G10	Q10	How completely and promptly are threats and vulnerabilities identified and addressed across ICT systems supporting critical functions?
G11	Q11	How completely and accurately are ICT third-party dependencies documented?
G12	Q12	How effectively are risks from legacy systems identified and mitigated over time?
G13	Q13	To what extent is data technically protected across all operational states?
G14	Q14	How effectively and quickly does the network architecture contain ICT disruptions within the initially affected segment?
G15	Q15	How effectively are access controls enforced and how completely are access events audited across systems?

Goal ID	Q ID	Question
G16	Q16	How completely and consistently are strong authentication mechanisms applied to privileged and remote access?
G17	Q17	How consistently is the risk-based change management process applied to all ICT changes?
G18	Q18	How timely is the application of patches and updates relative to criticality-based policy thresholds?
G19	Q19.1	How reliably do automatic alerting mechanisms trigger upon threshold breaches?
	Q19.2	How quickly do alerting mechanisms generate alerts upon threshold breaches?
G20	Q20	How completely and accurately are ICT disruption and recovery events recorded?
G21	Q21	How completely and consistently are the financial impacts of major ICT incidents captured and reported?
G22	Q22.1	How effectively are backup systems protected from compromise?
	Q22.2	How reliably can they support recovery within defined targets?
G23	Q23	How completely, quickly, and effectively is data integrity verified across assets subject to recovery operations?
G24	Q24	How consistently and thoroughly are post-incident reviews conducted following major ICT incidents?
G25	Q25	How effectively and completely are post-incident lessons learned translated into ICT framework improvements?
G26	Q26	How comprehensively and regularly are ICT risk exposure levels and incident patterns monitored and communicated to relevant stakeholders?

Goal ID	Q ID	Question
G27	Q27	How effectively are technology developments monitored and their security implications integrated into the ICT risk management framework?

Table B.17: GQM Step 2: Goal-to-Question translation

The goal-to-question translation produced at least 1 question per goal, which are the guide to the next and last step: identifying the metrics.

B.3 GQM Phase 3: Question-to-Metric

The third and final translation step converts each question into one or more metrics. As established in Chapter 4 and confirmed through the framework's revision during expert validation, every metric in the final framework is quantitative: each captures a degree, rate, count, or duration that answers its associated question. During the validation, it was identified that not all questions could be answered with a resilience metric; those questions were therefore scoped out, so that the definitive list of metrics serves as a guide for measuring resilience according to DORA requirements. Of the 30 questions derived in Phase 2, 13 – concerning governance and administrative processes such as framework documentation, audit finding resolution, and asset inventory maintenance – yielded no resilience metric; an explicit justification is recorded for each. The remaining 17 questions, spanning 14 goals, were translated into a total of 50 quantitative metrics. Table B.18 presents the resilience metrics associated with each question, as well as indicating the questions that cannot be answered through resilience metrics. For the latter, other types of metrics may be applicable; these, however, are not within the scope of this work.

Each metric is defined with the attributes proposed in Chapter 4: Name, Definition, Formula, and Measurement Type, in addition to its associated Question ID. Examples of data sources are added for illustration purposes only. Frequency and threshold/benchmark values remain outside the scope of this thesis, for the reasons given in Chapter 4: defining them requires empirical calibration against institution-specific risk tolerance and data not available within this study.

Q ID	Question	Metric
Q1	Is the ICT risk management framework sufficiently current and complete to guide operational decisions?	No resilience metric: framework review and approval are governance activities and don't measure operational behavior.
Q2	How quickly are critical ICT audit findings resolved after identification?	No resilience metric: audit finding resolution is an administrative governance process and does not measure operational behavior.
Q3	Are ICT risk tolerance thresholds and recovery objectives sufficiently defined and approved to guide operational decisions?	No resilience metric: documentation and approval of RTO and RPO are governance activities and even though RTO and RPO serve as input to resilience measurements elsewhere, defining them is not an operational measure.
Q4	Are ICT risk KPIs comprehensively defined, actively owned, and regularly reported?	No resilience metric: defining and reporting KPIs is a governance meta-process. Whether KPIs exist and are reported does not measure operational behavior.
Q5	How completely and continuously are ICT systems and user activities covered by operational detection mechanisms?	% of ICT systems covered by operational detection mechanisms
		Mean Time to Detect (MTTD) ICT-related incidents, anomalous activity or security events
		% of false alerts out of the total # of alerts
		% of successful detection tests out of the total simulated attack scenarios

Q ID	Question	Metric
Q6.1	How frequently and successfully are recovery and backup plans tested against defined RTO/RPO targets?	% of recovery and backup plans that meet defined RTO/RPO targets during tests
		Average gap between tested recovery time and defined RTO, across systems supporting critical functions
Q6.2	How representative are the test scenarios of real-world adverse conditions?	% of defined minimum adverse scenarios covered in tests per testing cycle
Q7	To what extent do ICT systems supporting critical/important functions maintain required operational properties under normal and adverse conditions?	% uptime of ICT systems supporting critical functions per measurement period (availability)
		Number of confirmed integrity violations detected in systems supporting critical functions per measurement period
		Number of confirmed confidentiality breaches in systems supporting critical functions per measurement period
		% of signed assets out of the total deployable assets
Q8	Can redundant capacity sustain all critical/important functions within defined RTO and RPO targets when primary systems are unavailable?	Failover time (time to activate redundant capacity) per critical function
		% of critical functions whose redundant capacity sustains full operational load during failover tests
		% of failover tests completed within defined RTO targets

Q ID	Question	Metric
Q9	How complete and current is the ICT asset inventory across all material changes?	No resilience metric: asset inventory is an administrative process and does not measure operational behavior
Q10	How completely and promptly are threats and vulnerabilities identified and addressed across ICT systems supporting critical functions?	% of ICT systems scanned within the defined scanning frequency
		Mean time from vulnerability identification to remediation
		% of ICT systems with no unaddressed critical severity vulnerabilities at a given point in time
		Number of open critical/high critical vulnerabilities
		% of recurrent vulnerabilities out of the total remediated vulnerabilities
Q11	How completely and accurately are ICT third-party dependencies documented?	No resilience metric: documentation of third party dependencies is an administrative activity and does not measure operational behavior
Q12	How effectively are risks from legacy systems identified and mitigated over time?	% of legacy ICT systems with at least one unmitigated critical or high severity finding at a given point in time
		Average time between legacy system risk identification and initiation of remediation action
		% of systems with verified ICT support status out of the total production systems
Q13	To what extent is data technically protected across all operational states?	% of data in transit protected by defined encryption mechanisms

Q ID	Question	Metric
		% of data at rest protected by defined encryption mechanisms
		Number of confirmed data integrity or confidentiality violations per measurement period
		% of critical data stores with integrity validation out of the total # of critical data stores
Q14	How effectively and quickly does the network architecture contain ICT disruptions within the initially affected segment?	Time to isolate a compromised network segment from systems supporting critical functions
		% of ICT disruptions contained within the initially affected network segment (i.e., did not propagate)
		% of disruptions that reached systems supporting critical functions from an initially non-critical segment
		% of segmentation validation tests out of total # of segmentation tests
Q15	How effectively are access controls enforced and how completely are access events audited across systems?	% of unauthorized access attempts to systems that are detected and blocked
		Average time to revoke access rights following a detected compromise or user departure
		% of access events (categories?) to systems that are fully logged and auditable
		% of accounts reviewed within required period out of the total # of privileged accounts

Q ID	Question	Metric
Q16	How completely and consistently are strong authentication mechanisms applied to privileged and remote access?	% of privileged accounts with strong authentication enforced
		% of authentication-related security events (e.g., bypass attempts, credential compromise) detected per measurement period
		% of remote access accounts protected by MFA out of the total # of remote access accounts
Q17	How consistently is the risk-based change management process applied to all ICT changes?	No resilience metric: change management process is a governance/administrative activity and does not measure operational behavior.
Q18	How timely is the application of patches and updates relative to criticality-based policy thresholds?	Average time from patch release to patch installation
		% of systems with patches applied within policy-defined time frames
Q19	Q19.1: How reliably do automatic alerting mechanisms trigger upon threshold breaches? Q19.2: How quickly do alerting mechanisms generate alerts upon threshold breaches?	% of defined alert thresholds for which automatic alerting is verified as operational
		Mean time between a threshold breach and alert generation (alert latency)
		% of threshold breaches that successfully triggered an automatic alert (alert activation rate)
		% of false alerts out of the total # of alerts

Q ID	Question	Metric
Q20	How completely and accurately are ICT disruption and recovery events recorded?	No resilience metric: record maintenance is an administrative activity for documentation and does not measure operational behavior.
Q21	How completely and consistently are the financial impacts of major ICT incidents captured and reported?	No resilience metric: cost/loss tracking is a financial reporting activity and does not measure operational behavior.
Q22	Q22.1: How effectively are backup systems protected from compromise? Q22.2: How reliably can they support recovery within defined targets?	% of backup restoration tests completed successfully (data restored completely and within RTO)
		Average time to restore from backup for systems supporting critical/important functions
		% of unauthorized access attempts to backup systems that were detected and blocked
Q23	How completely, quickly, and effectively is data integrity verified across assets subject to recovery operations?	Average time to complete integrity validation after recovery initiation
		Number of integrity verification methods applied per recovery operation
		% of recovered assets subjected to integrity validation out of the total # of recovered assets
		% of recovery operations passing integrity verification out of the total # of recovery operations
Q24	How consistently and thoroughly are post-incident reviews conducted following major ICT incidents?	No resilience metric: post incident review is an organizational activity and does not measure operational behavior

Q ID	Question	Metric
Q25	How effectively and completely are post-incident lessons learned translated into ICT framework improvements?	No resilience metric: lessons learned integration is an organizational activity and does not measure operational behavior
Q26	How comprehensively and regularly are ICT risk exposure levels and incident patterns monitored and communicated to relevant stakeholders?	No resilience metric: monitoring and reporting are analytical and reporting activities and don't measure operational behavior. Although the monitoring data is used for measurement.
Q27	How effectively are technology developments monitored and their security implications integrated into the ICT risk management framework?	No resilience metric: cost/loss tracking is a financial reporting activity and does not measure operational behavior.

Table B.18: GQM Step 3: Question-to-Metric translation

B.4 Metric structure

As stated in Chapter 4, Section 4.3, each metric is defined with a set of attributes that constitute its structure and serve as a guide for users selecting and implementing the framework. Table B.19 presents the full metric catalog: 14 goals, 17 questions, and 50 metrics, each specified through its name, definition, formula, measurement type, and illustrative data sources.

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G5	ICT systems covered by operational detection mechanisms	% of ICT systems covered by operational detection mechanisms	(ICT Systems Covered by Detection Mechanisms / Total ICT Systems) $\times$ 100	Percentage (%)	Security monitoring tools, risk registries
G5	Mean Time to Detect (MTTD)	Mean Time to Detect (MTTD) ICT-related incidents, anomalous activity or security events	Σ Detection Times / Number of Detected Events	Time	Security monitoring tools, incident reports
G5	False Alert Rate	% of false alerts out of the total # of alerts	(False Alerts / Total Alerts) $\times$ 100	Percentage (%)	Security monitoring tools, incident management systems
G5	Detection Test Success Rate	% of successful detection tests out of the total simulated attack scenarios	(Successful Detection Tests / Total Simulated Attack Scenarios) $\times$ 100	Percentage (%)	Penetration records, penetration tests

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G6	Recovery & backup plans meeting RTO/RPO targets	% of recovery and backup plans that meet defined RTO/RPO targets during tests	(Plans Meeting RTO/RPO During Tests / Total Plans Tested) $\times$ 100	Percentage (%)	Disaster recovery testing records
G6	Average Recovery Time Gap vs RTO	Average gap between tested recovery time and defined RTO, across systems supporting critical/important functions	Σ(Tested Recovery Time $-$ Defined RTO) / Number of Tests	Count	Disaster recovery testing records
G6	Adverse Scenario Coverage	% of defined minimum adverse scenarios covered in tests per testing cycle	(Adverse Scenarios Tested / Defined Minimum Adverse Scenarios) $\times$ 100	Percentage (%)	Disaster recovery testing records, recovery procedures
G7	System Availability (Uptime)	Percentage of time ICT systems supporting critical or important functions are operational and available.	(Total Time $-$ Downtime) / Total Time $\times$ 100	Percentage (%)	Monitoring tools, availability monitoring platforms, service management systems

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G7	Confirmed Integrity Violations	Number of confirmed incidents affecting the integrity of systems or data.	Count per Measurement Period	Count	Incident management systems, security monitoring tools
G7	Confirmed Confidentiality Breaches	Number of confirmed incidents affecting confidentiality of information assets.	Count per Measurement Period	Count	Incident records, DLP tools, security event management systems
G7	Cryptographic Signing Coverage	Percentage of deployable assets protected by cryptographic signing mechanisms.	(Signed Assets / Total Deployable Assets) $\times$ 100	Percentage (%)	CI/CD platforms, software asset repositories
G8	Failover Time	Average time required to activate redundant capacity following disruption of primary systems.	Σ Failover Activation Times / Number of Failover Tests	Time	Disaster recovery tests, failover exercise reports

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G8	Operational Load Sustainability During Failover	Percentage of tested functions whose redundant capacity sustains full operational load.	(Functions Sustaining Full Load / Functions Tested) $\times$ 100	Percentage (%)	Failover test reports, capacity testing records
G8	Failover RTO Compliance	Percentage of failover tests completed within defined RTO targets.	(Failover Tests Meeting RTO / Total Failover Tests) $\times$ 100	Percentage (%)	Disaster recovery testing records
G10	Vulnerability Scan Coverage	Percentage of ICT systems scanned within the required scanning frequency.	(Systems Scanned Within Required Frequency / Total Systems) $\times$ 100	Percentage (%)	Vulnerability scanners, asset inventory
G10	Mean Time to Remediate Vulnerabilities	Average time from vulnerability identification to remediation.	Σ Remediation Times / Number of Vulnerabilities Remediated	Time	Vulnerability management platform, ticketing systems
G10	ICT Systems Without Critical Vulnerabilities	Percentage of ICT systems without open critical vulnerabilities.	(Systems With No Open Critical Vulnerabilities / Total Systems) $\times$ 100	Percentage (%)	Vulnerability management tools

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G10	Critical Vulnerability Backlog	Number of open critical or high-severity vulnerabilities.	Count of Open Critical/High Vulnerabilities	Count	Vulnerability management tools
G10	Vulnerability Recurrence Rate	Percentage of remediated vulnerabilities that subsequently reoccur.	(Recurrent Vulnerabilities / Total Remediated Vulnerabilities) $\times$ 100	Percentage (%)	Vulnerability management systems
G12	Legacy ICT Systems with Unmitigated Critical Findings	Percentage of legacy ICT systems with open critical or high-risk findings.	(Legacy Systems with Open Critical Findings / Total Legacy Systems) $\times$ 100	Percentage (%)	Risk registers, vulnerability management systems
G12	Time to Initiate Remediation	Average time between risk identification and initiation of remediation.	Σ(Time from Identification to Remediation Start) / Number of Findings	Time	Risk management tools, ticketing systems
G12	Vendor Support Verification Rate	Percentage of production systems with verified ICT support status.	(Systems With Verified Support Status / Total Production Systems) $\times$ 100	Percentage (%)	CMDB, asset inventory, vendor management records

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G13	Encryption Coverage (Data in Transit)	Percentage of sensitive data flows protected by approved encryption mechanisms.	(Protected Data Flows / Total Sensitive Data Flows) $\times$ 100	Percentage (%)	Network monitoring tools, architecture repositories
G13	Encryption Coverage (Data at Rest)	Percentage of sensitive data repositories protected by approved encryption mechanisms.	(Encrypted Data Repositories / Total Sensitive Data Repositories) $\times$ 100	Percentage (%)	Storage management tools, database inventories
G13	Confirmed Integrity or Confidentiality Violations	Number of confirmed incidents affecting data integrity or confidentiality.	Count per Measurement Period	Count	Incident management systems, DLP tools
G13	Integrity Protection Coverage	Percentage of critical data stores protected by integrity validation mechanisms.	(Critical Data Stores with Integrity Validation / Total Critical Data Stores) $\times$ 100	Percentage (%)	Data management tools, security architecture repositories

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G14	Time to Isolate Compromised Segment	Average time required to isolate a compromised network segment.	Σ Isolation Times / Number of Isolation Events	Time	Incident response records, network management tools
G14	Disruptions Contained Within Initial Segment	Percentage of ICT disruptions contained within the initially affected network segment.	(Contained Disruptions / Total Disruptions) $\times$ 100	Percentage (%)	Incident reports, network monitoring systems
G14	Disruptions Reaching Critical/Important Systems	Percentage of disruptions that propagated to systems supporting critical or important functions.	(Disruptions Reaching Critical Systems / Total Disruptions) $\times$ 100	Percentage (%)	Incident records, network monitoring systems
G14	Segmentation Validation Success Rate	Percentage of segmentation tests demonstrating effective network isolation.	(Successful Segmentation Tests / Total Segmentation Tests) $\times$ 100	Percentage (%)	Penetration tests, network validation exercises

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G15	Unauthorized Access Attempts Detected & Blocked	Percentage of unauthorized access attempts successfully detected and blocked.	(Unauthorized Attempts Blocked / Total Unauthorized Attempts Detected) $\times$ 100	Percentage (%)	IAM tools, SIEM/XDR platforms
G15	Access Revocation Time	Average time required to revoke access rights after compromise detection or user departure.	Σ Revocation Times / Number of Revocations	Time	IAM systems, HR systems, ticketing tools
G15	Auditable Access Events	Percentage of access events that are fully logged and auditable.	(Fully Logged Access Events / Total Access Events) $\times$ 100	Percentage (%)	Log management systems, SIEM platforms
G15	Privileged Access Review Compliance	Percentage of privileged accounts reviewed within the required review cycle.	(Privileged Accounts Reviewed / Total Privileged Accounts) $\times$ 100	Percentage (%)	PAM tools, IAM systems

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G16	Privileged Accounts with Strong Authentication	Percentage of privileged accounts protected by strong authentication mechanisms.	(Privileged Accounts with Strong Authentication / Total Privileged Accounts) $\times$ 100	Percentage (%)	IAM systems, authentication platforms
G16	Authentication-Related Security Events Detected	Number of detected authentication-related security events.	Count per Measurement Period	Count	SIEM/XDR tools, authentication platforms
G16	MFA Coverage for Remote Access	Percentage of remote access accounts protected by multi-factor authentication.	(Remote Access Accounts Protected by MFA / Total Remote Access Accounts) $\times$ 100	Percentage (%)	Remote access platforms, IAM systems
G18	Patch Deployment Time	Average time from patch release to installation.	Σ(Patch Installation Date $-$ Patch Release Date) / Number of Patches	Time	Patch management systems

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G18	Patch Compliance Rate	Percentage of systems patched within policy-defined timeframes.	(Systems Patched Within Policy Timeframe / Total Systems Requiring Patches) $\times$ 100	Percentage (%)	Patch management systems, asset inventory
G19	Operational Alert Threshold Coverage	Percentage of defined alert thresholds with verified automatic alerting functionality.	(Operational Alert Thresholds / Total Defined Alert Thresholds) $\times$ 100	Percentage (%)	Monitoring systems, SIEM/XDR platforms
G19	Alert Latency	Average time between threshold breach and alert generation.	Σ(Alert Generation Time $-$ Threshold Breach Time) / Number of Alerts	Time	Monitoring platforms, SIEM/XDR systems
G19	Alert Activation Rate	Percentage of threshold breaches that triggered an automatic alert.	(Threshold Breaches Triggering Alerts / Total Threshold Breaches) $\times$ 100	Percentage (%)	Monitoring tools, SIEM/XDR systems
G19	False Alert Rate	Percentage of alerts determined to be false positives.	(False Alerts / Total Alerts) $\times$ 100	Percentage (%)	SIEM/XDR systems, SOC records

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G22	Backup Restoration Success Rate	Percentage of backup restoration tests completed successfully within defined recovery objectives.	(Successful Backup Restorations / Total Backup Restoration Tests) $\times$ 100	Percentage (%)	Backup platforms, recovery test reports
G22	Backup Restore Time	Average time required to restore systems or data from backup.	Σ Restore Times / Number of Restore Operations	Time	Backup management systems
G22	Unauthorized Access Attempts Blocked (Backup Systems)	Percentage of unauthorized access attempts to backup systems that were detected and blocked.	(Blocked Unauthorized Attempts / Total Unauthorized Attempts) $\times$ 100	Percentage (%)	Backup security logs, SIEM/XDR platforms
G23	Integrity Validation Time	Average time required to complete integrity verification following recovery initiation.	Σ Validation Times / Number of Recovery Operations	Time	Recovery operation records

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G23	Integrity Verification Methods Applied	Average number of integrity verification methods applied per recovery operation.	Σ Verification Methods / Number of Recovery Operations	Number	Recovery procedures, test reports
G23	Integrity Verification Coverage	Percentage of recovered assets subjected to integrity validation.	(Recovered Assets Validated / Total Recovered Assets) $\times$ 100	Percentage (%)	Recovery records, validation logs
G23	Integrity Verification Success Rate	Percentage of recovery operations that successfully passed integrity verification.	(Recovery Operations Passing Integrity Verification / Total Recovery Operations) $\times$ 100	Percentage (%)	Recovery reports, validation records

Table B.19: Full metric catalog and specs

C

Consent Form

Master´s Programme in Open eGovernment, 2026 Spring Semester

We hope you are willing to take part in a study in the field of resilience in business ecosystems, specifically the digital resilience of financial institutions and their compliance with the EU DORA regulation. The study aims to develop and validate a framework for measuring the resilience of ICT risk management in financial institutions. The goal is to fill the gap between the abundance of available resilience metrics and the specific requirements of DORA for ICT management, enabling more effective tracking, reporting, and compliance.

To validate the developed framework and KPIs, we need to conduct a sufficient number of expert interviews with professionals who can provide feedback based on their work in the field. This stage of research and data collection is expected to take place during May 2026.

The study forms part of the compulsory program curriculum and is supervised by one of the assigned supervisors from the Department of Computer and Systems Sciences, who will ensure that students adhere to all necessary rules. The resulting thesis will be assessed and graded by an examiner at the end of the course.

Participation in the research is voluntary, and we ask for your approval to use the data collected for the study. During the course of the students' work on the study, your personal data will be protected and will not be disclosed to unauthorized persons. We will store recordings of the interviews and other information about the interviewee(s) in a secure manner.

Any photographic, video, or sound material collected will be anonymized, coded, and transcribed as text.

This will be done immediately upon collection in order to eliminate any potential for detecting that you have participated. The consent forms will be kept within the Stockholm University domain cloud but separately from the recordings so that they cannot be linked. When the study is completed and the thesis has passed assessment, we will destroy all original collected data (e.g., video/sound, written notes taken during the interview, written responses or documents provided by the interviewee(s)).

The results of the study will be published in the thesis in a manner that will not reveal your identity. The study adheres to guidelines on research ethics and common laws.

To collect data, we need your signed consent on the second page of this form. Even if you sign the form, you may still withdraw from participation at any time without giving a reason.

Please check the box below:

❏ I agree to be interviewed. I understand that my personal information and information about my organization will not be published.

Date: Click or tap to enter a date.

Signature of Interviewee: Click or tap here to enter text.

Please contact us if you need further information.

Students:

1. Maria Aguilar, maag7600@student.se.se;
2. Monika Didziulyte, modi8933@student.su.se.

Supervisor: Simon Hacks (Senior Lecturer, Associate Professor), simon.hacks@dsv.su.se.

Further Information Regarding Guidelines and Legislation Related to the Study

The personal data essential for carrying out the study are regulated according to the requirement of consent (*samtyckeskravet*) in Swedish legislation, specifically the Personal Data Act (in Swedish: *Dataskyddsförordningen*). Stockholm University is responsible for the processing of personal data.

Under the Swedish Personal Data Act (*Dataskyddsförordningen*, effective as of May 25, 2018), you are entitled to free access to all information involving you and, if needed, to have incorrect information amended. You also have the right to request deletion, restriction, or object to the use of your personal data. You have the opportunity to lodge a complaint with the data security officer at Stockholm University (dpo@su.se) or with the Swedish Data Protection Authority (https://datainspektionen.se/kontakta-ossa/).

Please contact the supervisor or students for further information.

D

Complementary Interview Materials

Introduction

Thank you for participating in this study. Your expertise in the financial sector is invaluable to us.

The purpose of this document is to:

- Explain how we developed our proposed cyber resilience metrics for measuring ICT risk management under the EU DORA regulation (Chapter II: ICT Risk Management);
- Present the full list of cyber resilience metrics for your validation;
- Gather your expert feedback on whether these metrics are relevant and practical.

Please read the sections below. After reviewing the metrics, you will be asked to complete the Metrics Validation Sheet and the Overall Questions at the end. The entire validation should take approximately 15–20 minutes.

Approach to the framework development and metric design

To develop the metrics framework, the study team used the GQM (Goal-Question-Metric) approach proposed by Basili et al. (1994). The approach starts with goals, then questions, then metrics. This allows us to trace every

metric back to the regulatory requirement and ensure that each metric is purposeful. In our case, we made sure that every metric corresponds to a specific statement or requirement of the DORA regulation, Chapter II: ICT Risk Management.

Below is an example illustrating our process of deriving **measurable quantitative metrics** from relevant DORA requirements, specifically Article 6(8)(e) and (f), Article 9(1), and Article 10(1) and (3).

1. **Metric design**
   The process follows three steps:

   - Requirement - to - Goal translation
   - Goal-to-Question translation
   - Question-to-Metric translation

2. **Metric structure**
   Following the structure proposed by Ko et al. (2025) and Bodeau et al. (2018), each metric includes the following attributes: name, definition, measurement type, and data source.

   The measurement frequency, target values, thresholds/benchmark levels are outside the scope of this study. Credit institutions vary in size, complexity, risk profile, and cybersecurity maturity. Consequently, these attributes should be defined by each institution in accordance with their profile, regulatory obligations, and operational context.

3. Example: Asset Inventory and Classification

Requirement Summary	Goal Statement	Questions	Metric
Financial entities shall continuously monitor ICT systems, user activity, and anomalous behavior, and shall implement and demonstrate the effectiveness of detection and prevention controls designed to identify and mitigate incidents, performance degradation, and single points of failure.	Assess the monitoring of ICT systems, tools, and user activity to enable the timely detection of anomalous activities, performance issues, and single points of failure, with respect to monitoring coverage and continuity, from the viewpoint of Security Management and ICT threat detection operations.	How completely and continuously are ICT systems and user activities covered by operational detection mechanisms?	ICT Systems Covered by Operational Detection Mechanisms (%)
		How quickly are ICT-related incidents, anomalous activities, and security events detected after occurrence?	Mean Time to Detect (MTTD)
		How accurate and reliable are the detection mechanisms in identifying genuine events?	False Alert Rate (%)
		How effective are the detection mechanisms in identifying simulated threats and attack scenarios?	Detection Test Success Rate (%)

Table D.1: Example of the metric design

Metric	Definition	Measurement Type	Data source
ICT Systems Covered by Operational Detection Mechanisms	The percentage of ICT systems that are monitored by operational detection mechanisms capable of identifying ICT-related incidents, anomalous activity, performance issues, or security events.	Percentage (%)	Asset inventory, CMDB, monitoring and detection platform inventories, SIEM/XDR coverage reports.
Mean Time to Detect (MTTD)	The average elapsed time between the occurrence of an ICT-related incident, anomalous activity, or security event and its detection.	Time (minutes, hours, or days)	Incident management systems, SIEM/XDR logs, SOC records.
False Alert Rate	The percentage of alerts generated by detection mechanisms that are false positives.	Percentage (%)	SIEM/XDR platforms, SOC investigation records.
Detection Test Success Rate	The percentage of simulated attack scenarios successfully detected.	Percentage (%)	Security testing reports, red-team exercise results.

Table D.2: Example of the metric structure

Metrics Validation Sheet

Instructions: For each goal (G5-G23), please review the associated metrics and indicate whether each metric is:

- **Relevant** – Is it important for DORA compliance?
- **Practical** – Is it realistic for banks/financial institutions to implement?

If yes, **tick (✓) the box**. Use the feedback column for any comments (optional). The definitions, formulas, measurement types, and data sources of all metrics are available in the D.1: Annex A: Metrics and their attributes at the end of this document.

DORA Ref.	G#	Goal Summary	Metric	Relevant	Practical	Feedback (optional)
6.8(e), 6.8(f), 9.1, 10.1, 10.3	G5	Continuous monitoring of ICT systems and user activity enables timely threat detection	ICT Systems Covered by Operational Detection Mechanisms	❑	❑	
			Mean Time to Detect (MTTD)	❑	❑	
			False Alert Rate; Detection Test Success Rate	❑	❑	
6.8(g), 7(d), 11.2(c), 11.2(d), 12.1, 12.2	G6	Recovery, backup, and business continuity capabilities are regularly tested and validated	Recovery & Backup Plans Meeting RTO/RPO Targets	❑	❑	
			Average Recovery Time Gap vs RTO	❑	❑	
			Adverse Scenario Coverage	❑	❑	
7(b), 9.2, 9.3(b), 9.3(c), 11.2(c), 11.2(d)	G7	ICT systems supporting critical or important functions maintain operational trustworthiness	System Availability (Uptime)	❑	❑	
			Confirmed Integrity Violations	❑	❑	
			Confirmed Confidentiality Breaches	❑	❑	
			Cryptographic Signing Coverage	❑	❑	
7(c), 11.4, 11.6(a), 12.4	G8	Redundant capacity supports continuity of critical or important functions	Failover Time	❑	❑	
			Operational Load Sustainability During Failover	❑	❑	
			Failover RTO Compliance	❑	❑	
8.2, 13.1	G10	Threats and vulnerabilities are identified and remediated in a timely manner	Vulnerability Scan Coverage	❑	❑	
			Mean Time to Remediate Vulnerabilities	❑	❑	
			ICT Systems Without Critical Vulnerabilities	❑	❑	
			Critical Vulnerability Backlog	❑	❑	
			Vulnerability Recurrence Rate	❑	❑	
8.7	G12	Risks arising from legacy ICT systems are identified and mitigated	Legacy ICT Systems with Unmitigated Critical Findings	❑	❑	
			Time to Initiate Remediation	❑	❑	
			Vendor Support Verification Rate	❑	❑	
9.3(a), 9.3(d)	G13	Data protection across all operational states	Encryption Coverage (Data in Transit)	❑	❑	

DORA Ref.	G#	Goal Summary	Metric	Relevant	Practical	Feedback (optional)
			Encryption Coverage (Data at Rest)	❑	❑	
			Confirmed Integrity or Confidentiality Violations	❑	❑	
			Integrity Protection Coverage	❑	❑	
9.4(b)	G14	Network architecture limits propagation of ICT disruptions	Time to Isolate Compromised Segment	❑	❑	
			Disruptions Contained Within Initial Segment	❑	❑	
			Disruptions Reaching Critical/Important Systems	❑	❑	
			Segmentation Validation Success Rate	❑	❑	
9.4(c)	G15	Access controls prevent unauthorized use and ensure accountability	Unauthorized Access Attempts Detected & Blocked	❑	❑	
			Access Revocation Time	❑	❑	
			Auditable Access Events	❑	❑	
			Privileged Access Review Compliance	❑	❑	
9.4(d)	G16	Strong authentication is consistently applied	Privileged Accounts with Strong Authentication	❑	❑	
			Authentication-Related Security Events Detected	❑	❑	
			MFA Coverage for Remote Access	❑	❑	
9.4(f)	G18	Timely patch and update management	Patch Deployment Time	❑	❑	
			Patch Compliance Rate	❑	❑	
10.2	G19	Alerting mechanisms support timely incident response	Operational Alert Threshold Coverage	❑	❑	
			Alert Latency	❑	❑	
			Alert Activation Rate	❑	❑	
			False Alert Rate	❑	❑	
12.3	G22	Backup systems are protected and support recovery	Backup Restoration Success Rate	❑	❑	
			Backup Restore Time	❑	❑	
			Unauthorized Access Attempts Blocked (Backup Systems)	❑	❑	
12.7	G23	Data integrity is verified during recovery operations	Integrity Validation Time	❑	❑	
			Integrity Verification Methods Applied	❑	❑	
			Integrity Verification Coverage	❑	❑	
			Integrity Verification Success Rate	❑	❑	

Table D.3: DORA KPI evaluation overview

Overall Questions

1. **Overall, how would you rate these metrics for the financial sector?**

❑ Highly relevant and practical

❑ Relevant but somewhat impractical

❑ Partially relevant

❑ Largely irrelevant or unrealistic

2. **Which metrics would be most difficult for credit institutions to implement in practice?**

3. **Which metrics would be most difficult for credit institutions to implement in practice?**

4. **Which metrics are missing or should be added?**

5. **Any other comments or suggestions based on your industry experience?**

D.1 Annex A: Metrics and their attributes

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G7	System Availability (Uptime)	Percentage of time ICT systems supporting critical or important functions are operational and available.	(Total Time - Downtime) / Total Time $\times 100$	Percentage (%)	Monitoring tools, availability monitoring platforms, service management systems
G7	Confirmed Integrity Violations	Number of confirmed incidents affecting the integrity of systems or data.	Count per measurement period	Count	Incident management systems, security monitoring tools
G7	Confirmed Confidentiality Breaches	Number of confirmed incidents affecting confidentiality of information assets.	Count per measurement period	Count	Incident records, DLP tools, security event management systems
G7	Cryptographic Signing Coverage	Percentage of deployable assets protected by cryptographic signing mechanisms.	(Signed Assets / Total Deployable Assets) $\times 100$	Percentage (%)	CI/CD platforms, software asset repositories
G8	Failover Time	Average time required to activate redundant capacity following disruption of primary systems.	$\sum$ Failover activation times / Number of failover tests	Time	Disaster recovery tests, failover exercise reports
G8	Operational Load Sustainability During Failover	Percentage of tested functions whose redundant capacity sustains full operational load.	(Functions sustaining full load / Functions tested) $\times 100$	Percentage (%)	Failover test reports, capacity testing records
G8	Failover RTO Compliance	Percentage of failover tests completed within defined RTO targets.	(Failover tests meeting RTO / Total failover tests) $\times 100$	Percentage (%)	Disaster recovery testing records
G10	Vulnerability Scan Coverage	Percentage of ICT systems scanned within the required scanning frequency.	(Systems scanned within required frequency / Total systems) $\times 100$	Percentage (%)	Vulnerability scanners, asset inventory
G10	Mean Time to Remediate Vulnerabilities	Average time from vulnerability identification to remediation.	$\sum$ remediation times / Number of vulnerabilities remediated	Time	Vulnerability management platform, ticketing systems
G10	ICT Systems Without Critical Vulnerabilities	Percentage of ICT systems without open critical vulnerabilities.	(Systems with no open critical vulnerabilities / Total systems) $\times 100$	Percentage (%)	Vulnerability management tools
G10	Critical Vulnerability Backlog	Number of open critical or high-severity vulnerabilities.	Count of open critical/high vulnerabilities	Count	Vulnerability management tools
G10	Vulnerability Recurrence Rate	Percentage of remediated vulnerabilities that subsequently reoccur.	(Recurrent vulnerabilities / Total remediated vulnerabilities) $\times 100$	Percentage (%)	Vulnerability management systems

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G12	Legacy ICT Systems with Unmitigated Critical Findings	Percentage of legacy ICT systems with open critical or high-risk findings.	(Legacy systems with open critical findings / Total legacy systems) $\times 100$	Percentage (%)	Risk registers, vulnerability management systems
G12	Time to Initiate Remediation	Average time between risk identification and initiation of remediation.	$\sum$(time from identification to remediation start) / Number of findings	Time	Risk management tools, ticketing systems
G12	Vendor Support Verification Rate	Percentage of production systems with verified ICT support status.	(Systems with verified support status / Total production systems) $\times 100$	Percentage (%)	CMDB, asset inventory, vendor management records
G13	Encryption Coverage (Data in Transit)	Percentage of sensitive data flows protected by approved encryption mechanisms.	(Protected data flows / Total sensitive data flows) $\times 100$	Percentage (%)	Network monitoring tools, architecture repositories
G13	Encryption Coverage (Data at Rest)	Percentage of sensitive data repositories protected by approved encryption mechanisms.	(Encrypted data repositories / Total sensitive data repositories) $\times 100$	Percentage (%)	Storage management tools, database inventories
G13	Confirmed Integrity or Confidentiality Violations	Number of confirmed incidents affecting data integrity or confidentiality.	Count per measurement period	Count	Incident management systems, DLP tools
G13	Integrity Protection Coverage	Percentage of critical data stores protected by integrity validation mechanisms.	(Critical data stores with integrity validation / Total critical data stores) $\times 100$	Percentage (%)	Data management tools, security architecture repositories
G14	Time to Isolate Compromised Segment	Average time required to isolate a compromised network segment.	$\sum$ isolation times / Number of isolation events	Time	Incident response records, network management tools
G14	Disruptions Contained Within Initial Segment	Percentage of ICT disruptions contained within the initially affected network segment.	(Contained disruptions / Total disruptions) $\times 100$	Percentage (%)	Incident reports, network monitoring systems
G14	Disruptions Reaching Critical/Important Systems	Percentage of disruptions that propagated to systems supporting critical or important functions.	(Disruptions reaching critical systems / Total disruptions) $\times 100$	Percentage (%)	Incident records, network monitoring systems
G14	Segmentation Validation Success Rate	Percentage of segmentation tests demonstrating effective network isolation.	(Successful segmentation tests / Total segmentation tests) $\times 100$	Percentage (%)	Penetration tests, network validation exercises

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G15	Unauthorized Access Attempts Detected & Blocked	Percentage of unauthorized access attempts successfully detected and blocked.	(Unauthorized attempts blocked / Total unauthorized attempts detected) $\times 100$	Percentage (%)	IAM tools, SIEM/XDR platforms
G15	Access Revocation Time	Average time required to revoke access rights after compromise detection or user departure.	$\sum$ revocation times / Number of revocations	Time	IAM systems, HR systems, ticketing tools
G15	Auditable Access Events	Percentage of access events that are fully logged and auditable.	(Fully logged access events / Total access events) $\times 100$	Percentage (%)	Log management systems, SIEM platforms
G15	Privileged Access Review Compliance	Percentage of privileged accounts reviewed within the required review cycle.	(Privileged accounts reviewed / Total privileged accounts) $\times 100$	Percentage (%)	PAM tools, IAM systems
G16	Privileged Accounts with Strong Authentication	Percentage of privileged accounts protected by strong authentication mechanisms.	(Privileged accounts with strong authentication / Total privileged accounts) $\times 100$	Percentage (%)	IAM systems, authentication platforms
G16	Authentication-Related Security Events Detected	Number of detected authentication-related security events.	Count per measurement period	Count	SIEM/XDR tools, authentication platforms
G16	MFA Coverage for Remote Access	Percentage of remote access accounts protected by multi-factor authentication.	(Remote access accounts protected by MFA / Total remote access accounts) $\times 100$	Percentage (%)	Remote access platforms, IAM systems
G18	Patch Deployment Time	Average time from patch release to installation.	$\sum$(patch installation date - patch release date) / Number of patches	Time	Patch management systems
G18	Patch Compliance Rate	Percentage of systems patched within policy-defined timeframes.	(Systems patched within policy timeframe / Total systems requiring patches) $\times 100$	Percentage (%)	Patch management systems, asset inventory
G19	Operational Alert Threshold Coverage	Percentage of defined alert thresholds with verified automatic alerting functionality.	(Operational alert thresholds / Total defined alert thresholds) $\times 100$	Percentage (%)	Monitoring systems, SIEM/XDR platforms
G19	Alert Latency	Average time between threshold breach and alert generation.	$\sum$(alert generation time - threshold breach time) / Number of alerts	Time	Monitoring platforms, SIEM/XDR systems
G19	Alert Activation Rate	Percentage of threshold breaches that triggered an automatic alert.	(Threshold breaches triggering alerts / Total threshold breaches) $\times 100$	Percentage (%)	Monitoring tools, SIEM/XDR systems
G19	False Alert Rate	Percentage of alerts determined to be false positives.	(False alerts / Total alerts) $\times 100$	Percentage (%)	SIEM/XDR systems, SOC records

Goal #	Metric Name	Definition	Formula	Measurement Type	Data Sources
G22	Backup Restoration Success Rate	Percentage of backup restoration tests completed successfully within defined recovery objectives.	(Successful backup restorations / Total backup restoration tests) $\times 100$	Percentage (%)	Backup platforms, recovery test reports
G22	Backup Restore Time	Average time required to restore systems or data from backup.	$\sum$ restore times / Number of restore operations	Time	Backup management systems
G22	Unauthorized Access Attempts Blocked (Backup Systems)	Percentage of unauthorized access attempts to backup systems that were detected and blocked.	(Blocked unauthorized attempts / Total unauthorized attempts) $\times 100$	Percentage (%)	Backup security logs, SIEM/XDR platforms
G23	Integrity Validation Time	Average time required to complete integrity verification following recovery initiation.	$\sum$ validation times / Number of recovery operations	Time	Recovery operation records
G23	Integrity Verification Methods Applied	Average number of integrity verification methods applied per recovery operation.	$\sum$ verification methods / Number of recovery operations	Number	Recovery procedures, test reports
G23	Integrity Verification Coverage	Percentage of recovered assets subjected to integrity validation.	(Recovered assets validated / Total recovered assets) $\times 100$	Percentage (%)	Recovery records, validation logs
G23	Integrity Verification Success Rate	Percentage of recovery operations that successfully passed integrity verification.	(Recovery operations passing integrity verification / Total recovery operations) $\times 100$	Percentage (%)	Recovery reports, validation records

Table D.4: Resilience KPI evaluation overview